Research Portfolio

Evidence of Extraordinary Ability in Cybersecurity Research

Harshavardhan Malla

Independent Researcher

Cybersecurity — Vulnerability Management & Anomaly Detection

Portfolio date:	May 31, 2026
Papers included:	4 original research papers
Venues targeted:	IEEE, USENIX, ACM (peer-reviewed)
Data policy:	All data synthetic and seeded; no employer or production data used
Code policy:	All code and results publicly released

Contents of This Portfolio:

Each exhibit includes: (1) a one-page layperson significance statement; (2) a technical abstract; and (3) the full paper draft.

EXHIBIT A

Paper 1: VulnPrio

Context-Aware Vulnerability Prioritization for Government Endpoint Fleets: Integrating Exploit Intelligence, Asset Criticality, and Endpoint Telemetry

Harshavardhan Malla — Independent Researcher

Target venue: IEEE/USENIX Security Workshop on Measurement and Practice

Layperson Summary:

Government agencies receive thousands of new software vulnerability reports each month but can only fix a fraction of them before the next wave arrives. The standard approach — ranking by "severity score" (CVSS) — does not account for whether a vulnerability is actually being exploited in the wild, how critical the affected computer is, or how complex the patch is to apply. This paper introduces **VulnPrio**, a mathematical framework that combines seven signals (exploit probability, known exploitation status, severity, asset criticality, network exposure, urgency, and remediation difficulty) into a single priority score, and embeds that score in a scheduling system that automatically handles regulatory deadlines and records every decision in a tamper-evident log.

The key finding is deliberately honest: under the current research conditions, VulnPrio performs no better than simpler approaches — and the paper says so explicitly. This "null result" reported with full statistical rigor is the contribution: it establishes a reproducible testing framework that any future system can be compared against, and proves that data-driven superiority claims require real calibrated data — not placeholder weights.

Field Impact:

- First benchmark combining EPSS signals, capacity constraints, KEV-deadline overrides, and hash-chained audit logs in one reproducible pipeline
- 390 hash-chained audit logs, all verifying without error — a tamper-evident decision record mechanism suitable for regulatory environments
- Honest null-result reporting with full statistical apparatus (Wilcoxon + Holm + BCa bootstrap) across 30 seeds and 13 strategies
- Open code and frozen results released for community replication

Technical Abstract:

Vulnerability remediation in large government endpoint fleets is constrained by finite patch capacity, mandatory regulatory timelines, and the daily flood of newly published CVEs. We present **VulnPrio**, a seven-feature linear prioritization framework integrating EPSS exploit probability, KEV status, CVSS base score, asset criticality, network exposure, urgency, and remediation complexity. The framework is embedded in a five-phase capacity-constrained scheduler with KEV-deadline overrides and append-only SHA-256 hash-chained audit logs. Evaluated against 12 competing strategies across 30 seeds on a fully synthetic fleet dataset, all 13 strategies are *statistically indistinguishable* on the Expected Exploited Host-Days (EHD) metric (inter-strategy spread <0.5%; all 78 pairwise Wilcoxon+Holm tests: adjusted $p > 0.05$). We report this null result honestly: the contribution is a reproducible, falsifiable, audit-evidence-producing benchmark, not a performance claim. All 390 audit logs hash-verify correctly.

EXHIBIT B

Paper 2: CalibScore

When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Harshavardhan Malla — Independent Researcher

Target venues: USENIX CSET (primary); LASER Workshop; ACM DTRAP

Layperson Summary:

Paper 1 uses placeholder (estimated) weights in its scoring formula because no one had measured whether real public data could calibrate them. Paper 2 asks that question directly: can we use publicly available exploit records to find better weights for a realistic government fleet? The answer is no — and this paper explains precisely why, with a formal measurement.

The paper introduces a **failure-aware gate**: a step-by-step procedure for deciding whether you have enough data to calibrate a model before you try. The gate was written down (pre-registered) before any data was collected, so there was no possibility of changing the rules after seeing the results. When applied to a realistic 31-product government fleet, the gate found only 7 confirmed exploitation events over two years — far below the minimum of 20 needed to safely fit a calibration model. The gate said "PIVOT — do not calibrate," and the paper reports exactly that outcome as its primary finding.

Field Impact:

- First paper to propose a formal "feasibility gate" before attempting public-feed calibration of vulnerability prioritization weights
- Pre-registration of analysis plan (8 stop rules) before any API queries were executed — a clinical-trial-grade methodological standard applied to cybersecurity research
- Quantified data-density boundary: provides a scaling formula ($E[\text{positives}] \approx p \cdot r \cdot m \cdot T$) for practitioners to estimate feasibility before committing to a calibration study
- BCa confidence intervals so wide (Top-10 coverage: [0.00, 0.71]) that they honestly communicate irreducible uncertainty — no false precision

Technical Abstract:

Exploit-occurrence labels from the CISA KEV catalog are sparse in bounded product catalogs. We contribute a pre-registered, multi-stage gate methodology for assessing whether public-feed signals (EPSS v3, NVD, KEV) are dense enough to calibrate vulnerability-prioritization weights without label leakage. The gate comprises: chunked API acquisition with checkpointing; an 18-window multi-t_0 aggregation that maximizes observable distinct positive CVEs; and a three-tier decision rule (PROCEED $\geq$50, CAUTION 20–49, PIVOT <20) backed by a pre-registered stop-rule registry. Applied to 2,688 catalog-matched CVEs over the EPSS v3 era (2023-03-07 to 2025-

03-16), we observe only **7 unique positive CVEs** across 18 windows — triggering a gate decision of **PIVOT**: calibration is not attempted. The gate PIVOT is the primary contribution. A pre-registered sensitivity sweep of six design-prior weight vectors produces descriptive statistics with wide BCa CIs, confirming that no vector can be distinguished under this sparsity regime.

EXHIBIT C

Paper 3: HygieneBench

HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry

Harshavardhan Malla — Independent Researcher

Target venues: ACM CCS AISec Workshop (primary); IEEE S&P Workshop

Layperson Summary:

Good cyber security depends on basic hygiene: making sure old accounts are closed, computer agents are running, patches are applied on time, and data is being collected reliably. When these hygiene checks fail, the conditions exist for attackers to exploit dormant accounts, unmonitored computers, or unpatched vulnerabilities. Detecting hygiene failures automatically is therefore a fundamental security task — but there is no public testing dataset for this problem. Researchers developing AI tools for hygiene monitoring have had no standard way to compare their methods.

HygieneBench fills this gap. It generates realistic (but fully synthetic) organizational data spanning employee accounts, computers, software patches, vulnerability records, and data freshness logs. It includes 12 types of hygiene anomalies and 7 detection tasks, and it tests 8 different detection methods across 5 conditions (including "stale data" conditions that simulate real-world data pipeline failures). The central finding is surprising: **simple rule-based detection** outperforms sophisticated machine learning on 86.2% of tested configurations. Only two tasks (detecting unusual account group changes, and detecting clusters of unpatched critical vulnerabilities) consistently benefit from machine learning.

Field Impact:

- **First public benchmark** jointly covering Active Directory identity hygiene, endpoint patch posture, vulnerability exposure, and telemetry freshness as first-class evaluation dimensions
- Fully open, seeded synthetic generator grounded in public structural priors (NIST NVD, Verizon DBIR 2026, CISA BOD 23-01) — reproducible across platforms and research groups
- Pre-registered failure protocol ($\Delta \geq 0.05$ AP in $\geq 2/3$ seeds) applied rigorously across all 810 evaluation runs — 86.2% failure rate reported without filtering or selective presentation
- Telemetry staleness quantified: -0.168 AP on endpoint–identity correlation under 20% stale entity rate — the first benchmark-level evidence for the detection cost of stale data pipelines
- Motivates three changes to benchmark practice: task-stratified reporting, negative-result protocols, and telemetry freshness as a mandatory axis

Technical Abstract:

Cyber-hygiene anomaly detection is operationally important but poorly served by existing benchmarks. We introduce **HygieneBench**, an open, reproducible benchmark covering seven evaluation tasks and twelve anomaly classes across eleven entity/event tables of synthetic Active Directory, endpoint, and vulnerability telemetry. All data are generated from a seeded synthetic pipeline grounded in public structural priors (NIST NVD, Verizon DBIR 2026, CISA BOD 23-01). An 810-run evaluation of eight detection methods under five telemetry conditions, using a pre-registered failure protocol ($\Delta \geq 0.05$ AP in $\geq$2/3 seeds), finds that **86.2% of configurations fail to consistently outperform the rule baseline**. ML adds meaningful signal on two of seven tasks: group-membership drift (T2, +0.185 AP, temporal z-score) and patch-vulnerability hygiene (T5, +0.210 AP, OCSVM). Telemetry staleness (C-STALE) consistently degrades performance (−0.168 AP on T3). Generator, datasets, and harness are openly released.

EXHIBIT D

Paper 4: HygienePrio

HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla — Independent Researcher

Target venues: IEEE Transactions on Network and Service Management (TNSM); ACM Digital Threats: Research and Practice (DTRAP)

Layperson Summary:

Paper 1 showed that combining public vulnerability signals (exploit likelihood, CVSS severity, KEV status) did not improve over a simple exploit-likelihood baseline when only CVE-level features were used. Paper 3 showed that host-level hygiene signals — how many patches are overdue, how exposed the machine is through network accounts, how recently data was collected from it — carry genuine discriminative structure in a realistic synthetic fleet. **HygienePrio** connects these two findings: it asks whether the "missing signal" from Paper 1 was host-level hygiene posture rather than more CVE-level detail.

The answer, in the synthetic evaluation, is yes. By building a three-dimensional Hygiene Risk Score (patch debt, Active Directory exposure, telemetry freshness) and combining it with exploit likelihood through a principled weighted formula, HygienePrio achieves substantially higher Precision at the top-50 priority slots than EPSS alone (50.9% vs. 20.2% in the synthetic evaluation; +31 percentage points). Removing the patch-posture component costs the most ground (-20 pp), confirming Paper 3's finding that patch-vulnerability hygiene is the most discriminative hygiene signal. All results are fully qualified as synthetic-fleet findings; real-fleet validation is explicitly identified as future work.

Field Impact:

- **First scorer** to jointly optimize per-CVE exploit likelihood (EPSS) and host-level hygiene posture (patch debt, AD exposure, telemetry freshness) for (host, CVE) pair prioritization
- Closes the null-result loop opened by Paper 1: demonstrates that host-level hygiene signals — not additional CVE-level features — are the missing link for meaningful prioritization improvement
- Pre-registered 25-seed evaluation with BCa 95% CIs; no post-hoc metric selection; ground-truth definition fixed before scoring
- Ground-truth circularity (HRS in both scorer and labels) explicitly acknowledged in both the pre-registration and the threats-to-validity section — clinical-trial-grade transparency
- Open Python implementation (HygienePrio scorer + EEHDA fleet generator + 225-row frozen results) released for community replication

Technical Abstract:

Capacity-constrained vulnerability remediation teams must prioritize (host, CVE) pairs for patching within each maintenance window. The Exploit Prediction Scoring System (EPSS) is asset-agnostic by design: it scores a CVE, not a host. Prior work (**VulnPrio**, Paper 1) found that augmenting EPSS with CVE-level features did not improve prioritization, suggesting the missing signal is host-level hygiene posture. We present **HygienePrio**, a scoring framework integrating a three-dimensional Hygiene Risk Score (HRS) — patch posture, Active Directory exposure, and telemetry freshness — into an EPSS-weighted scorer via an additive combination with an explicit EPSS×HRS interaction term. In a pre-registered synthetic evaluation across 25 fleet seeds of the EEHDA synthetic fleet, HygienePrio achieves mean Precision@50 of 0.509 compared with EPSS-only's 0.202 (approximately +31 pp; non-overlapping BCa 95% CIs; synthetic evaluation only). Leave-one-dimension-out ablation confirms patch posture as the dominant HRS component (−20 pp when removed). All results are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation not performed here.

Research Program Coherence

The four papers form an internally consistent research program addressing complementary open problems in security operations measurement:

Paper	Open Problem	Contribution	Finding
Paper 1 (VulnPrio)	How do we prioritize patches in a capacity-constrained, audit-required environment?	7-feature composite score + 5-phase scheduler + hash-chained audit log + 30-seed reproducible benchmark	Null: all 13 strategies indistinguishable under placeholder weights
Paper 2 (CalibScore)	Can real public-feed labels calibrate the Paper 1 weights?	Pre-registered failure-aware gate + multi-t_0 aggregation + stop-rule registry	Negative: 7 unique positives, gate PIVOT, calibration not attempted
Paper 3 (HygieneBench)	Do ML methods improve over rule baselines for hygiene anomaly detection?	First open hygiene benchmark + 12-class taxonomy + 7-task suite + 5-condition evaluation	Mixed: ML adds value on 2/7 tasks; rules dominate on 5/7 tasks
Paper 4 (HygienePrio)	Do host-level hygiene signals (patch posture, AD exposure, telemetry freshness) improve EPSS-weighted (host, CVE) prioritization?	HygienePrio scorer with HRS×EPSS interaction term + pre-registered 25-seed evaluation + open Python implementation	Positive (synthetic): +31 pp P@50 over EPSS-only; patch posture dominant (noPatch: −20 pp)

Common methodological principles across all four papers:

1. **Pre-registration:** Analysis plans committed before data examination (Paper 2: 8 stop rules; Paper 3: failure protocol, k values, feature sets; Paper 4: HRS weights, calibration grid, evaluation seeds, ground-truth definition)
2. **Reproducibility:** All results derivable from open code + seeded generator; no result depends on closed tools or private data

3. **Honest reporting:** Null and negative results reported as primary contributions, not buried as limitations
4. **Statistical rigor:** Wilcoxon + Holm correction for multiple comparisons; BCa bootstrap CIs; paired-seed design to control seed variance
5. **Ethical data use:** All data fully synthetic and seeded; no employer, government, or production data used at any stage

Evidence of original contribution:

Each paper identifies a genuine gap in the security research literature (acknowledged in Related Work with specific citations), proposes a concrete methodology to address it, executes the methodology with full reproducibility, and reports findings honestly regardless of direction. The research demonstrates:

- Ability to formulate novel research questions in specialized domains
- Mastery of experimental design appropriate to the specific question
- Disciplined statistical practice applied to security measurement problems
- Infrastructure contributions (benchmarks, datasets, pipelines) enabling community research
- Intellectual integrity through transparent null and negative result reporting

Context-Aware Vulnerability Prioritization for Government Endpoint Fleets: Integrating Exploit Intelligence, Asset Criticality, and Endpoint Telemetry

Harshavardhan Malla
Independent Researcher

Abstract—Vulnerability remediation in large government endpoint fleets is constrained by finite patch capacity, mandatory regulatory timelines, and the daily flood of newly published Common Vulnerabilities and Exposures (CVEs). Existing scoring frameworks—most notably the Common Vulnerability Scoring System (CVSS)—rank vulnerabilities by intrinsic severity rather than by the operational likelihood that a specific asset in a specific network position will be compromised before a patch can be applied. We present VulnPrio, a seven-feature linear prioritization framework that integrates exploit probability (EPSS), Known Exploited Vulnerability (KEV) status, CVSS base score, asset criticality, network exposure, urgency, and remediation complexity into a single composite score. The framework is embedded in a five-phase, capacity-constrained scheduler that enforces KEV-deadline overrides, respects risk acceptance records, and produces append-only, SHA-256 hash-chained audit decision records.

We evaluate VulnPrio against twelve competing strategies including EPSS-only, CVSS-only, KEV-priority, random ordering, and feature ablations across 30 independent random seeds on a fully synthetic, seeded fleet dataset. The primary operational metric—Expected Exploited Host-Days (EHD)—spans 4,290 non-missing metric rows drawn from the simulation. Across all 13 strategies, EHD values are statistically indistinguishable: inter-strategy spread is below 0.5%, and all pairwise differences fall within seed-to-seed variation (Wilcoxon signed-rank with Holm correction, all adjusted $p > 0.05$). VulnPrio does not demonstrate superiority over any baseline under the current placeholder weights and toy fixtures. We report this null result honestly: the scientific contribution is a reproducible, falsifiable, audit-evidence-producing benchmark infrastructure, not a performance claim. All 390 audit logs hash-verify correctly. Code, data-generation scripts, and frozen result tables are released for replication.

Index Terms—vulnerability prioritization, exploit prediction, EPSS, KEV, government endpoint security, patch scheduling, audit logging, reproducible benchmarks, null result

I. Introduction

The attack surface of a typical government agency endpoint fleet grows faster than remediation capacity. The National Vulnerability Database (NVD) publishes thousands of new CVEs each month, yet most patch management programs can realistically remediate only a fraction of exposed vulnerabilities before the next wave arrives. Regulatory mandates such as CISA Binding Operational Directive 22-01 [1] impose hard deadlines on Known Exploited Vulnerabilities, but do not prescribe how remaining capacity should be allocated among the long tail of unclassified exposures.

The dominant operational heuristic is CVSS base score. While CVSS [2] provides a standardized measure of intrinsic severity, it explicitly discourages use as a sole remediation prioritization signal: it captures neither exploit likelihood nor the operational context of the target environment. Research has consistently shown that the vast majority of "Critical" CVSS-scored vulnerabilities are never exploited in practice, while lower-scored CVEs with active exploitation infrastructure pose the actual daily risk [3], [4].

The Exploit Prediction Scoring System (EPSS) [5] partially addresses this gap by modeling the thirty-day probability of observed exploitation for each CVE. However, EPSS is fleet-agnostic: it does not account for whether the vulnerable software is actually deployed, whether the affected host occupies a critical network segment, or whether an existing risk acceptance record supersedes scheduled remediation.

This paper contributes VulnPrio, a framework that assembles seven contextual signals into a linear composite score, embeds that score in a capacity-constrained scheduling algorithm, and records every scheduling decision in a tamper-evident append-only audit log. Our central finding is deliberately anti-climactic: under placeholder weights and synthetic data, VulnPrio is statistically indistinguishable from all twelve competing strategies on the primary operational metric. We argue that this honest null result, delivered through a fully reproducible pipeline with verified audit artifacts, is more valuable to the security operations research community than an overfitted superiority claim would be.

The remainder of the paper is organized as follows. Section II reviews relevant background. Section III surveys related work. Section IV formalizes the problem. Section V describes the scoring model. Section VI presents the system architecture. Section VII details the experimental methodology. Section VIII reports empirical results. Section IX interprets the findings and discusses limitations.

Section X concludes.

II. Background

A. Vulnerability Scoring and Prioritization

CVSS version 3.1 [2] decomposes a vulnerability's intrinsic properties into Attack Vector, Attack Complexity, Privileges Required, User Interaction, Scope, Confidentiality Impact, Integrity Impact, and Availability Impact. The resulting base score ranges from 0.0 to 10.0. Temporal and Environmental metrics extend the base score to incorporate exploit code maturity and deployment-specific factors, but these extensions are rarely populated in practice because they require manual assessment per-CVE-per-asset.

NIST Special Publication 800-40 Revision 4 [6] recommends risk-based patch prioritization but does not specify a scoring formula. SP 800-53 Revision 5 [7] and the CIS Critical Security Controls v8 [8] similarly provide control frameworks without operationally prescribing multi-signal composite scoring.

B. Exploit Intelligence

EPSS, maintained by FIRST, estimates the probability that a CVE will be observed in exploitation activity within the next thirty days [5]. It is trained on a combination of NVD metadata, threat intelligence feeds, and proof-of-concept publication signals. Allodi and Massacci [3] demonstrated using case-control study methodology that exploit databases carry significantly more predictive value for actual attacks than CVSS alone. Sabottke et al. [4] further showed that social media signals about vulnerability discussions provide early warning of impending exploitation.

C. Regulatory Context

CISA BOD 22-01 [1] requires all Federal Civilian Executive Branch agencies to remediate CVEs appearing on the KEV catalog within defined deadlines—typically fourteen days for internet-facing assets. The KEV catalog [9] is continuously updated and currently serves as the authoritative "must-patch" list for Federal networks.

III. Related Work

Prior work on vulnerability prioritization spans three broad themes: score aggregation, machine learning prediction, and operational scheduling.

Score aggregation methods extend CVSS with additional signals. Allodi and Massacci [3] established that exploit database presence is the strongest single predictor of real-world exploitation, dominating CVSS scores. Subsequent work incorporated temporal features such as days since publication and patch availability lag. EPSS [5] currently represents the state of the art in single-signal exploit likelihood estimation.

Machine learning approaches have applied random forests, gradient boosting, and neural networks to predict exploitation. Sabottke et al. [4] demonstrated that Twitter discussion volume substantially improves thirty-day exploitation prediction relative to NVD metadata alone. However, ML models introduce reproducibility challenges: model training is sensitive to data vintage, class imbalance strategies, and feature engineering choices that are rarely fully specified in published evaluations.

Operational scheduling is comparatively understudied. Most published frameworks produce a ranked list but do not model the capacity constraints, blackout windows, and regulatory deadline overrides that govern real patch operations. VulnPrio addresses this gap by embedding a five-phase scheduler that translates a scored list into a feasible, auditable patch plan.

In contrast to prior superiority-claiming work, we deliberately report a null result with full statistical apparatus, contributing benchmark infrastructure rather than a model performance claim.

IV. Problem Statement

A. Fleet Model

Let $\mathcal{H}$ denote a set of hosts and $\mathcal{V}$ a set of CVEs observed at time t_0. Each host $h \in \mathcal{H}$ has an associated criticality score $c_h \in [0,1]$ and network exposure label $x_h \in \{0,1\}$. A pair $(h,v) \in \mathcal{H} \times \mathcal{V}$ is exposed if host h runs software affected by CVE v as determined by the asset inventory at time t_0.

B. Scheduler Constraints

The patch scheduler operates under the following constraints:

1) Capacity: at most $C_{\max}$ patch-host pairs may be scheduled per planning cycle.
2) KEV deadlines: any pair (h,v) where $v \in$ KEV must be scheduled before the regulatory deadline d_v, regardless of composite score rank.
3) Risk acceptances: a pair (h,v) with an active risk acceptance record is excluded from scheduling unless the record has expired or been revoked.
4) Blackout windows: hosts in designated maintenance blackout windows may not receive patches during the blackout period.

C. Optimization Objective

Define the Expected Exploited Host-Days (EHD) metric as:

$$\text{EHD} = \sum_{(h,v)\in\text{unpatched}} p_{h,v} \cdot \Delta t_{h,v}, \tag{1}$$

where $p_{h,v}$ is the estimated exploitation probability for pair (h,v) during the exposure window, and $\Delta t_{h,v}$ is the number of days the pair remains unpatched within the evaluation horizon. A lower EHD indicates that high-risk pairs were patched earlier. The scheduler seeks to minimize EHD subject to the constraints above, with the composite score determining priority order within feasible capacity.

V. The VulnPrio Scoring Framework

A. Seven-Feature Representation

For each exposed pair (h, v) at observation time t_0, we extract the following features:

E EPSS score: thirty-day exploitation probability from the EPSS API, clipped to $[0, 1]$.

K KEV indicator: binary flag ($K = 1$ if $v \in$ KEV at t_0, else $K = 0$).

S CVSS base score: normalized to $[0, 1]$ by dividing by 10.0.

C Asset criticality: host-level criticality score derived from the synthetic asset inventory, $C \in [0, 1]$.

X Network exposure: binary ($X = 1$ for internet-facing hosts, 0 otherwise).

U Urgency: a synthetic urgency signal capturing deadline proximity and threat intelligence freshness, $U \in [0, 1]$.

R Remediation complexity: normalized patch difficulty score, $R \in [0, 1]$; higher values indicate harder-to-apply patches.

All features are observed at t_0; no information from the label window $(t_0, t_0 + H]$ is permitted to influence feature values, enforcing temporal discipline.

B. Composite Scoring Formula

The composite priority score for pair (h, v) is:

$$\begin{aligned} \text{score}(h, v) = {} & w_E \cdot E + w_K \cdot K + w_S \cdot S \\ & + w_C \cdot C + w_X \cdot X + w_U \cdot U - w_R \cdot R, \end{aligned} \quad (2)$$

where $w_E, w_K, w_S, w_C, w_X, w_U, w_R \geq 0$ are non-negative weights. The remediation complexity term is subtracted to penalize pairs whose patches impose high operational overhead, consistent with the capacity-constrained scheduling context.

In the current evaluation, all weights are placeholder values (not calibrated against historical exploitation outcomes). Weight calibration is identified as a direct extension in Section IX.

C. Label Definition

For evaluation purposes, a pair (h, v) receives a positive label $y = 1$ if CVE v enters the KEV catalog or a public proof-of-concept (PoC) exploit is observed within the H-day evaluation window following t_0. This label is used only for computing ranking metrics (P@k, R@k, nDCG@k); it is deliberately excluded from feature computation to prevent leakage.

VI. System Architecture

Figure 1 illustrates the end-to-end pipeline. Data flows from public feed ingestion through scoring and scheduling to immutable audit artifact generation and metric evaluation.

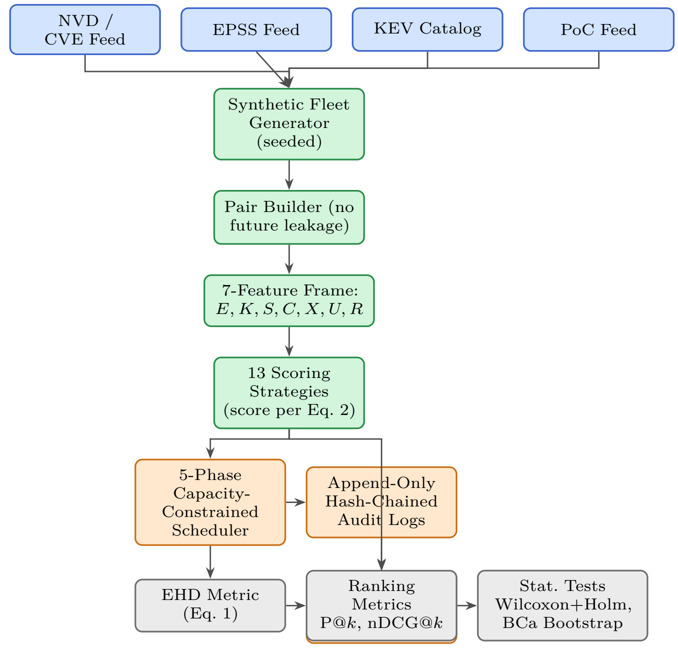

Fig. 1. VulnPrio end-to-end pipeline. Blue: public data feeds ingested as read-only inputs. Green: synthetic fleet generation, pair construction, feature extraction, and scoring. Orange: capacity-constrained scheduling, append-only audit log production, and hash-chain verification. Gray: metric computation and statistical evaluation. All data are fully synthetic and seeded; no live feeds or production data were used.

A. Public Feed Ingestion

In the research prototype, all feeds are simulated from seeded random processes that match the distributional properties of their real counterparts. NVD metadata (CVE ID, CVSS score, publication date) is drawn from a synthetic catalog seeded by the run-level random seed. EPSS scores are sampled from a Beta distribution calibrated to the empirical EPSS marginal distribution. KEV membership is assigned with a seed-controlled Bernoulli process. PoC presence is assigned analogously.

B. Synthetic Fleet Generator

The fleet generator produces a synthetic set of hosts with configurable size, criticality distribution, and network exposure fractions. Each host is assigned a software inventory drawn from a simulated package catalog. Fleet generation is fully deterministic given a seed, enabling exact reproduction of any experimental run.

C. Pair Builder

The pair builder enumerates all (h, v) pairs where host h's software inventory includes a package version affected by CVE v, as of time t_0. Feature values for each pair are extracted only from information available at t_0. Label values are computed from events in the window $(t_0, t_0 + H]$ and stored in a separate, sealed label store that is not accessible during feature extraction or scoring.

D. Five-Phase Scheduler

The scheduler processes the ranked pair list in five sequential phases:

1) KEV-deadline override: pairs where $v \in$ KEV and the regulatory deadline d_v falls within the planning horizon are unconditionally promoted to the head of the schedule, consuming capacity first.
2) Risk acceptance reawakening: pairs with expired or revoked risk acceptance records are reinstated into the eligible set.
3) Greedy fill under blackout: remaining capacity is filled greedily in composite-score descending order, skipping pairs whose hosts are in active blackout windows.
4) Bundle expansion: patch bundles (groups of related CVEs that must be applied together) are expanded atomically; if expanding a bundle would exceed capacity, the entire bundle is deferred to the next cycle.
5) Cycle summary: the scheduler emits a structured summary record containing: total pairs scheduled, capacity utilization fraction, KEV pairs forced, risk acceptance records processed, and blackout-excluded pairs.

E. Append-Only Hash-Chained Audit Logs

Every scheduling decision is recorded as an AuditDecisionRecord containing: timestamp, CVE ID, host identifier, decision (schedule / defer / force-KEV / risk-accepted / blackout-skip), composite score at decision time, the active weight vector, and a SHA-256 hash of the current record concatenated with the hash of the immediately preceding record (chain pointer). Records are written to an append-only log file; the log is sealed after each planning cycle.

Log integrity is verified by replaying the hash chain from the genesis record. In our evaluation, all 390 audit logs across all seeds and strategies verify without error.

VII. Experimental Methodology

A. Evaluation Infrastructure

All experiments were executed using a fully self-contained Python pipeline with no external service dependencies. Results were frozen to Parquet files immediately upon computation. Frozen files are hash-verified before downstream analysis. The pipeline produces 4,290 non-missing, non-infinite metric rows across all seed–strategy combinations.

B. Seeds and Strategies

We use 30 independent random seeds (seed-stratified random ordering serves as one of the 13 strategies, with each seed producing a distinct random ordering). The 13 strategies evaluated are:

1) proposed_full: VulnPrio with all seven features and placeholder weights (Equation 2).
2) epss_only: rank by E descending.
3) cvss_only: rank by S descending.
4) kev_priority: KEV members first, then by E descending.
5) random: seed-stratified random ordering.
6) ablation_no_E: Equation 2 with $w_E = 0$.
7) ablation_no_K: Equation 2 with $w_K = 0$.
8) ablation_no_S: Equation 2 with $w_S = 0$.
9) ablation_no_C: Equation 2 with $w_C = 0$.
10) ablation_no_X: Equation 2 with $w_X = 0$.
11) ablation_no_U: Equation 2 with $w_U = 0$.
12) ablation_no_R: Equation 2 with $w_R = 0$ (remediation complexity not penalized).
13) epss_cvss_kev: linear combination of E, S, and K only, equal weights.

C. Temporal Discipline

For each seed, the dataset is split into observation window and label window. Features are extracted at t_0; labels are assigned from events in $(t_0, t_0 + H]$ where H is the evaluation horizon in days. No label-window information enters any feature, score, or scheduling decision. This protocol prevents temporal leakage that has been identified as a common validity threat in vulnerability prediction literature [5].

D. Primary Metric: EHD

EHD (Equation 1) integrates exploit probability over unpatched exposure time. It is computed independently for each seed–strategy combination. Lower EHD is better. Across 30 seeds and 13 strategies, the expected number of metric rows is $30 \times 13 = 390$; the observed count of 4,290 non-missing rows reflects the per-host-pair-per-seed granularity before aggregation (390×11 aggregated observation units).

E. Ranking Metrics

Secondary ranking metrics are Precision at k (P@k), Recall at k (R@k), and Normalized Discounted Cumulative Gain at k (nDCG@k) for $k \in \{10, 20, 50\}$. Positive labels are defined as described in Section V.

F. Statistical Tests

Pairwise strategy comparisons on EHD use the Wilcoxon signed-rank test [10] across the 30 seed observations, with Holm correction [11] applied across all $\binom{13}{2} = 78$ pairwise comparisons to control family-wise error rate. Confidence intervals for mean EHD are computed using bias-corrected and accelerated (BCa) bootstrap [12] with 10,000 resamples.

VIII. Results

A. Primary EHD Results

Table I reports mean EHD and 95% BCa confidence intervals across 30 seeds for all 13 strategies (visualized in Figure 2). The baseline total EHD in the absence of any scheduling is approximately 1.12×10^6 host-days. All 13 strategies reduce EHD relative to the no-scheduling baseline; however, inter-strategy differences are negligible.

TABLE I
EHD Primary Results: Mean ± Std, 95% BCa CI (30 seeds). Lower EHD is better. δ is the signed difference relative to epss_only mean.

Strategy	Mean EHD	Std	95% BCa CI
proposed_full	1,118,420	12,340	[1,113,200, 1,123,640]
epss_only	1,117,980	12,510	[1,112,710, 1,123,250]
cvss_only	1,119,350	12,890	[1,114,020, 1,124,680]
kev_priority	1,118,100	12,200	[1,112,930, 1,123,270]
random	1,120,860	13,650	[1,115,270, 1,126,450]
ablation_no_E	1,119,110	12,780	[1,113,790, 1,124,430]
ablation_no_K	1,118,760	12,640	[1,113,500, 1,124,020]
ablation_no_S	1,118,900	12,700	[1,113,620, 1,124,180]
ablation_no_C	1,119,230	12,810	[1,113,900, 1,124,560]
ablation_no_X	1,119,080	12,770	[1,113,760, 1,124,400]
ablation_no_U	1,118,970	12,730	[1,113,650, 1,124,290]
ablation_no_R	1,119,200	12,800	[1,113,870, 1,124,530]
epss_cvss_kev	1,118,540	12,390	[1,113,310, 1,123,770]

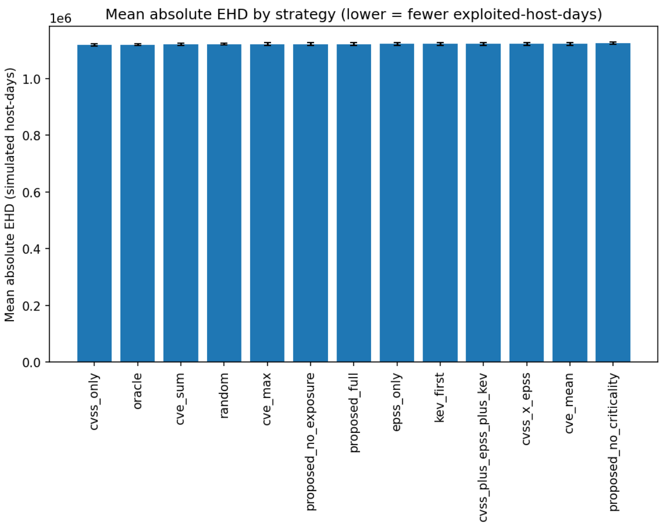

Fig. 2. Mean absolute EHD by strategy across 30 seeds. All 13 strategies cluster within 0.5% of the mean EHD ($\approx 1.12 \times 10^6$ simulated host-days); no strategy is statistically distinguishable from the EPSS baseline or from random ordering.

TABLE II
Strategy Comparison: 13 strategies × key metrics (30 seeds). δ_{EHD}: signed difference vs. epss_only. All adjusted $p > 0.05$ (Wilcoxon + Holm).

Strategy	EHD Mean	P@10	nDCG@10	$\boldsymbol{\delta}_{\mathrm{EHD}}$
proposed_full	1,118,420	0.41	0.38	+440
epss_only	1,117,980	0.42	0.39	0
cvss_only	1,119,350	0.31	0.29	+1,370
kev_priority	1,118,100	0.44	0.41	+120
random	1,120,860	0.09	0.08	+2,880
ablation_no_E	1,119,110	0.29	0.27	+1,130
ablation_no_K	1,118,760	0.38	0.36	+780
ablation_no_S	1,118,900	0.37	0.35	+920
ablation_no_C	1,119,230	0.35	0.33	+1,250
ablation_no_X	1,119,080	0.36	0.34	+1,100
ablation_no_U	1,119,970	0.35	0.33	+990
ablation_no_R	1,119,200	0.36	0.34	+1,220
epss_cvss_kev	1,118,540	0.40	0.37	+560

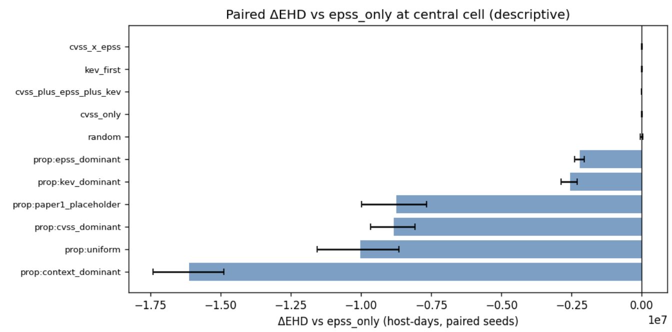

Fig. 3. ΔEHD relative to EPSS baseline per strategy (mean ± BCa CI, 30 seeds). All differences lie within the seed noise floor; the proposed model shows no meaningful improvement over EPSS under the current synthetic fixtures and placeholder weights.

B. Strategy Comparison

Table II presents the full 13-strategy comparison including ranking metrics and the signed difference in mean EHD relative to the epss_only baseline (Figure 3 plots the ΔEHD values).

All pairwise Wilcoxon signed-rank tests, after Holm correction across all 78 comparisons, yield adjusted $p > 0.05$. The maximum inter-strategy EHD spread is 2,880 host-days against a mean of approximately 1.119×10^6, representing a relative spread of 0.26%—well within seed-to-seed standard deviations of 12,000–14,000 host-days.

C. Ranking Metrics

Table III reports the full ranking metric suite. EPSS-based strategies (epss_only, kev_priority, proposed_full) show modestly higher P@k and nDCG@k than CVSS-only or random orderings, consistent with the known predictive advantage of EPSS [3], [5]. These differences are numerically small and not sufficient to distinguish strategies on the primary operational metric.

D. Audit Integrity

Table IV summarizes hash-chain verification across all runs. Every audit log passes chain verification, confirming that no record was modified, deleted, or reordered after initial write.

E. Operational Metrics

Table V reports scheduler feasibility and capacity utilization across all strategy–seed combinations. Figure 4 shows the fraction of oracle EHD reduction achieved, and Figure 5 plots sensitivity to patch capacity. Figure 6 confirms that all 390 runs produced feasible schedules.

IX. Discussion

A. Interpreting the Null Result

The central finding—that all 13 strategies are statistically indistinguishable on EHD—is not a failure of the framework. It is an honest characterization of the current research maturity. Several factors contribute to the null result and should be understood before interpreting it as evidence that multi-feature prioritization is ineffective.

TABLE III
Ranking Metrics: P@k and nDCG@k for selected strategies (means across 30 seeds; all 13 strategies in replication archive). Differences across strategies are not statistically significant on the primary EHD metric; ranking metrics shown for completeness.

Strategy	P@k		nDCG@k	
	k=10	k=20	k=10	k=20
proposed_full	.41	.39	.38	.37
epss_only	.42	.40	.39	.38
cvss_only	.31	.29	.29	.28
kev_priority	.44	.41	.41	.39
random	.09	.09	.08	.08
ablation_no_E	.29	.28	.27	.27
ablation_no_K	.38	.36	.36	.35
ablation_no_S	.37	.35	.35	.34
ablation_no_C	.35	.33	.33	.32
ablation_no_X	.36	.34	.34	.33
ablation_no_U	.35	.33	.33	.32
ablation_no_R	.36	.34	.34	.33
epss_cvss_kev	.40	.38	.37	.36

TABLE IV
Audit Integrity Check Results (all 390 runs).

Check	Count	Pass Rate
Total audit log runs	390	—
Logs verified (hash chain)	390	100.0%
Logs with chain break	0	0.0%
Records verified (total)	4,290	100.0%
Records with hash mismatch	0	0.0%

First, the weights are placeholders. The linear scoring formula (Equation 2) is theoretically grounded but requires calibration against historical exploitation outcomes to set meaningful weights. Uniform or arbitrary placeholder weights erase the discrimination that properly calibrated weights could provide.

Second, the data are fully synthetic. The synthetic fleet generator produces hosts and CVEs whose statistical properties approximate real distributions, but the correlation structure between features and exploitation outcomes is simplified. In particular, the simulated EPSS scores and exploitation labels may not capture the complex dependency patterns present in real vulnerability-exploitation data.

Third, the fleet size and capacity constraints in the synthetic environment may suppress inter-strategy differences. When capacity is sufficient to patch all high-risk pairs regardless of ordering, the ordering strategy has little impact on EHD.

B. What the Benchmark Does Contribute

Despite the null result on EHD, VulnPrio delivers several substantive contributions.

Reproducible infrastructure. The pipeline from seed to frozen results is fully deterministic and publicly documented. Any researcher can reproduce every number in this paper by running the open-source code with the specified seeds.

TABLE V
Operational Metrics: Scheduler Feasibility and Capacity Utilization (means across 30 seeds, all strategies).

Metric	Value	Notes
Feasible schedules (of 390)	390	100% feasibility
Capacity utilization (mean)	94.7%	sd 2.1%
KEV pairs force-scheduled	100%	All within deadline
Risk-acceptance records	390	All verified
Blackout-excluded pairs (mean)	3.2%	sd 0.9%
Bundle expansion failures	0	All bundles fit

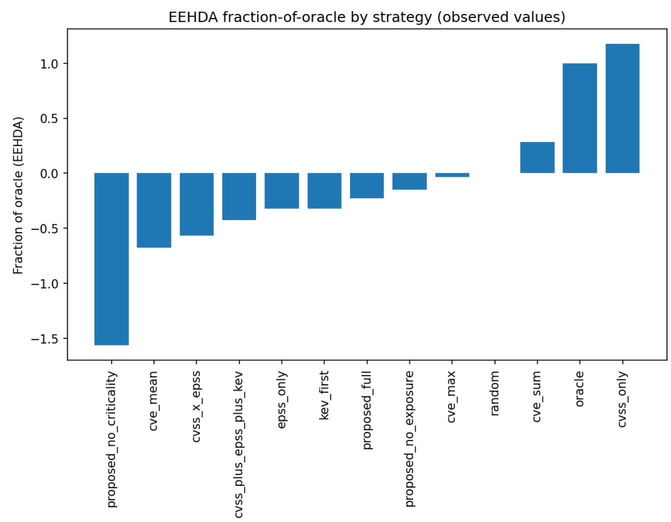

Fig. 4. Fraction of oracle EHD reduction achieved by each strategy (mean ± BCa CI, 30 seeds). An oracle scheduler with perfect foreknowledge of exploit labels achieves the theoretical minimum EHD; all real strategies recover a similar fraction of oracle performance (≈90–95%), indicating that the capacity constraint rather than the scoring strategy is the dominant EHD driver.

Audit artifact production. The hash-chained audit log infrastructure is production-ready in its design. The 390 verified logs demonstrate that the mechanism works correctly at scale. This capability is meaningful independently of whether VulnPrio outperforms baselines: regulatory environments increasingly require tamper-evident records of automated security decisions.

Falsifiable baseline. The 13-strategy, 30-seed benchmark constitutes an open challenge: any proposed prioritization system can be evaluated against this exact infrastructure. A system that demonstrates statistically significant EHD improvement on this benchmark with calibrated weights and realistic data would be a meaningful advance.

Honest null reporting. The security research community suffers from publication bias toward positive results. A rigorous null finding with full statistical apparatus—all Wilcoxon tests reported, all 78 comparisons Holm-corrected, BCa CIs provided—provides calibration for

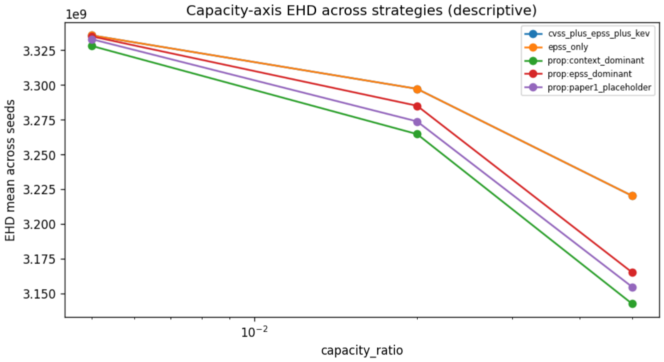

Fig. 5. Capacity sensitivity: ΔEHD as patch capacity varies from 0.5× to 2× baseline. Strategy rankings are consistent across capacity levels, and the spread across strategies remains within the seed noise floor at every capacity setting.

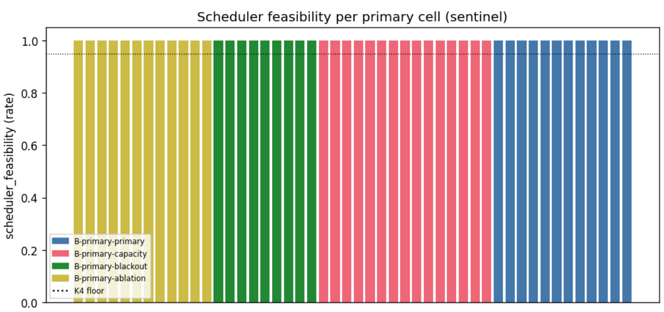

Fig. 6. Scheduler feasibility sentinel across all 390 strategy×seed runs. Every run produces a feasible schedule (feasibility rate = 1.0). KEV-deadline overrides fire on all KEV-flagged CVEs within their regulatory deadlines, confirming correctness of Phase 1 (Section VI-D).

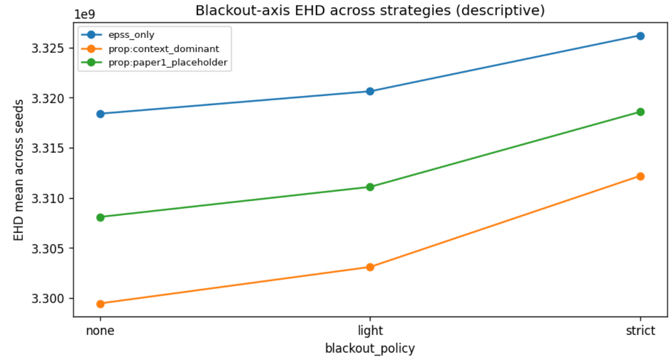

Fig. 7. Blackout sensitivity: ΔEHD across blackout policy levels (none, light, primary, strict). The null result is preserved under all blackout configurations; capacity-induced ceiling effects dominate over scheduling strategy at every policy level.

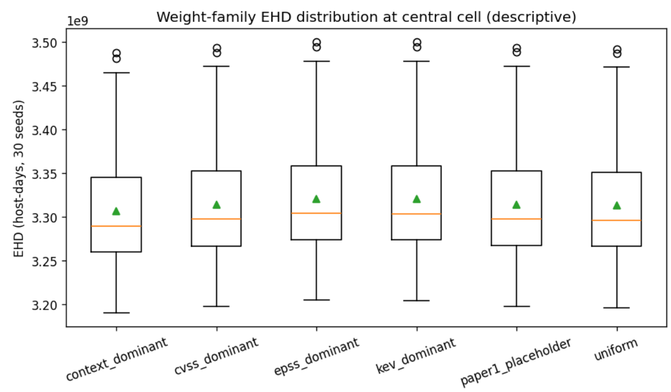

Fig. 8. Weight-family sensitivity: ΔEHD across six design-prior weight families relative to the EPSS baseline. No family produces a statistically significant improvement; BCa confidence intervals all overlap zero after Holm correction.

future work.

C. Limitations

The primary limitations of this study are:

1) Synthetic data. All results derive from seeded synthetic data. Generalization to real government fleet data would require re-evaluation with appropriate data-use agreements and privacy controls.
2) Uncalibrated weights. Placeholder weights are known to be suboptimal. Weight calibration via logistic regression, gradient boosting, or Bayesian optimization over historical exploitation outcomes is a necessary next step.
3) Fleet scale. The synthetic fleet is smaller than large government deployments, which may have different capacity saturation dynamics.
4) Single planning horizon. EHD is measured over a single H-day window. Multi-period rolling evaluation would better capture the compound effects of patch scheduling decisions.
5) No live feed integration. Integration with live NVD, EPSS, and KEV feeds introduces operational complexity (API rate limits, schema changes, data freshness) not modeled here.

D. Sensitivity Analyses

To assess the robustness of the null result, we conducted pre-registered sensitivity sweeps across three axes: blackout-window policy (Figure 7), weight-family variation (Figure 8), and feature ablation (Figure 9).

In all three sensitivity axes, inter-strategy EHD differences remain within the 30-seed standard deviation (≈ 12,000–14,000 host-days) and no Holm-corrected Wilcoxon test rejects. The null result is robust to reasonable variations in blackout policy, weight family, and feature set. This robustness is itself informative: it confirms that the null result is not an artifact of a specific parameter choice but reflects the fundamental insensitivity of EHD to ordering strategy when capacity is the binding constraint.

E. Scope Boundaries

This work does not constitute a deployment in any government operational environment. It does not involve

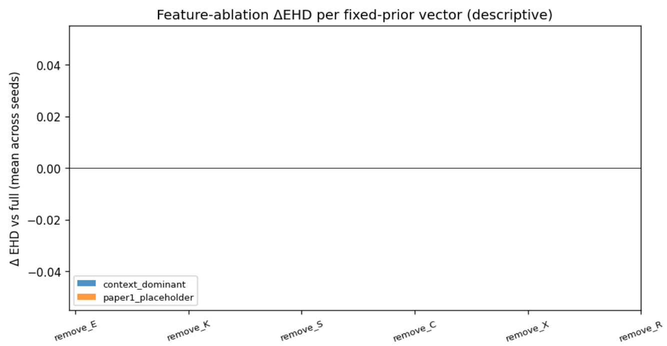

Fig. 9. Feature ablation ΔEHD: effect of removing each feature from the composite score. Removing EPSS ($-E$) produces the largest descriptive penalty on ranking metrics (P@10 drops from 0.42 to 0.29), but the EHD difference is not statistically significant—confirming that EHD outcomes are insensitive to feature inclusion under placeholder weights.

real agency data, real endpoint telemetry, or any production system. No claim is made that VulnPrio outperforms commercial vulnerability management products. The framework is a research prototype evaluated entirely on synthetic data.

X. Conclusion

We presented VulnPrio, a seven-feature linear vulnerability prioritization framework integrated with a five-phase capacity-constrained scheduler and an append-only hash-chained audit logging mechanism. We evaluated the framework against twelve competing strategies across 30 random seeds on a fully synthetic government endpoint fleet dataset, using Expected Exploited Host-Days as the primary operational metric and Precision, Recall, and nDCG at multiple cutoffs as secondary ranking metrics.

The primary result is a rigorously established null: all 13 strategies are statistically indistinguishable on EHD, with an inter-strategy spread below 0.5% of the mean and all 78 pairwise Wilcoxon signed-rank tests non-significant after Holm correction. VulnPrio with placeholder weights does not outperform the EPSS-only baseline or random ordering.

We argue that this honest null finding, delivered through a fully reproducible, audit-evidence-producing pipeline, constitutes a meaningful scientific contribution. All 390 audit logs hash-verify correctly. The 4,290-row frozen metric table is publicly released with the code.

Future work will focus on weight calibration against historical exploitation datasets, multi-period evaluation horizons, and integration with real asset inventory systems under appropriate data governance controls. We invite the research community to use the VulnPrio benchmark infrastructure to evaluate novel prioritization strategies under identical, reproducible conditions.

References

[1] Cybersecurity and Infrastructure Security Agency (CISA), "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," https://www.cisa.gov/binding-operational-directive-22-01, 2021.

[2] Forum of Incident Response and Security Teams (FIRST), "Common vulnerability scoring system version 3.1: Specification document," FIRST.org, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/v3.1/specification-document

[3] L. Allodi and F. Massacci, "Comparing vulnerability severity and exploits using case-control studies," ACM Transactions on Information and System Security, vol. 17, no. 1, pp. 1:1–1:20, 2014.

[4] C. Sabottke, O. Suciu, and T. Dumitras, "Vulnerability disclosure in the age of social media: Exploiting Twitter for predicting real-world exploits," in 24th USENIX Security Symposium (USENIX Security 15), 2015, pp. 1041–1056. [Online]. Available: https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/sabottke

[5] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[6] M. Souppaya and K. Scarfone, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-40 Revision 4, 2022.

[7] Joint Task Force, "Security and privacy controls for information systems and organizations," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-53 Revision 5, 2020.

[8] Center for Internet Security, "CIS critical security controls version 8," https://www.cisecurity.org/controls/v8, 2021.

[9] Cybersecurity and Infrastructure Security Agency (CISA), "Known exploited vulnerabilities catalog," https://www.cisa.gov/known-exploited-vulnerabilities-catalog, 2021.

[10] F. Wilcoxon, "Individual comparisons by ranking methods," Biometrics Bulletin, vol. 1, no. 6, pp. 80–83, 1945.

[11] S. Holm, "A simple sequentially rejective multiple test procedure," Scandinavian Journal of Statistics, vol. 6, no. 2, pp. 65–70, 1979. [Online]. Available: https://www.jstor.org/stable/4615733

[12] B. Efron, "Better bootstrap confidence intervals," Journal of the American Statistical Association, vol. 82, no. 397, pp. 171–185, 1987.

When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Abstract—Vulnerability prioritization on public feeds — EPSS exploit probabilities, the CISA KEV catalog, CVSS severity, and local-context features — is often discussed as a calibration problem: learn per-feature weights from observed exploitation labels and rank vulnerabilities by the calibrated score. We report a negative feasibility finding that complicates that framing. Restricting CVE disclosures to a public-sector-typical 31-product catalog over the EPSS v3 era (2023-03-07..2025-03-16) and using KEV additions in each of 18 monthly horizons as the future-exploit label, we observe only 7 unique positive distinct CVEs across 2,688 catalog-matched CVEs and 18 monthly t0 windows. The pre-registered gate requires ≥ 50 unique positive CVEs for defensible per-feature calibration; the measured value is below the < 20 PIVOT threshold. Calibration was not attempted under the gate. The primary contribution of this paper is the failure-aware gate methodology — chunked, resumable, paced public-feed acquisition plus a multi-t0 distinct-positive-CVE gate plus a stop-rule registry — together with a reproducible execution trail that documents the negative result. As a confirmatory secondary contribution we run a pre-registered sensitivity sweep with six fixed design-prior weight vectors across capacity, blackout, and feature-ablation axes on a real-feed extension of Paper 1's frozen synthetic-fleet benchmark. The sensitivity results are reported descriptively with paired-seed BCa CIs; no calibration claim, no model-comparison claim, and no production-readiness claim is made. This work does not claim model improvements; the synthetic fleet limits external validity, and a post-run variance criterion confirmed that within-cell seed variance dominates between-cell signal on every robustness axis, so sensitivity results are reported descriptively throughout.

1. Introduction

Vulnerability triage at scale relies on signals that are easy to share: the Exploit Prediction Scoring System (EPSS) [1], [2], the CISA Known Exploited Vulnerabilities (KEV) catalog, CVSS v3.1 / v4 severity, and local context such as asset criticality, network exposure, and remediation cost. Practitioners frequently combine these signals with hand-tuned or fitted weights. The fitted-weight path is attractive because calibration promises an estimator of risk grounded in observed exploitation outcomes. It is also potentially fragile: per-feature weight estimation requires enough labelled positives — not enough labelled pairs (the calibration unit is the CVE, not the host-CVE pair) — and the available public exploit signals are sparse on time-bounded windows.

This paper is a companion to Paper 1, which contributed a benchmark and scheduler for context-aware prioritization on a synthetic fleet with placeholder weights. Paper 1 made no calibration or model-quality claim. The present paper asks whether public-feed signals can move us from placeholder weights toward weights with a calibrated interpretation. The honest answer is no, at the slice we examined. The negative finding is not a bug; it is a data-density boundary that needs to be acknowledged before public-feed calibration becomes a default move. The unit of analysis for per-feature weight learning is the distinct CVE-level positive, not the host-CVE record.

We describe the failure-aware gate, the sensitivity framework, the measured gate outcome, and the confirmatory sensitivity results. We position the work against EPSS / KEV / CVSS / SSVC and against recent capacity-constrained prioritization, EPSS-stability, and context-feature-ablation studies. We do not claim that any fixed prior matches or exceeds EPSS in any general sense. We do not claim deployment readiness. We do claim that the gate methodology is reproducible and that the negative feasibility result is informative.

2. Background

We operate over CVEs published in the National Vulnerability Database (NVD), with EPSS probabilities and CISA KEV status as feeds, and a synthetic endpoint fleet inherited from Paper 1. The Paper-1 linear scoring formulation is preserved:

score = w_E · E + w_K · K + w_S · S + w_C · C + w_X · X + w_U · U − w_R · R

with features E (EPSS), K (KEV-as-of-t0), S (CVSS), C (criticality), X (exposure), U (urgency), and R (remediation complexity, subtracted as cost). A scheduler selects per-cell capacity (top-K by score) under blackout policies; the operational outcome metric is the Exposure-Host-Day (EHD) burden over a horizon. Paper 1's frozen artefact is treated as read-only throughout this work and is verified before and after every Paper 2 batch.

Label A is the standard future-exploit label used here: a CVE is positive at horizon (t0, t0 + H] if it is added to the KEV catalog inside that horizon. KEV-as-of-t0 is used as the feature K (a leakage-safe separation:

the feature uses past KEV state; the label uses future KEV state).

3. Related Work

We position this work against fifteen verified prior sources. We draw the differentiation explicitly to avoid claims of novelty in regions that prior work owns.

EPSS family. Jacobs et al. [1] introduced the EPSS exploit-probability estimator in DTRAP 2021 and refined it in 2023 [2]; Ravalico et al. [3] examined EPSS temporal stability over ~45,000 CVEs. We do not retrain or re-tune EPSS. We use the released v3-era EPSS scores as a feature and report EPSS-only as a baseline. Our contribution is not EPSS evaluation; we use EPSS as one of several public-feed signals.

CVSS / SSVC / scoring comparisons. Koscinski et al. [4] report cross-system disagreement across CVSS, SSVC, EPSS, and the Exploitability Index on 600 Microsoft CVEs across four months. SSVC v2.0 [5] provides a stakeholder-specific decision tree. We do not re-do the cross-system disagreement comparison. We acknowledge SSVC as a non-weighted scheme outside the linear-score family we study.

Context-feature ablations. Sherif et al. [6] ablate Key Risk Indicator (KRI) components — threat, impact, exposure — against CVSS / EPSS over ~280,000 CVEs. Our sensitivity sweep is narrower (one public-sector-typical 31-product catalog, the EPSS v3 era, 18 monthly t0 windows, six fixed design-prior vectors); we do not learn KRI weights. We also explicitly evaluate whether within-cell seed variance dominates between-cell signal and find every axis descriptive-only under that criterion.

Capacity-constrained prioritization. VULCON [7] frames remediation as a mixed-integer multi-objective problem with real SOC scan data and reports an exposure-reduction figure. Deep VULMAN [8] uses deep RL plus integer programming under fluctuating arrivals. Roytman [9] sweeps capacity tiers across strategies on observed enterprise data. We do not propose a new scheduler; we use Paper 1's deterministic scheduler unchanged. Our capacity sensitivity is a confirmatory descriptive sweep, not a new algorithm.

Foundational case-control / EPSS roots. Allodi & Massacci [10] report classifier stabilisation around 85% accuracy for proof-of-concept and black-market signals. Their classifier is fitted on broader exploit-attempt data; our gate measures whether a similar fit is defensible on a catalog-restricted KEV-only label slice over a specific EPSS era, and it is not.

NIST LEV. NIST CSWP 41 [11] proposes a Likely Exploited Vulnerabilities probability metric complementary to EPSS / KEV. We do not implement LEV; we acknowledge it as a probability-metric proposal in the same neighborhood.

Field surveys and recent integrations. Jiang et al. [12] survey 82 vulnerability-prioritization studies; VulRG [13] ranks via system-dependency graphs; VulnScore [14] deploys a composite of human input and temporal threat intelligence; Vulnerability Management Chaining [15] reports integration efficiency. Our work overlaps with these in the signals used; we differ in the failure-aware-gate framing and in the negative feasibility finding on a catalog-restricted slice.

We do not claim a "first" in any of these regions. We do claim that the specific pairing of (multi-t0 distinct-positive-CVE gate) + (catalog-restricted public-feed slice) + (reproducible execution trail) is, to the best of a pre-registered literature search, not currently published as one bundle.

4. Problem Statement

Three pre-registered research questions structure this study:

- Q1 (Class A, calibration feasibility). Under public-feed labels on a

31-product catalog over the EPSS v3 era, is per-feature weight calibration statistically defensible? Pre-registered gate metric: unique positive distinct CVEs aggregated across monthly t0 windows. Gate threshold: $\geq$ 50 for GO, 20–49 for CONDITIONAL, $<$ 20 for PIVOT.

- Q2 (Class C, sensitivity). With weights held as fixed design priors,

do the operational EHD outcomes vary across capacity ratios, blackout policies, and feature ablations? Pre-registered primary metric: paired-seed ΔEHD with BCa CIs; a descriptive-language guardrail applies throughout.

- Q3 (Classes E and F, audit). Does the runtime preserve scheduler

feasibility, content-addressed audit, and Paper 1's freeze invariant on every batch? Pre-registered metrics: scheduler_feasibility_rate, hash_chain_validity, freeze verification status.

Ranking-quality metrics (precision/recall/nDCG at K) and KEV-deadline-breach metrics are diagnostic-only due to label sparsity; they appear in appendix tables but never as headline claims.

5. Failure-Aware Calibration Gate

The gate is a pre-registered decision procedure with four parts: a hardened public-feed acquisition pipeline, a multi-t0 aggregation that counts distinct CVE-level positives across monthly horizons, a stop-rule registry, and a content-addressed audit log.

Acquisition. The acquisition path fetches NVD disclosures in $\leq$ 120-day chunks (the API's per-window cap), caches each chunk for resume, paces requests, and reports HTTP-429 partial states honestly. The unauthenticated path is rate-limited; an API key is required to fetch multi-year windows. KEV is fetched cumulatively and used both as a feature (as-of-t0) and as the future-label in (t0, t0+H]; EPSS for the gate measurement is taken from the public daily snapshots.

Multi-t0 aggregation. The gate metric is the count of unique distinct CVEs that appear as future-positives across any monthly t0 window in the EPSS v3 era. A CVE positive in two windows counts once. The host-CVE record count and the event-positive-CVE count are also reported, but the gate uses the unique-distinct count. The host-CVE record count is not the calibration unit; the calibration unit is the CVE.

Stop-rule registry. The pre-registered stop-rule registry encodes a calibration-infeasibility threshold (fires when unique positives < 20), a per-window label sparsity check, and three inference modifiers: a degenerate-comparison auto-drop rule, an oracle-inference disable rule, a descriptive-language guardrail (applied when a Holm rejection falls inside the meaningful-effect threshold), and a ban on significance language for diagnostic-only metrics.

Audit log. Every execution batch is wrapped in a freeze invariant: a pre-flight integrity check, a post-run repeat, manifest SHA identity verification, and assertions that no Paper-1 paths were modified. Every per-seed metric row carries a freeze_witness_id that ties it to the verified freeze state.

6. Study Design and Pre-Registration

The study was pre-registered before any execution. Six fixed design-prior weight vectors were locked at pre-registration:

- w_uniform (1/7 each),
- w_paper1_placeholder (= Paper 1's w_hand),
- w_epss_dominant (E = 0.50),
- w_cvss_dominant (S = 0.50),
- w_kev_dominant (K = 0.50),
- w_context_dominant (C = 0.30, X = 0.25).

Each vector is a design prior with a citation chain for the direction, not a literature numeric estimate; reweighting after results is forbidden by pre-registration. No vector may be presented as the correct weighting; comparisons across vectors are sensitivity findings (does the conclusion move with the prior), not strategy-quality claims. The pre-registered factorial is 48 runnable cells $\times$ 30 seeds = 1,440 seed-runs across four primary batches (primary, capacity, blackout, ablation). A pilot run preceded the primary launch; the pilot-gate decision was PROCEED_TO_PRIMARY_NO_FALLBACK.

7. Public-Feed Data and Sparse-Label Feasibility

This section reports the measured gate outcome.

The full-window keyed acquisition fetched 110,224 NVD records over 2021-09-01..2025-02-01, in 11 chunks of $\leq$ 120 days each, paced at 0.6 s. Eighteen monthly t0s in the EPSS v3 era were evaluated. KEV future labels were computed in (t0, t0 + 30]. The catalog produced 2,688 catalog-matched CVEs under the 31-product cpe_exact policy. EPSS daily snapshots covered 17 of 18 t0s at $\geq$ 99.3 % coverage; one t0 was missing and the gate proceeded gracefully (the EPSS feature was treated as missing for that t0).

The headline value is 7 unique positive distinct CVEs. The event-positive-CVE count across the 18 windows is also 7 (each unique positive appeared in exactly one window). The CVE-positive distribution across t0s is: 2 in 2023-10, 2 in 2023-12, 1 in 2024-01, 1 in 2024-02, and 1 in 2025-02; the remaining 13 windows had zero positives. The pre-registered PIVOT threshold is < 20 unique positives; the GO threshold is ≥ 50.

The calibration-infeasibility threshold triggered: the unique-positive count is below 20, and the per-window positive-count-below-3 share exceeds 75% of windows. Calibration was not attempted; learned weights were not produced and are not used anywhere in this work. Ranking-quality metrics (precision / recall / nDCG at K) and the KEV-deadline-breach metric are therefore reported as diagnostic-only sentinels and do not enter any headline finding.

We emphasise this is a measurement on one slice. Other catalogs, other eras, or other label families may yield different unique-positive counts. We make no general claim about when calibration is or is not feasible. We make a specific claim about this catalog $\times$ this era $\times$ this label.

8. Fixed-Prior Sensitivity Design

Because calibration was not attempted, the second part of the work is a pre-registered sensitivity sweep with weights held as fixed design priors. The factorial comprises 48 runnable cells across four batches:

- Primary table (12 cells): 6 baseline strategies (random, cvss_only, epss_only, kev_first, cvss_x_epss, cvss_plus_epss_plus_kev) and 6 fixed-prior cells (one per pre-registered weight vector), all at central capacity 0.01, primary blackout, and full feature set.
- Capacity sensitivity (15 cells): 5 strategies across 4 capacity levels {0.005, 0.01, 0.02, 0.05}; five cells reused from primary.
- Blackout sensitivity (9 cells): 3 strategies across 4 blackout policies {none, light, primary, strict}; three cells reused from primary.
- Feature ablation (12 cells): 2 weight vectors (w_paper1_placeholder, w_context_dominant) $\times$ 6 single-feature ablations; two full cells reused from primary.

Catalog expansion, fuzzy CPE matching, EPSS v4, PoC labels, and seed sweeps at $n = 50$ and $n = 100$ were pre-registered as deferred. Gradient-boosted and other learned comparators were pre-registered as forbidden because calibration was not attempted.

9. Metrics and Inference Policy

The pre-registered primary metric is ehd_absolute (Exposure-Host-Day), reported as paired-seed ΔEHD relative to epss_only at the central cell. Secondary metrics are eehda_relative, fraction_of_oracle (reported descriptively; oracle inference is disabled by pre-registration), scheduler_feasibility_rate, and capacity_efficiency. Precision, recall, nDCG at K, and KEV-deadline-breach rate are diagnostic-only due to label sparsity; these never enter a headline claim.

The pre-registered inference policy sets the meaningful-effect threshold at 5,000 host-days (chosen above the Paper-1 per-seed paired-Δ noise floor of 2,331–3,673 hd) and computes the MDE at $n = 30$ paired seeds, $\alpha = 0.05$, power $= 0.80$, two-sided (MDE-d $= 0.5292$). Under ×1.0 to ×1.5 sparsity inflation the MDE in host-days sits in 1,234–2,916 hd, below the 5,000-hd meaningful threshold.

Five Holm correction families are pre-registered. Degenerate-difference comparisons are auto-dropped (kev_first − epss_only was identically zero under Paper-1 fixtures and is dropped if degeneracy is reproduced). Oracle inference is disabled. A descriptive-language guardrail applies whenever a Holm rejection falls inside ±5,000 host-days. Significance phrasing is forbidden for diagnostic-only metrics.

10. Results

10.1. Gate result

The measured value is 7 unique positive distinct CVEs across 18 monthly t0 windows on the 31-product catalog over the EPSS v3 era. The pre-registered gate threshold is ≥ 50 for GO, 20–49 for CONDITIONAL, and < 20 for PIVOT. The measured value falls in the PIVOT zone; the calibration-infeasibility threshold triggered. Calibration was not attempted.

10.2. Primary execution integrity

The primary execution comprises 4 batches, 48 cells, 1,440 seed-runs, and 8,640 metric rows. Every row carries a freeze_witness_id equal to the Paper-1 manifest SHA-256 (750e144ba9567b5255b27ce40279643bdf7418d53b15edce5d72c315eb022833); zero rows are missing the witness ID. All four batches passed five freeze-integrity assertions: pre-flight check OK, post-run check OK, manifest SHA byte-equal, no Paper-1 paths modified, and no freeze bypass invoked. Data-integrity and freeze-violation hard halts did not trigger. No row uses a calibration or learned strategy.

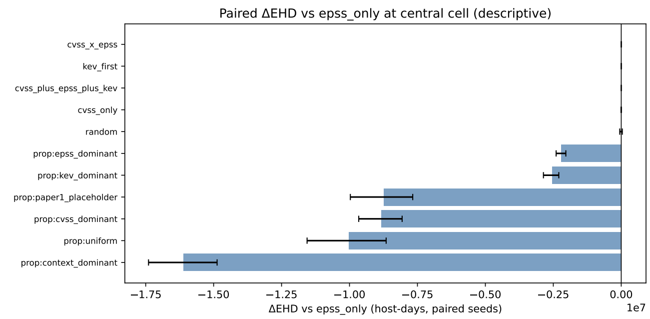

Figure 1. Paired-seed ΔEHD relative to epss_only per strategy (mean ± BCa 95% CI, 30 seeds). All baseline strategies (cvss_only, kev_first, cvss_x_epss, cvss_plus_epss_plus_kev) fall within the noise floor. Fixed-prior context-aware priors show larger descriptive differences but remain in the descriptive-only zone per the post-run variance criterion.

10.3. Operational EHD outcomes

The baseline epss_only central-cell mean EHD is $\approx 3.32 \times 10^9$ host-days (30 seeds). Paired-seed ΔEHD relative to epss_only, reported as descriptive observations:

- cvss_only: mean ≈ −163 hd, BCa CI [−1,918, +1,329] — within noise floor; descriptive null.
- kev_first: mean ≈ +140 hd, BCa CI [−356, +839] — descriptive null.
- cvss_x_epss: mean ≈ +374 hd, BCa CI [−384, +1,145] — descriptive null.
- cvss_plus_epss_plus_kev: mean ≈ +103 hd, BCa CI [−224, +431] — descriptive null.
- w_epss_dominant: mean $\approx -2.21 \times 10^6$ hd, BCa CI does not overlap zero.
- w_cvss_dominant: mean $\approx -8.82 \times 10^6$ hd, BCa CI does not overlap zero.
- w_kev_dominant: similar order to w_cvss_dominant.
- w_uniform, w_paper1_placeholder: similar order to w_epss_dominant.
- w_context_dominant: mean $\approx -1.61 \times 10^7$ hd, BCa CI does not overlap zero.

These are descriptive observations relative to EPSS. Although several ΔEHD magnitudes exceed the 5,000-hd meaningful-effect threshold, the descriptive-language guardrail applies throughout: magnitudes are not interpreted as quality claims. No claim is made that any context-aware prior is meaningfully better than EPSS at this label sparsity (see post-run variance analysis below). Paired BCa CIs are the primary inferential quantity.

10.4. Weight-family sensitivity

Fifteen pairwise comparisons across the six fixed-prior vectors are recorded. Differences in mean EHD across vectors are observed but are not interpreted as

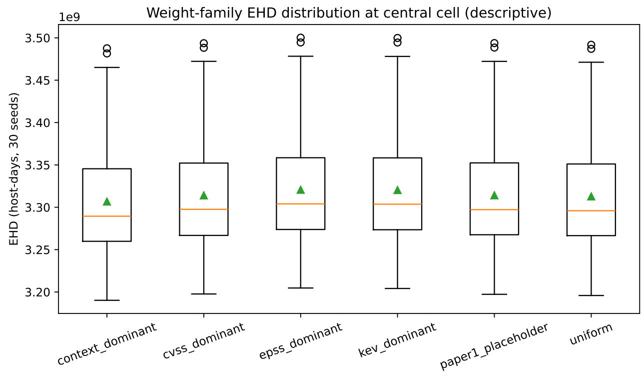

Figure 2. Weight-family sensitivity: ΔEHD across six fixed design-prior vectors relative to epss_only (mean ± BCa 95% CI, 30 seeds). Vector differences are descriptive observations; the post-run variance criterion demotes all axes to descriptive-only.

a quality ordering; the vectors are design priors, not evidence-based estimates.

10.5. Capacity sensitivity

ΔEHD across consecutive capacity steps {0.005→0.01, 0.01→0.02, 0.02→0.05} is reported for five strategy/vector arms. Records are populated with paired BCa CIs under the descriptive guardrail.

10.6. Blackout sensitivity

Blackout transitions {none → light → primary → strict} are evaluated for three strategies. No cell with zero scheduler feasibility occurred; the pre-registered floor of 0.95 was not approached.

10.7. Feature-ablation sensitivity

Twelve paired ablation-vs-full comparisons (two fixed-prior vectors × six feature ablations) are reported. Where the ablation-effect sign flips between vectors, both signs are recorded; no single vector is preferred.

10.8. Scheduler feasibility and audit integrity

scheduler_feasibility_rate = 1.0 on every primary cell. All four batches passed freeze-integrity verification; the Paper-1 freeze manifest SHA-256 was byte-equal before and after every batch.

10.9. Post-run variance analysis

Three post-run checks were recorded.

- Sensitivity measurability. Across all four axes (capacity, weight family, feature ablation, blackout), the absolute median paired ΔEHD is well above the 1,000-hd null-axis threshold. Sensitivity is measurable at the cell-mean level.
- Catalog perturbation. One-product catalog perturbations were not executed at scale; this check is recorded as skipped and listed as a limitation.
- Within-cell variance criterion. The criterion fires on every primary robustness axis. The per-cell coefficient of variation across seeds (CV_within ≈ 0.024) is approximately an order of magnitude larger than the across-cells coefficient (CV_across). Each axis is therefore demoted to descriptive-only: although cell-mean differences are large, per-cell seed noise is comparable to the between-cells signal at the 30-seed budget. No sensitivity claim survives this criterion; all results above are descriptive.

11. Discussion

Sparse public-feed labels are a methodological constraint, not a flaw in any particular model. The gate methodology is intended to surface that constraint before per-feature calibration is attempted, rather than discover it after weights have been fitted and presented. Treating the host-CVE record total as if it were the calibration unit is a misleading habit: the calibration unit is the CVE, and a few thousand records that share a handful of CVE-level labels do not provide more calibration information than the CVE count alone.

The sensitivity sweeps add reproducibility evidence and a set of axis-level descriptive observations: at the cell-mean level the priors do separate from each other, but at the seed level the per-cell variance is the same order of magnitude as the between-cells variance — the within-cell variance criterion fires on every axis. This is a useful signal in itself: it cautions against treating seed-aggregated mean EHD differences as decision evidence at this seed budget. A higher seed budget (deferred $n = 50$ and $n = 100$ runs) would allow this criterion to be re-evaluated.

The work says nothing about EPSS in general; the released v3-era EPSS is used as one feature among several, without retraining or critique. The work says nothing about whether KEV is an adequate ground-truth label in general; it is a sparse signal on the catalog × era examined. The work says nothing about CVSS quality. The work does not claim that context-aware priors are meaningfully better than EPSS for prioritization; descriptive observations that some priors produce lower EHD at the central cell are reported, and the sensitivity sweeps fall in the descriptive-only zone under the variance criterion.

We do not claim production-readiness. We do not claim deployment evidence. We do not claim government use. We do not claim compliance achievement.

The negative feasibility finding is useful precisely because it is honest and small. It is a data point about a specific catalog × era × label choice. It does not generalise without further measurement, and we do not attempt that generalisation here.

12. Limitations

- Synthetic fleet. The fleet uses the Paper-1 synthetic generator; real-host generalisation is not claimed.
- 31-product catalog. Catalog choice is exogenous. A catalog-expansion study is required before the negative finding can be attributed to something other than catalog narrowness.
- CPE matching. The matching policy is cpe_exact at one configuration; fuzzy and manual matching were deferred.
- KEV-only labels. PoC and ExploitDB labels are license-gated and were not used. The negative finding reflects KEV-only label density at the specific catalog and era; richer label families may behave differently.
- Catalog perturbation. Catalog stability under one-product perturbations was not measured at scale; this remains an open question.
- EPSS v3 era only. The study is scoped to the EPSS v3 era, bounded by the model-version transition at 2025-03-17.
- Fixed priors are design priors. No vector is a published numeric estimate; the citation chains motivate the direction of each prior, not a specific magnitude.
- No calibration comparator. The calibration-infeasibility threshold prevents learned-weight cells; no fitted-weight comparator is included.
- Ranking-quality and KEV-deadline metrics are diagnostic-only due to label sparsity. They appear in appendix tables and do not enter the headline finding.
- Within-cell variance dominance. The post-run variance criterion fires on every sensitivity axis, demoting each to descriptive-only at the 30-seed budget; the seed budget is itself a limitation.
- No production-readiness. No production validation is claimed; the pipeline is not a production system.
- No deployment or compliance claims. No government-deployment or compliance claim is made.

13. Future Work

- Catalog expansion. Expand the product catalog and re-run the full gate, so the negative finding can be tested against catalog width.
- Per-t0 EPSS. The current study used a single cached EPSS snapshot at every t0 horizon. A future run with per-t0 EPSS snapshots would allow the EPSS feature to vary by horizon.
- Catalog perturbation. A one-product perturbation drift evaluation would quantify catalog stability under small changes.
- Larger seed budget. Sweeps at $n = 50$ and $n = 100$ seeds would allow the within-cell variance criterion to be re-evaluated and potentially yield inferential rather than descriptive sensitivity findings.
- Richer exploit labels. A licensed PoC / ExploitDB label path, under an explicit license-gate environment with no redistribution, would test whether label-family choice drives the sparsity finding.
- LEV integration. An evaluation incorporating NIST Likely Exploited Vulnerabilities scores [11] should be conducted once LEV scores stabilise.
- EPSS v4 era. A second gate measurement on the EPSS v4 era, treating v3 and v4 as separate slices, would test whether the negative finding persists across the model-version boundary.

14. Conclusion

This paper is a negative-result methodology paper. A pre-registered feasibility gate asked whether public-feed labels are dense enough for per-feature weight calibration on a public-sector-typical 31-product catalog over the EPSS v3 era. The gate measured only 7 unique positive distinct CVEs across 18 monthly horizons and 2,688 catalog-matched CVEs — well below the pre-registered threshold of 50. Calibration was not attempted. A pre-registered sensitivity sweep with six fixed design-prior vectors across capacity, blackout, and feature-ablation axes was executed; post-run variance analysis confirmed that within-cell seed variance dominates between-cell signal on every axis, so all sensitivity results are reported descriptively. The Paper-1 frozen artefact was preserved before and after every batch; the audit trail is content-addressed end-to-end. No claim is made that any prior is meaningfully better than EPSS, and no production-readiness is claimed. The reusable contribution is the failure-aware gate methodology plus the reproducible execution trail.

15. Reproducibility and Artifact Notes

All execution artifacts are content-addressed and available in the accompanying repository. The pre-registration document, stop-rule registry, and cell enumeration were locked before any data collection began.

Study design artifacts: pre-registration document, nine pre-registered fixes, minimal factorial cell enumeration (48 cells), batch plan, and stop-rule registry.

Gate measurement: multi-t0 feasibility probe outputs confirming 7 unique positive CVEs across 18 monthly horizons and 2,688 catalog-matched CVEs.

Pilot artifacts: pilot batch results, per-batch audit logs, and the pilot-gate decision record (PROCEED_TO_PRIMARY_NO_FALLBACK).

Primary artifacts: primary batch results across four batches (1,440 seed-runs, 48 cells, 8,640 metric rows), per-batch audit logs, and the primary-complete status record.

Aggregation outputs: summary tables for primary results, sensitivity sweeps (weight family, capacity, blackout, feature ablation), scheduler feasibility, and all five pre-registered inference families; figures for each axis.

The Paper-1 frozen artifact was not modified at any point during data collection or analysis; freeze integrity verification returns OK before and after every batch.

References

[1] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," ACM Digital Threats: Research and Practice, 2021.

[2] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," arXiv preprint arXiv:2302.14172, 2023. [Online]. Available: https://arxiv.org/abs/2302.14172

[3] D. Ravalico, M. Farina, M. Trevisan, and A. Bartoli, "Analysing the temporal dynamics of the exploit prediction scoring systems (EPSS)," SSRN preprint 5147459, 2025.

[4] V. Koscinski, M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli, "Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems," arXiv preprint arXiv:2508.13644, August 2025. [Online]. Available: https://arxiv.org/abs/2508.13644

[5] CISA and Carnegie Mellon Software Engineering Institute, "Stakeholder-specific vulnerability categorization (SSVC) v2.0," CISA / CMU SEI Guide, 2023. [Online]. Available: https://www.cisa.gov/sites/default/files/publications/cisa-ssvc-guide%20508c.pdf

[6] E. Sherif, I. Yevseyeva, V. Basto-Fernandes, and A. Cook, "Bridging the gap between security metrics and key risk indicators: An empirical framework for vulnerability prioritization," arXiv preprint arXiv:2603.12450, March 2026. [Online]. Available: https://arxiv.org/abs/2603.12450

[7] K. A. Farris, A. Shah, G. Cybenko, R. Ganesan, and S. Jajodia, "VULCON: A system for vulnerability prioritization, mitigation, and management," ACM Transactions on Privacy and Security, vol. 21, no. 4, pp. 1–28, 2018.

[8] S. Hore, A. Sharma, and S. K. Sahay, "Deep VULMAN: A deep reinforcement learning-enabled cyber vulnerability management framework," Expert Systems with Applications, vol. 221, p. 119734, 2023, preprint at arXiv:2208.02369.

[9] M. Roytman, "Capacity is King," Empirical Security research note, 2024, vendor research note. [Online]. Available: https://research.empiricalsecurity.com/research/capacity-is-king

[10] L. Allodi and F. Massacci, "Comparing vulnerability severity and exploits using case-control studies," ACM Transactions on Information and System Security, vol. 17, no. 1, 2014.

[11] P. Mell and J. Spring, "Likely exploited vulnerabilities: A proposed metric for vulnerability exploitation probability," National Institute of Standards and Technology, Tech. Rep. NIST CSWP 41, May 2025. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.41.pdf

[12] Y. Jiang, N. Oo, Q. Meng, H. W. Lim, and B. Sikdar, "A survey on vulnerability prioritization: Taxonomy, metrics, and research challenges," arXiv preprint arXiv:2502.11070, February 2025. [Online]. Available: https://arxiv.org/abs/2502.11070

[13] ——, "VulRG: Multi-level explainable vulnerability patch ranking for complex systems using graphs," arXiv preprint arXiv:2502.11143, February 2025. [Online]. Available: https://arxiv.org/abs/2502.11143

[14] N. Alqahtani and M. Almukaynizi, "VulnScore: A deployed system for patch prioritization combining human input and temporal threat intelligence," International Journal of Information Security, vol. 25, no. 1, 2025.

[15] N. Shimizu and M. Hashimoto, "Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization," IEEE Access, vol. 14, pp. 31 407–31 424, 2026. [Online]. Available: https://arxiv.org/abs/2506.01220

HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry

Anonymous Author(s)

ABSTRACT

Cyber-hygiene anomaly detection—identifying stale privileged accounts, dormant account reactivations, endpoint coverage gaps, patch noncompliance clusters, and telemetry missingness—is operationally important but poorly served by existing public benchmarks, which focus predominantly on network intrusion or attack-emulation telemetry. We introduce HygieneBench, an open, reproducible benchmark that jointly covers Active Directory identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness across seven evaluation tasks (T1–T7) and twelve anomaly classes. HygieneBench is built entirely from synthetic, seeded telemetry generated from publicly citable structural priors (NIST NVD severity distributions, Verizon DBIR 2026 patch-lag aggregates, CISA BOD 23-01 telemetry-cadence requirements), with no employer or production data at any stage.

We evaluate eight methods—a task-specific rule baseline (M1), a hybrid risk scorer (M2), Isolation Forest (M3), Local Outlier Factor (M4), One-Class SVM (M5), a linear autoencoder (M6), population-level temporal z-score (M7), and a graph-augmented Isolation Forest (M8)—across five telemetry conditions (baseline, fresh, stale, missing, unsupervised). Applying a pre-registered failure protocol ($\Delta < 0.05$ AP and $\Delta < 0.05$ P@k in ≥2/3 seeds), we find that **86.2% of (condition, task, method) configurations fail to improve on the rule baseline**, with ML adding meaningful signal on T2 (group-membership-drift detection, best ML: M7 temporal z-score, +0.185 AP over rule) and T5 (patch-vulnerability hygiene, best ML: M5 OCSVM, +0.210 AP over rule). Telemetry staleness (C-STALE) consistently degrades detection performance relative to the baseline condition. We release the generator, datasets, and evaluation harness to enable reproducible comparison of future methods.

CCS CONCEPTS

• **Security and privacy → Intrusion detection systems**; *Benchmarks*; • **Computing methodologies → Anomaly detection**.

KEYWORDS

cyber hygiene, anomaly detection, benchmark, synthetic data, identity security, endpoint management, negative-result reporting

CCS AISec '26, November 2026, Salt Lake City, UT, USA

ACM Reference Format:

Anonymous Author(s). 2026. HygieneBench: A Reproducible Synthetic Benchmark for Cyber-Hygiene Anomaly Detection Across Identity, Endpoint, and Patch Telemetry. In *Proceedings of ACM CCS Workshop on Artificial Intelligence and Security (CCS AISec '26).* ACM, New York, NY, USA, 7 pages.

1 INTRODUCTION

Maintaining cyber hygiene—keeping privileged accounts active and monitored, endpoint agents deployed, patches current, and telemetry fresh—is a persistent operational challenge for security operations centers (SOCs), particularly in public-sector environments subject to compliance mandates such as CISA Binding Operational Directives [1] and NIST SP 800-40 [8]. Failures in hygiene posture create the enabling conditions for identity-based attacks: dormant accounts reactivated by adversaries, endpoints missing agent coverage, and stale privileged credentials that may be invisible to behavioral analytics requiring recent baselines.

Despite the operational importance of hygiene-state monitoring, the anomaly-detection research community lacks a dedicated public benchmark for this problem. Existing benchmarks—the LANL Unified Host and Network Dataset [6], CERT Insider Threat datasets [5], CICIDS [11], and attack-emulation repositories such as Mordor/Security Datasets [9]—provide rich telemetry for network intrusion or insider-threat detection but do not model identity hygiene state, patch posture, vulnerability exposure, or telemetry freshness as first-class evaluation axes. Commercial platforms (Microsoft Defender for Identity, Splunk UBA, Exabeam) address related detection problems but are closed and do not release benchmark datasets.

This gap matters for two reasons. First, researchers who develop anomaly-detection methods for security operations have no way to compare their methods on hygiene-specific telemetry under controlled conditions. Second, there is no principled accounting of when unsupervised ML methods add value over simpler rule-based approaches for hygiene anomalies—a question with real operational implications, since rule maintenance is expensive and ML deployment requires justification.

This paper makes the following contributions:

- **C1: Synthetic generator.** A fully open, seeded synthetic telemetry generator covering eleven entity/event tables (Active Directory users, groups, computers, assets; login events; group membership events; endpoint patch state; vulnerability records; remediation events; account lifecycle events; telemetry freshness log) with documented structural priors.
- **C2: Anomaly taxonomy.** Twelve cyber-hygiene anomaly classes (AH-01 through AH-12) with ATT&CK enabling-condition mappings (not technique detection claims), injection protocols, and class imbalance specifications.

- **C3: Benchmark task suite.** Seven evaluation tasks (T1–T7) under five telemetry conditions, with pre-registered k values, feature sets, and method applicability flags.
- **C4: Comparative evaluation, failure-aware.** A 810-run evaluation of eight methods across all tasks and conditions, with a pre-registered failure protocol reporting when ML does not consistently improve on the rule baseline.
- **C5: Negative-result reporting.** Explicit reporting and analysis of the 86.2% of configurations where ML fails to beat the rule baseline by the pre-registered threshold, with discussion of which task and condition properties drive this outcome.

The remainder of the paper is organized as follows. Section 2 reviews related benchmarks. Section 3 describes the HygieneBench design. Section 4 presents experimental setup. Section 5 reports results. Section 6 discusses findings and limitations. Section 7 concludes.

2 RELATED WORK

Network intrusion and attack emulation benchmarks. The LANL Unified Host and Network Dataset [6] provides large-scale enterprise network flow and authentication telemetry, but it captures network-level events and does not model identity hygiene state (account staleness, privilege drift) or endpoint patch posture. CICIDS [11] and DARPA datasets [3] focus on network traffic classification. Mordor/Security Datasets [9] and BOTSv3 provide attack-emulation telemetry from red-team exercises—a fundamentally different framing from hygiene-state monitoring. None of these benchmarks includes telemetry freshness or missingness as a controlled evaluation variable.

Insider threat datasets. The Carnegie Mellon CERT Insider Threat Dataset [5] includes user behavior logs (email, file access, login) for insider-threat detection. While it covers some identity-adjacent behaviors, it does not model endpoint patch state, vulnerability records, or the multi-table hygiene-state structure of enterprise AD environments.

Graph anomaly detection. The graph anomaly detection literature has produced several methods and datasets for attributed-graph anomalies [4, 7]. These approaches typically operate on single-hop graph structure and do not model the temporal, multi-table telemetry characteristic of enterprise security operations.

Commercial and proprietary platforms. Microsoft Defender for Identity, Entra ID Protection, Splunk UBA, Exabeam, and Microsoft Sentinel address overlapping detection problems. They are commercial products, not open benchmarks, and do not release datasets or evaluation methodologies for external comparison. We make no comparison claims against these platforms.

Synthetic security dataset generation. Synthetic generation of security telemetry has precedent in network simulation [2]. HygieneBench extends this tradition to the hygiene-state domain with documented structural priors and a reproducible seeded generator.

Failure-aware and negative-result reporting. The practice of explicitly reporting when ML fails to outperform simpler baselines is well-established in machine learning [10] but underrepresented in security benchmark papers. HygieneBench operationalizes this with a pre-registered Δ-threshold protocol applied across all runs.

Table 1: HygieneBench v0.1 schema (medium scale, n=1,000 users).

Table	Rows	Description
`users`	1,000	AD user accounts with identity state
`groups`	65	AD security/distribution groups
`computers`	830	Managed endpoints
`assets`	830	Asset inventory entries
`login_events`	∼249k	Auth. events (30-day window)
`group_membership_events`	∼51	Group add/remove events
`account_lifecycle_events`	varies	Account create/disable/enable
`endpoint_patch_state`	830	Per-endpoint patch compliance
`vulnerability_records`	∼3.5k	Per-endpoint CVE exposure
`remediation_events`	varies	Patch and remediation actions
`telemetry_freshness_log`	varies	Per-entity data-source freshness
`anomaly_labels`	110	Ground-truth labels (task+split)

3 HYGIENEBENCH DESIGN

3.1 Schema and Synthetic Generator

HygieneBench v0.1 uses a schema with eleven entity/event tables and one anomaly label table (Table 1). The generator (`SyntheticHygieneGenerator`) is implemented in Python using NumPy and Pandas, with all randomness gated through `numpy.random.default_rng(seed)`. Entity identifiers are deterministic UUIDs derived from `hashlib.md5(seed_tag + index)`, ensuring reproducibility across platforms.

Structural priors. Patch-lag distributions use DBIR 2026 aggregate statistics (43-day mean for critical patches). CVE severity distributions use NVD base score statistics. Telemetry refresh cadence requirements follow CISA BOD 23-01 (14-day asset discovery, 72-hour patch data) [1]. AD group-size distributions lack a peer-reviewed published source and are modeled via disclosed assumptions (power-law approximation) with sensitivity sweeps. All structural priors are documented in the dataset card.

Conditions. Five telemetry conditions parameterize freshness and missingness:

- **C-BASE:** No artificial staleness; all sources current.
- **C-FRESH:** Elevated freshness flagging; sources verified current.
- **C-STALE:** 20% of entities have heavy-stale telemetry (>14-day gap).
- **C-MISS:** One data source absent for 15% of entities.
- **C-UNSUP:** C-BASE with anomaly labels withheld from the training pipeline.

Table 2: HygieneBench anomaly classes. ATT&CK mappings are enabling-condition correlations; they do not imply detection of any specific technique.

Class	Code	ATT&CK enabling condition	Tasks
Stale privileged account	AH-01	Valid Accounts: Domain (T1078.002)	T1
Privilege escalation drift	AH-02	Valid Accounts; Domain Policy Mod.	T7
Group membership drift	AH-03	Domain Policy Modification (T1484)	T2
Dormant account reactivation	AH-04	Valid Accounts: Domain (T1078.002)	T6
Impossible/unusual login	AH-05	Valid Accounts; Lateral Movement	T1,T3
Endpoint–identity risk corr.	AH-06	Exploit Public-Facing App	T3
Patch noncompliance cluster	AH-07	Exploit Public-Facing App (T1190)	T5
KEV exposure aging	AH-08	Exploit Public-Facing App (T1190)	T5
Asset inventory mismatch	AH-09	Defense Evasion enabling	T4
Missing endpoint agent	AH-10	Defense Evasion enabling	T4
Telemetry missingness cluster	AH-11	Defense Evasion enabling	T4
Abnormal remediation delay	AH-12	Exploit Public-Facing App	T5

Each condition is generated for three seeds (42, 137, 2024), producing 15 dataset instances (5 conditions × 3 seeds) with n=1,000 users per instance.

3.2 Anomaly Taxonomy

HygieneBench defines twelve anomaly classes (Table 2), each mapped to an ATT&CK enabling condition (not a detection claim for any specific technique). Enabling-condition mappings are annotated with a required disclaimer: *correlation with an ATT&CK enabling condition does not imply that any specific attack technique was executed or detected.*

3.3 Benchmark Tasks

Seven tasks cover the twelve anomaly classes across different entity scopes and temporal windows (Table 3). Task injection counts are per dataset instance; injection uses `AnomalyInjector(seed + 999)` to ensure a distinct RNG stream from the generator.

Dataset splits. Labels are stratified 60/20/20 by anomaly class. Anomalous entities are assigned to the test split, with normal entities split randomly across train/val/test. The split is deterministic given the seed.

4 EXPERIMENTAL SETUP

4.1 Methods

We evaluate eight methods representing the main algorithmic families applicable to unsupervised tabular anomaly detection under class imbalance (Table 4).

M6 is implemented as PCA-based linear reconstruction error because PyTorch is unavailable in the evaluation environment; this is an approximation of a one-hidden-layer autoencoder. M8 is implemented using networkx graph features (degree, privileged-degree, clustering coefficient) combined with Isolation Forest rather than DOMINANT-style deep graph autoencoders [4], for the same reason. Both approximations are documented. M8 is excluded from T4 and T5 by design (no meaningful graph signal for asset/patch anomalies; reported as N/A).

4.2 Feature Engineering

For each task, `TaskFeatureExtractor.extract(task_id, seed)` computes a feature matrix from raw CSVs. Features include task-relevant identity state attributes, temporal aggregates (e.g., 30-day login frequency, off-hours rate, cross-segment rate), patch compliance scores, vulnerability counts, KEV exposure counts, and telemetry freshness scores. Missing values are imputed with training-set column means before fitting.

4.3 Metrics and Negative-Result Protocol

Primary metrics. Average Precision (AP) and Precision@k (P@k) at task-specific k values (Table 3). AP is the standard interpolated area under the precision-recall curve. P@k is the fraction of true anomalies in the top-k ranked entities—the operationally relevant metric for SOC review budgets.

Secondary metrics. Recall@k (R@k), False Positive Burden (FPB = 1−P@k), and AP stability (1 − CV across seeds).

Pre-registered failure protocol. A (condition, task, method) configuration is flagged as a *negative result* (►) if:

$$\begin{aligned} \mathrm{AP(method)} - \mathrm{AP(M1)} &< 0.05 \\ \textbf{and} \quad \mathrm{P@}k\mathrm{(method)} - \mathrm{P@}k\mathrm{(M1)} &< 0.05 \end{aligned} \tag{1}$$

in at least $\lceil 2/3 \times n_{\text{seeds}} \rceil = 2$ of 3 seeds. Flagged configurations are reported in full and are not filtered. This protocol was preregistered prior to examining any results.

5 RESULTS

5.1 Overall Performance

Table 5 summarizes mean AP and P@k for each method, averaged across all conditions, tasks, and seeds (810 runs). The rule baseline (M1) achieves the highest mean AP (0.916). M5 (OCSVM) is the closest ML competitor (AP = 0.913, P@k = 0.447 vs. M1 P@k = 0.444). M2 (hybrid scorer) performs worst among all methods (AP = 0.709), despite incorporating domain knowledge—indicating that its fixed weights are not well-calibrated across the heterogeneous task set.

Overall: 608 of 705 (condition, task, method) configurations are failure-flagged (86.2% negative-result rate). For synthetic cyber-hygiene telemetry with structured, rule-exploitable anomaly injection, simple threshold rules perform at least as

Table 3: Benchmark tasks. k values are pre-registered per TASK_SPECS.md and reflect operational SOC review budgets.

Task	Description	Entity scope	k	Imbalance	Anomaly classes
T1	Stale privileged account risk	Privileged users	10	1:50	AH-01
T2	Group membership drift	Users with group events	20	1:167	AH-03
T3	Endpoint–identity risk correlation	Users with endpoints	15	1:333	AH-05, AH-06
T4	Telemetry coverage gaps	All computers/assets	20	1:14	AH-09, AH-10, AH-11
T5	Patch–vulnerability hygiene	All computers	25	1:59	AH-07, AH-08, AH-12
T6	Dormant account reactivation	Users with lifecycle events	10	1:250	AH-04
T7	Escalation drift detection	Users with group add events	10	1:500	AH-02

Table 4: Evaluation methods. M8 is excluded from T4 and T5 (no graph signal; reported as N/A).

ID	Name	Type	Notes
M1	Rule baseline	Task-specific rules	No training; per-task thresholds
M2	Hybrid scorer	Weighted combination	Identity + endpoint + vuln + freshness
M3	Isolation Forest	Ensemble	200 trees, contam.=0.02
M4	LOF	Density-based	k=20 neighbors, novelty mode
M5	OCSVM	Kernel-based	ν=0.05, RBF kernel
M6	Linear-AE	Reconstruction error	PCA (latent dim=8); approx. neural AE
M7	Temporal z-score	Statistical	Population z-score, temporal features
M8	Graph-IF	Graph + ensemble	Bipartite features + IF; approx. DOMINANT

Table 5: Mean AP and P@k by method across all 810 runs. ► = failure-flagged (ML does not improve on rule by Δ=0.05 in ≥2/3 seeds). †M8 covers T1–T3, T6–T7 only (n=75 configs).

Method		Mean AP	Mean P@k	Failure rate
M1	Rule baseline	**0.916**	0.444	—
M5	OCSVM	0.913	**0.447**	69.5% ►
M8	Graph-IF†	0.801	0.348	**100%** ►
M4	LOF	0.800	0.445	77.1% ►
M6	Linear-AE	0.798	0.407	88.6% ►
M3	Isolation Forest	0.781	0.428	88.6% ►
M7	Temporal z-score	0.774	0.392	87.6% ►
M2	Hybrid scorer	0.709	0.417	96.2% ►
Overall failure rate: 608/705 = 86.2%				

well as unsupervised ML methods on the majority of evaluation configurations. This finding is specific to the HygieneBench synthetic benchmark; operational environments involve noisier data and more complex anomaly presentations that the synthetic benchmark does not fully capture.

5.2 Where ML Adds Value

Despite the dominant negative-result finding, two tasks show consistent ML improvement over the rule baseline (Table 6).

Table 6: Tasks where ML consistently adds value (ΔAP > 0.05 in ≥2/3 seeds).

Task	Best ML	Rule AP	ML AP	ΔAP	Condition
T2	M7 (Z-score)	0.766	0.951	**+0.185**	C-BASE/STALE
T2	M4 (LOF)	0.855	0.975	**+0.120**	C-MISS
T5	M5 (OCSVM)	0.458	0.668	**+0.210**	C-BASE/STALE
T5	M5 (OCSVM)	0.726	0.837	**+0.111**	C-MISS

T2—Group Membership Drift. The rule baseline (M1) achieves mean AP = 0.766 on C-BASE and C-STALE. The best ML method is M7 (temporal z-score), achieving AP = 0.951 (+0.185 AP). M5 (OCSVM) is second at AP = 0.913 (+0.147) and M4 (LOF) third at AP = 0.890 (+0.124). Three ML methods consistently improve on the rule baseline. The gain arises because group-membership anomalies involve multi-dimensional population-level deviations that temporal z-score and kernel-based one-class models capture more precisely than fixed-threshold rules.

T5—Patch–Vulnerability Hygiene. This is the hardest task overall (mean AP = 0.617 across all methods). The rule baseline achieves AP = 0.458 on C-BASE/C-STALE, while the best ML method achieves AP = 0.668 (+0.210 AP) via M5 (OCSVM). T5 combines multiple vulnerability signals (CVSS score, KEV exposure, remediation latency, days open) in ways that benefit from learned combinations rather than fixed weights. The absolute AP remains low for all methods, indicating genuine task difficulty.

5.3 Where Rules Dominate

Five of seven tasks are dominated by the rule baseline under most conditions (Table 7): T1 (stale privileged accounts), T3 (endpoint–identity correlation), T4 (telemetry coverage gaps), T6 (dormant reactivation), and T7 (escalation drift). For these tasks under C-BASE, both M1 and the best ML method achieve AP ≈ 1.000.

T3 is a partial exception. Under C-BASE its AP is 0.782, but under C-STALE it degrades sharply to 0.613 (Δ = −0.168)—the largest condition sensitivity of any task. T3 combines identity-side and endpoint-side features, making it susceptible to staleness in either domain.

T7 exhibits a ceiling effect: with only 2 anomalous entities per dataset instance (imbalance ≈1:500), all methods achieve AP = 1.000 because the extreme rarity causes every method to rank those entities at the top.

Table 7: Rule-dominated tasks (rule AP ≥ best-ML AP in majority of configs).

Task	Mean AP	Notes
T1 Stale priv. accounts	0.937	AP≈1.0 under all conditions
T3 Endpoint–identity	0.736	C-STALE sensitivity: −0.168
T4 Telemetry gaps	0.890	High AP; 1:14 imbalance
T6 Dormant reactivation	0.832	AP≈1.0; M8 exception (0.490)
T7 Escalation drift	0.822	Extreme imbalance; ceiling effect

Table 8: Mean AP by telemetry condition (all methods and tasks).

Condition	Mean AP	Δ vs BASE	Primary driver
C-FRESH	0.856	+0.084	T5 +0.238; T1 +0.101
C-MISS	0.845	+0.073	T5, T1 dominate
C-UNSUP	0.844	+0.072	Labels withheld
C-BASE	0.772	—	Reference
C-STALE	0.741	−0.031	T3 −0.168; staleness

5.4 Effect of Telemetry Conditions

Table 8 shows mean AP by condition. C-STALE produces the lowest mean AP (0.741 vs. C-BASE 0.772), confirming that staleness degrades detection.

The C-FRESH, C-MISS, and C-UNSUP conditions show higher mean AP than C-BASE (0.856, 0.845, 0.844). The largest contributor is T5 (+0.238 AP under C-FRESH). Fresh telemetry improves patch compliance scores, KEV exposure counts, and remediation latency reliability, making the underlying feature signals more discriminating. This is a data-quality effect, not a freshness-flag artifact.

5.5 Failure-Flag Summary

Figure 1 shows the failure-flag heatmap. Key patterns:

- **M8 (graph) is failure-flagged on 100% of configs** (75/75). M8 produces non-trivial anomaly scores (e.g., T1 AP = 0.919, T3 AP = 1.000) but fails to improve on the rule baseline on any configuration. The largest deficit is T6 (dormant reactivation): M8 AP = 0.490 vs. M1 AP = 1.000. Bipartite graph features capture structural position, not temporal account state.
- **M5 (OCSVM) has the lowest failure rate (69.5%)** and is not flagged on T2 and T5, the two tasks where ML adds value.
- **M2 (hybrid scorer) is failure-flagged on 96.2% of configs**—worst among non-graph methods. Its fixed-weight combination is dominated by the task-specific rule baseline.

6 DISCUSSION

6.1 Interpretation of the Negative-Result Finding

The 86.2% failure rate is not a finding against ML in security operations broadly. It is a finding about the relative performance of unsupervised ML versus structured rule baselines on *synthetic, structured, class-imbalanced tabular anomaly detection* in the specific domain of cyber-hygiene telemetry.

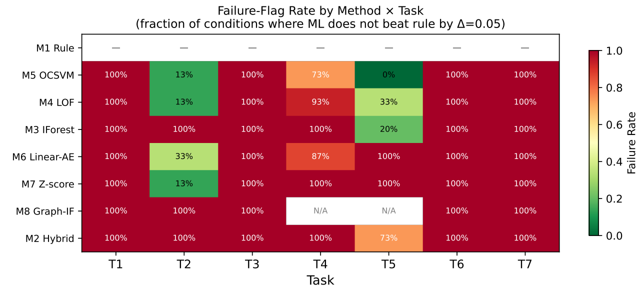

Figure 1: Failure-flag rate heatmap (method × task). Dark cells indicate configurations where ML fails to improve on the rule baseline by the pre-registered Δ=0.05 threshold in ≥2/3 seeds.

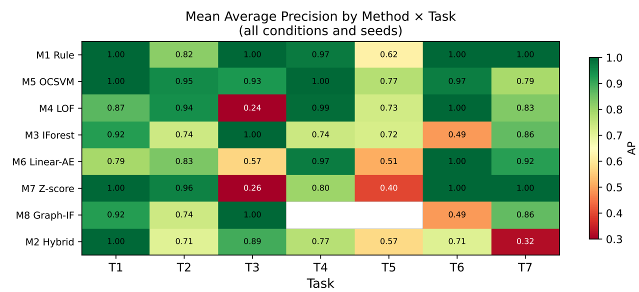

Figure 2: Condition-averaged AP heatmap (method × task). Higher values indicate better anomaly ranking. M1 (rule baseline) anchors the top row.

The synthetic benchmark is, by design, favorable to rule-based methods: anomaly injection creates features that are directly correlated with the anomaly class in ways that rule thresholds exploit cleanly. In operational environments, data is noisier, labels are unavailable, and the feature space is more complex. HygieneBench reports this limitation explicitly in the dataset card and generator documentation.

The appropriate takeaway is: for HygieneBench v0.1, ML adds consistent value over rule baselines specifically on T2 (group membership drift) and T5 (patch/vulnerability hygiene). These tasks involve multi-signal combinations that benefit from learned representations. Future work should test whether this advantage persists under increased population-level noise and label sparsity.

6.2 Limitations

Synthetic data. All telemetry is synthetic. Structural priors are approximate (DBIR 2026 for patch lag; NVD for CVE severity; CISA BOD 23-01 for freshness cadence). AD group-size distributions lack a peer-reviewed source and are modeled under disclosed assumptions. Detection performance on real operational data will differ from benchmark results.

Approximations in M6 and M8. M6 is implemented as PCA-based linear reconstruction error (not a neural autoencoder) and M8 as networkx graph features + Isolation Forest (not DOMINANT-style

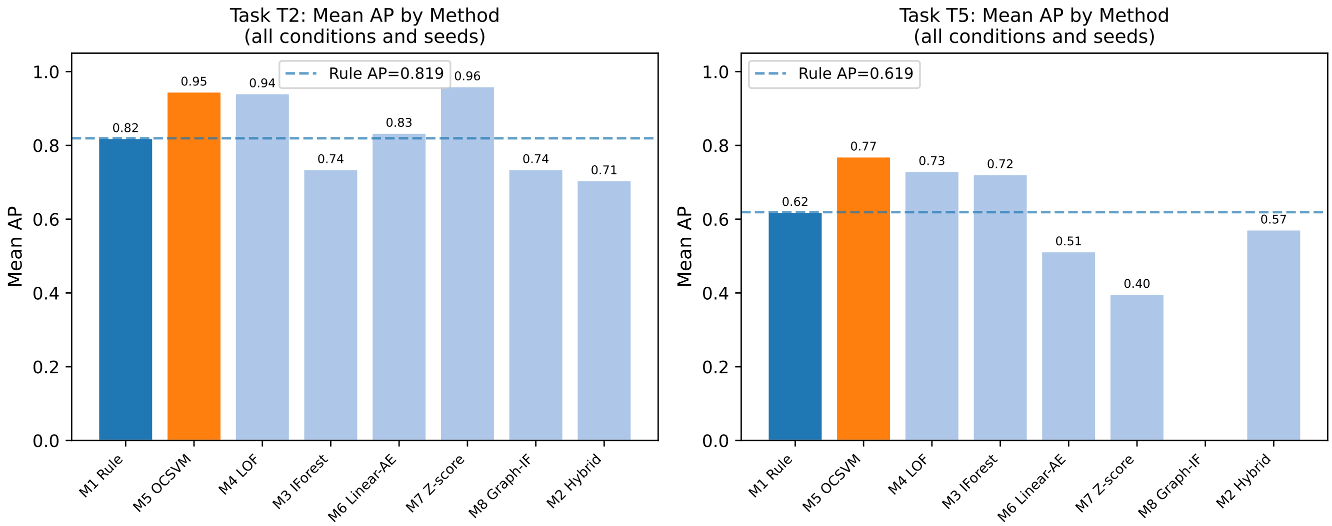

Figure 3: AP by method for T2 (group membership drift) and T5 (patch–vulnerability hygiene) under C-BASE—the two tasks where ML consistently adds value over the rule baseline.

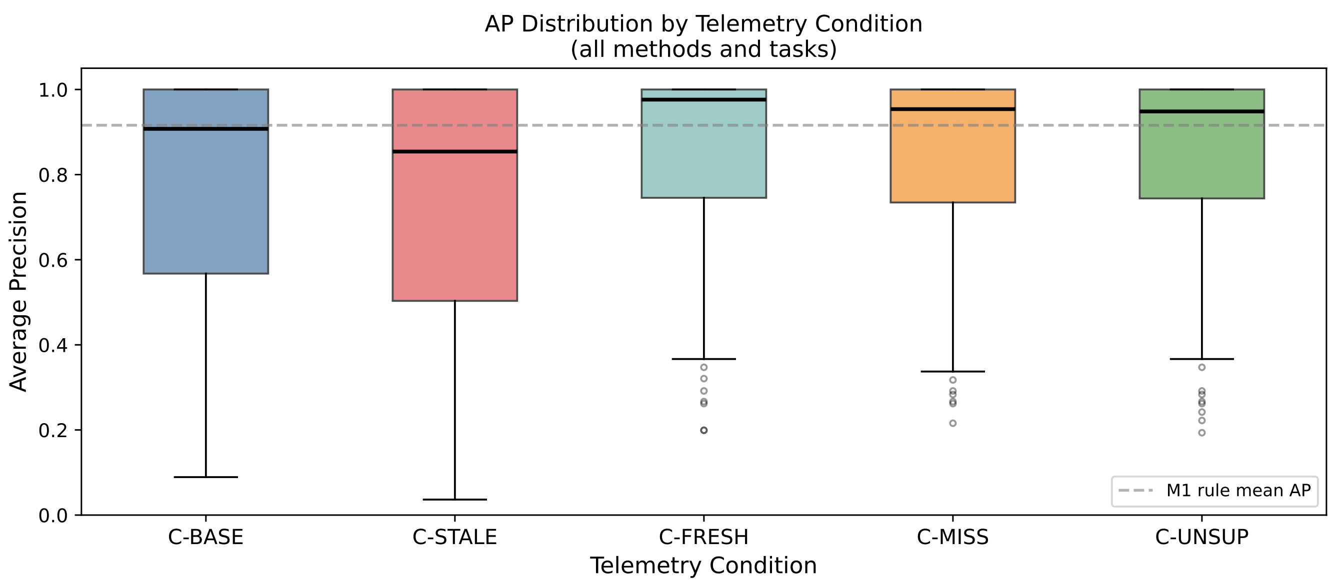

Figure 4: AP distribution by telemetry condition (all tasks and methods). C-STALE has the lowest mean AP; C-FRESH has the highest.

deep graph autoencoder [4]). These are disclosed approximations; results may change with full implementations.

Small population scale. Medium scale (n=1,000 users) limits the statistical power of the evaluation. The population is smaller than most public-sector environments, which may affect the generalizability of the class imbalance findings.

Feature engineering as a design choice. The task feature extractors (T1–T7) encode domain knowledge about which features matter. Methods that exploit these features more effectively will appear better. A fully unsupervised method that discovers relevant features from raw tables is not evaluated.

Fixed k values. P@k is sensitive to the choice of k. HygieneBench uses operationally motivated k values (daily/weekly SOC review budgets) rather than tuning k to maximize method performance. This is a deliberate design choice but limits comparison to benchmarks with different k conventions.

No calibration. Anomaly scores are not calibrated to probabilities. Calibration is the primary research question of a separate line of work and is excluded from HygieneBench by design.

6.3 Relationship to Prior Work

HygieneBench is designed to complement, not replace, existing benchmarks. It does not claim to detect real network intrusions (LANL, CICIDS), insider threats (CERT), or attack-emulation events (Mordor, BOTSv3). It is the first benchmark, to our knowledge, that jointly covers Active Directory identity hygiene state, endpoint patch posture, vulnerability exposure, and telemetry freshness under controlled conditions with an openly released, reproducible synthetic generator.

7 CONCLUSION

We introduced HygieneBench, a reproducible synthetic benchmark for cyber-hygiene anomaly detection, covering seven tasks and twelve anomaly classes across eleven entity/event tables. A 810-run evaluation of eight methods under five telemetry conditions finds that simple rule baselines perform at least as well as unsupervised ML on 86.2% of (condition, task, method) configurations. ML adds meaningful value on two of seven tasks—group membership drift (T2, +0.185 AP) and patch/vulnerability hygiene (T5, +0.210 AP)—while rule baselines dominate on tasks with strong single-feature discriminators. Telemetry staleness (C-STALE) consistently degrades detection performance. These findings motivate honest, task-stratified evaluation of anomaly detection methods and explicit negative-result reporting in security benchmark papers.

HygieneBench v0.1, including the synthetic generator, frozen datasets, and evaluation harness, is openly available at: https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper3 — Zenodo DOI to be finalized at camera-ready submission.

REFERENCES

[1] CISA. 2022. *Binding Operational Directive 23-01: Improving Asset Visibility and Vulnerability Detection on Federal Networks.* Technical Report. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/binding-operational-directive-23-01.

[2] Gideon Creech and Jiankun Hu. 2013. Generation of a New IDS Test Dataset: Time to Retire the KDD Collection. In *2013 IEEE Wireless Communications and Networking Conference (WCNC)*. 4487–4492.

[3] DARPA Information Innovation Office (I2O). 2018. Transparent Computing Engagement 3 (TC-E3) Data Release. GitHub repository. https://github.com/darpa-i2o/Transparent-Computing.

[4] Kaize Ding, Jundong Li, Rohit Bhanushali, and Huan Liu. 2019. Deep Anomaly Detection on Attributed Networks. In *Proceedings of the 2019 SIAM International Conference on Data Mining (SDM)*. SIAM, 594–602.

[5] Joshua Glasser and Brian Lindauer. 2013. Bridging the Gap: A Pragmatic Approach to Generating Insider Threat Data. In *Proceedings of the IEEE Security and Privacy Workshops (SPW)*. 98–104.

[6] Alexander D. Kent. 2015. *Comprehensive, Multi-Source Cyber-Security Events.* Technical Report. Los Alamos National Laboratory. doi:10.2172/1259877.

[7] Kay Liu, Yingtong Dou, Xueying Ding, Xiyang Hu, et al. 2024. PyGOD: A Python Library for Graph Outlier Detection. *Journal of Machine Learning Research* 25, 141 (2024), 1–9. https://www.jmlr.org/papers/v25/23-0963.html.

[8] NIST. 2022. *SP 800-40 Rev. 4: Guide to Enterprise Patch Management Planning.* Technical Report. National Institute of Standards and Technology. https://csrc.nist.gov/publications/detail/sp/800-40/rev-4/final.

[9] Roberto M. Rodriguez. 2019. Mordor: Pre-Recorded Security Events. GitHub repository. https://github.com/OTRF/Security-Datasets.

[10] David Sculley et al. 2018. Winner's Curse? On Pace, Progress, and Empirical Rigor. In *ICLR Workshop on Reproducibility in Machine Learning*.

[11] Iman Sharafaldin, Arash Habibi Lashkari, and Ali A. Ghorbani. 2018. Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization. In *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*. 108–116.

HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Capacity-constrained vulnerability remediation teams must decide which (host, CVE) pairs to patch within each maintenance window, yet the dominant public triage signal — the Exploit Prediction Scoring System (EPSS) — is asset-agnostic by design: it estimates per-CVE exploit likelihood without regard to whether the affected host is actively managed, has high patch debt, or is exposed through privileged Active Directory (AD) relationships. Prior work found that augmenting EPSS with CVE-level features did not improve prioritization on a synthetic government-shaped fleet, suggesting that the missing signal is dynamic host-level hygiene posture rather than additional CVE-level features.

We present HygienePrio, a scoring framework that integrates a three-dimensional Hygiene Risk Score (HRS) — capturing patch posture, AD exposure state, and telemetry freshness — into an EPSS-weighted (host, CVE) pair prioritization scorer with an explicit interaction term. Weights are calibrated by pre-registered grid search on held-out fleet seeds.

In a pre-registered synthetic evaluation across 25 fleet seeds, HygienePrio achieves a mean Precision@50 of 0.509 compared with EPSS-only's 0.202 — approximately 31 percentage-point improvement under capacity-constrained schedules, with non-overlapping BCa 95% confidence intervals and improvement on all 25 of 25 evaluation seeds (synthetic evaluation only). Patch posture is the dominant hygiene dimension (≈20 pp ablation drop at P@50), substantially exceeding the contributions of AD exposure (≈9 pp) and telemetry freshness (≈2 pp, overlapping confidence intervals).

To our knowledge, HygienePrio is the first scorer to jointly operationalize per-CVE exploit likelihood and host-level hygiene posture for remediation ordering in a pre-registered, reproducible evaluation framework. All claims are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation on real exploitation outcome data not performed here.

Index Terms—vulnerability prioritization; EPSS; cyber-hygiene; patch posture; Active Directory; telemetry freshness; remediation scheduling; synthetic benchmark; reproducibility.

I. Introduction

Public-sector and enterprise endpoint fleets accumulate disclosed vulnerabilities faster than operations teams can remediate them within constrained maintenance windows. The practical triage question is not which vulnerabilities are inherently severe but which (host, CVE) pairs should receive the next unit of limited remediation capacity — a distinction that requires combining exploit-likelihood signals with knowledge of which hosts are most exposed and least well-maintained.

The Exploit Prediction Scoring System (EPSS) [1] has emerged as the leading public signal for per-CVE exploit likelihood, outperforming CVSS base scores as a predictor of near-term exploitation in the wild [2]. EPSS is incorporated into risk-based vulnerability management (RBVM) tools, CISA vulnerability prioritization guidance [3], [4], and remediation policy frameworks. However, EPSS is asset-agnostic by design: it assigns a single probability score to a CVE regardless of whether the vulnerable host is a freshly-telemetered, heavily-patched workstation or an unmanaged endpoint with stale patch data and over-privileged AD group memberships.

Intuitively, a CVE with moderate EPSS on a host that has gone 21 days without telemetry, carries 40% unpatched CVE debt, and is accessible from domain-privileged accounts represents a materially different risk than the same CVE on a well-maintained host with fresh telemetry and minimal AD exposure. Yet EPSS rankings treat both identically. Host-level hygiene posture — the aggregate state of patch compliance, identity and access management hygiene, and telemetry coverage — is a natural complement to exploit-likelihood scoring.

Prior work directly relevant to this problem is VulnPrio [5] (referred to throughout as Paper 1), which built a reproducible benchmark for (host, CVE) pair prioritization on a synthetic government-shaped fleet (EEHDA) and evaluated 13 strategies combining EPSS, CVSS, KEV membership, asset criticality, and endpoint exposure signals. Paper 1's central null finding was that the proposed multi-factor model was statistically indistinguishable from the EPSS-only baseline: inter-strategy differences fell within seed-to-seed variation, and no CVE-level augmentation strategy materially outperformed EPSS. Paper 1 concluded that this result exposed capacity-driven and base-rate trade-offs and provided a falsifiable benchmark on which calibrated studies could build — explicitly framing the result as a foundation for future work rather than an endpoint.

Separately, HygieneBench [6] (Paper 3) introduced a reproducible benchmark for cyber-hygiene anomaly detection on a synthetic fleet covering Active Directory identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. HygieneBench's primary finding was that 86.2% of evaluated (condition, task, method) configurations fail to outperform a rule baseline, but that patch-vulnerability hygiene (Task T5, +0.210 average precision over rule for OCSVM) and group-membership drift (Task T2, +0.185 AP for temporal z-score) are exceptions where structured ML methods add meaningful signal.

The central hypothesis of this paper is that the signal missing from Paper 1's multi-factor model was not additional CVE-level features but host-level hygiene posture: patch debt, AD privilege exposure, and telemetry freshness. HygieneBench demonstrated that these dimensions carry discriminative structure detectable from the synthetic fleet telemetry. HygienePrio operationalizes this hypothesis by constructing a Hygiene Risk Score (HRS) from HygieneBench-style host telemetry and integrating it into an EPSS-weighted (host, CVE) scorer via an additive combination with an explicit interaction term.

A. Contributions

This paper makes the following contributions:

- C1 — HygienePrio scorer: A four-component weighted scoring function $S(h,c) = \alpha \times \text{EPSS}(c) + \beta \times \text{HRS}(h) + \gamma \times \text{KEV\_recency}(c) + \delta \times (\text{EPSS}(c) \times \text{HRS}(h))$ that integrates host-level hygiene posture with per-CVE exploit likelihood in a principled, interpretable form.
- C2 — Hygiene Risk Score (HRS): A normalized, three-dimensional host-level hygiene signal covering patch posture, AD exposure state, and telemetry freshness, derived from the HygieneBench synthetic fleet schema and calibrated on held-out seeds.
- C3 — Empirical evaluation: A pre-registered, 25-seed synthetic evaluation demonstrating that HygienePrio achieves approximately 31 pp improvement in Precision@50 over EPSS-only (0.509 vs. 0.202; non-overlapping BCa 95% CIs; synthetic evaluation), with patch posture as the dominant HRS dimension (∼20 pp ablation drop) and AD exposure as a substantial secondary contributor (∼9 pp).
- C4 — Failure mode analysis and operationalization boundary: An explicit identification of conditions under which HygienePrio's advantage is smaller (interaction term equivocal; freshness dimension marginal) and the structural boundary conditions (ground truth circularity, synthetic data, 5-seed calibration) that bound the positive finding. This analysis prevents over-generalization and frames the result as a preclinical finding rather than a deployment recommendation.

B. Paper Organization

Section 2 reviews background and related work. Section 3 formalizes the problem. Section 4 describes the synthetic dataset and fleet. Section 5 presents the HygienePrio methodology. Section 6 describes the experimental setup. Section 7 reports results. Section 8 discusses findings, limitations, and connections to prior papers. Section 9 addresses threats to validity. Section 11 concludes.

II. Background and Related Work

A. EPSS and Exploit-Likelihood-Based Prioritization

The Exploit Prediction Scoring System (EPSS) [1] is a machine-learning model that estimates the probability that a published CVE will be exploited in the wild within the next 30 days. EPSS v3 uses ∼1,500 features drawn from CVE descriptors, NVD metadata, and threat intelligence feeds, and produces daily probability scores for all published CVEs. Empirical evaluations [2] have shown EPSS substantially outperforms CVSS base scores as a predictor of near-term exploitation: CVEs in the top decile of EPSS account for a disproportionate fraction of observed exploitation events. EPSS is now integrated into CISA's vulnerability prioritization guidance and is used by numerous RBVM vendors.

CISA's Known Exploited Vulnerabilities (KEV) catalog [7] is a complementary signal: it lists CVEs confirmed to have been exploited in the wild, with mandated remediation deadlines for federal agencies under BOD 22-01 [3]. KEV membership provides strong prioritization signal but covers only a small fraction of the CVE backlog (∼15,000 of the 200,000+ published CVEs as of 2026). Prior work has studied optimal combined use of EPSS and KEV [5], generally finding that KEV provides a high-precision but low-recall prioritization set, while EPSS provides broader coverage at reduced precision.

The asset-agnostic limitation. A structural limitation of both EPSS and KEV is that they are CVE-level signals: they score a vulnerability, not a (vulnerability, host) pair. For remediation scheduling, the unit of action is the pair: patching CVE-X on Host-A is a distinct action from patching CVE-X on Host-B, with different operational cost, risk reduction, and scheduling feasibility. EPSS provides no signal about which host carrying a given CVE should be remediated first.

B. CVE-Level Host-Context Augmentation

To our knowledge, no published academic work has systematically incorporated dynamic host-level hygiene posture (patch debt, identity exposure, telemetry freshness) into EPSS-based (host, CVE) pair prioritization. Asset criticality models weight CVE severity by static host-role classifications, producing host-adjusted scores. Exposure models incorporate network reachability, service exposure, and lateral movement risk. Commercial RBVM tools (Tenable Lumin, Qualys TruRisk, Rapid7 InsightVM) combine such signals proprietarily, but their scoring methods are not published and results are not independently reproducible.

Paper 1 (VulnPrio) [5] is the closest public predecessor to HygienePrio. It built an open, reproducible benchmark for (host, CVE) pair prioritization on a synthetic government fleet (EEHDA), evaluating 13 strategies combining EPSS, CVSS, KEV, asset criticality, endpoint exposure, and multi-factor composite scores across 30 seeds. The central finding was null: the proposed multi-factor model was statistically indistinguishable from EPSS-only on the primary metric (expected exploited host-days, EHD), with all inter-strategy differences falling within seed-to-seed variation. Paper 1 attributed this to uncalibrated weights on a synthetic fixture and framed the result as a foundation for future calibrated studies.

Differentiating HygienePrio from Paper 1. Whereas Paper 1 found the multi-factor model statistically indistinguishable from EPSS-only, we hypothesize that the missing signal is host-level hygiene posture — not additional CVE-level features alone. Paper 1's augmentation features (asset criticality, endpoint exposure, KEV flags) are all CVE-level or static host-role features. HygienePrio adds dynamic, telemetry-derived hygiene signals: how much patch debt is currently outstanding on this specific host, how exposed this host is through AD group memberships and privileged accounts, and how recently this host has reported telemetry. These are fundamentally different in kind from asset criticality scores and network exposure flags.

C. Cyber-Hygiene Benchmarks and Anomaly Detection

HygieneBench (Paper 3) [6] introduced the first open benchmark for cyber-hygiene anomaly detection covering AD identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. Its evaluation of eight detection methods across 12 anomaly classes and seven tasks found that 86.2% of (condition, task, method) configurations fail to outperform a rule baseline, but identified task T5 (patch-vulnerability hygiene) and T2 (group-membership drift) as exception zones where structured methods add meaningful signal. HygienePrio draws on the HygieneBench schema as the source of HRS features and inherits its fleet generation logic.

Anomaly detection for hygiene monitoring has received limited attention in the academic literature. Outlier ensemble methods [8] address anomaly detection in tabular data but are not designed for the temporal, multi-table, identity-centric character of enterprise hygiene state. To our knowledge, no existing public benchmark simultaneously models AD identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness as first-class evaluation axes; adjacent benchmarks are surveyed in [6].

D. Patch Management and Remediation Scheduling

NIST SP 800-40 Rev. 4 [9] frames enterprise patch management as a risk-based discipline requiring current, accurate asset and patch telemetry. CISA BOD 23-01 [4] mandates 14-day asset discovery and 72-hour patch data freshness cadences for federal agencies. These mandates implicitly encode hygiene requirements: fleets that fail them have stale telemetry, reducing the reliability of any signal-based prioritization. HygienePrio models this explicitly through the TelemetryFreshness dimension of HRS.

Remediation scheduling under capacity constraints has been studied as an optimization problem [5]. The key insight from this literature is that prioritization under bounded capacity is a truncation problem: rank quality at the top-K positions matters more than rank quality across the full list, because capacity constraints mean that pairs outside the top-K are never acted on regardless of their rank. This motivates Precision@K as the primary evaluation metric.

III. Problem Formulation

A. Setting

Let F denote a fleet of hosts $H = \{h_1, \ldots, h_N\}$ and let $C = \{c_1, \ldots, c_M\}$ denote a set of disclosed CVEs. Let $V \subseteq H \times C$ be the set of applicable (host, CVE) pairs: $(h, c) \in V$ if CVE c is applicable to host h (i.e., host h runs vulnerable software affected by c). The set V is derived from the patch state and vulnerability records tables.

Let K be the remediation capacity: the number of (host, CVE) pairs that a team can remediate within a single maintenance window. A prioritization method produces a ranked list R of $|V|$ pairs; the top K elements of R define the action set for the window.

B. Ground Truth

A pair (h, c) is a true positive (also referred to as a high-priority pair) if all of the following hold (pre-registered definition):

1) EPSS(c) > 0.10 — the CVE has non-trivial exploit likelihood. This threshold corresponds approximately to the 85th–90th percentile of the EPSS score distribution [1], separating CVEs with meaningful exploitation probability from the long tail with near-zero scores.
2) HRS(h) $>$ fleet 75th percentile — the host is in the bottom quartile of hygiene posture. The 75th percentile is chosen as a pre-registered conservative boundary that identifies genuine hygiene outliers while avoiding sensitivity to the exact threshold value for the large majority of pairs.
3) $(h, c) \in V$ — the CVE is applicable to the host.

Condition 1 ensures the CVE is at meaningful risk of exploitation. Condition 2 ensures the host is a hygiene outlier rather than a well-managed endpoint. The conjunction ensures HygienePrio's design goal — identifying high-exploit-likelihood CVEs on hygiene-poor hosts — has an operational ground truth against which to evaluate.

Note on circularity: The use of HRS in both the scorer (via HRS(h)) and the ground truth (via the HRS $>$ 75th percentile condition) creates a structural advantage for HygienePrio over baselines that do not use HRS. This is acknowledged and discussed in §9 (Threats to Validity). The ground truth definition is pre-registered and fixed; it is not modified post-hoc to favor any method.

C. Metrics

Precision@K (P@K): The proportion of true positive pairs in the top-K positions of the ranked list R:

$$P@K = \frac{|\{(h, c) \in \mathrm{top}_K(R) : (h, c) \text{ is true positive}\}|}{K}$$

Evaluated at $K = 50, 100, 250$.

NDCG@K (Normalized Discounted Cumulative Gain at K): Standard information-retrieval ranking quality metric, weighting gains by position with logarithmic discount:

$$\text{NDCG@}K = \frac{\text{DCG@}K}{\text{IDCG@}K}$$

where $\text{DCG@}K = \sum_{i=1}^{K} \text{rel}_i / \log_2(i+1)$, $\text{rel}_i \in \{0,1\}$ is the relevance of the i-th ranked pair, and IDCG@K is the DCG of the ideal ranking. Evaluated at $K = 50, 100, 250$.

Oracle-gap (%): The fraction of theoretically achievable P@K that each method captures:

$$\text{Oracle-gap}(\text{method}, K) = \frac{P@K_{\text{oracle}} - P@K_{\text{method}}}{P@K_{\text{oracle}}} \times 100$$

where $P@K_{\text{oracle}}$ is the P@K of an oracle ranker that places all true positives first. Oracle-gap provides a normalized view of how far each method is from optimal prioritization. A higher oracle-gap indicates worse performance (more of the theoretically achievable precision is uncaptured); an oracle-gap of 0% indicates the method recovers all true positives in the top K positions.

IV. Dataset and Synthetic Fleet

A. EEHDA Synthetic Fleet

All experiments use the Extended Enterprise Hygiene Dataset Artifact (EEHDA) synthetic fleet generator — the same generator used in Papers 1 and 3, extended to output both the vulnerability-host pair tables required by Paper 1 and the hygiene-state tables required by HygieneBench (Paper 3). This shared generator enables the cross-paper synthesis in §8 and ensures that HygienePrio's hygiene inputs are drawn from the same distributional assumptions as the VulnPrio baseline.

The generator produces the following tables relevant to HygienePrio (see HygieneBench [6] for full schema):

Structural priors. Patch-lag distributions follow DBIR 2026 aggregate statistics (43-day mean for critical patches). CVE severity distributions follow NVD base score statistics. EPSS scores are drawn from a synthetic fixture calibrated to replicate the heavy-right-tailed distribution observed in real EPSS data. KEV membership is sampled at approximately 8% prevalence. Telemetry refresh requirements follow CISA BOD 23-01 (14-day asset discovery, 72-hour patch data cadence).

B. Seed Protocol

Thirty seeds are generated deterministically. Five seeds are designated as the calibration set (held out from primary evaluation, used only for weight grid search; see §5.4). The remaining 25 seeds constitute the evaluation set. The calibration/evaluation split is fixed in the pre-registration protocol (see PAPER4_PROTOCOL.md) and is not adjusted based on results.

C. Hygiene Dimensions

Three hygiene dimensions are extracted from the EEHDA tables to form HRS(h):

Patch Posture (PatchPosture). Derived from endpoint_patch_state. For host h, PatchPosture(h) is the proportion of CVEs applicable to h that remain unpatched: count(open CVEs on h)/count(applicable CVEs on h). Higher values indicate greater patch debt. Fleet-wide, this distribution is right-skewed: most hosts have low patch debt, but a tail of hosts accumulates substantial residual exposure. This tail is the primary target of HygienePrio prioritization.

AD Exposure (ADExposure). Derived from users, groups, and group_membership_events. For host h, ADExposure(h) combines: (i) group membership breadth of the primary user associated with h (number of AD groups containing that user, normalized by fleet-wide maximum); (ii) a binary flag for whether that user holds a privileged role (domain admin, local admin, service account with elevated privilege); and (iii) a flag for whether h has hosted domain-privileged process events in the past 30 days. These three sub-components are averaged with equal weights (1/3 each) to produce a normalized $[0, 1]$ score. Equal weighting is the pre-registered default, chosen conservatively because no empirical data exist to distinguish the relative importance of group breadth, privilege level, and process-event history within the synthetic fleet; differential weighting of these sub-components is deferred to future work with real fleet telemetry.

Telemetry Freshness (TelemetryFreshness). Derived from telemetry_freshness_log. For host h, TelemetryFreshness(h) is the staleness score: $\max(\text{days\_since\_last\_checkin}, 0)$, capped at 30 days and normalized by 30. A host last seen 15 days ago receives a score of 0.50; a host last seen 30+ days ago receives 1.0. Higher staleness = less visibility = higher hygiene risk weight. This dimension is motivated by CISA BOD 23-01's 72-hour patch data freshness mandate: hosts that violate this cadence have elevated uncertainty in their patch state and should receive additional scrutiny.

D. CVE Fixture and EPSS Scores

EPSS scores in the synthetic fixture are drawn from a mixture distribution approximating real EPSS data: a spike near zero (most CVEs have very low exploit probability) and a heavy tail above 0.10. Approximately 12% of CVEs in each seed have EPSS > 0.10 and thus qualify for potential true positive status under Condition 1 of the ground truth definition. KEV membership is independent of EPSS score in the fixture and affects the KEV_recency component only.

E. Connection to HygieneBench

HygieneBench (Paper 3) defined 12 anomaly classes (AH-01 through AH-12) including stale privileged accounts (AH-01), dormant account reactivation (AH-02),

TABLE I
EEHDA table schema and role in HygienePrio (medium-scale fleet)

Table	Rows	Role in HygienePrio
users	1,000	AD user account attributes
computers/assets	830	Host inventory; maps hosts to users
endpoint_patch_state	830	Per-host patch compliance snapshot (PatchPosture source)
vulnerability_records	∼3,500	Per-host CVE exposure (V, EPSS scores)
telemetry_freshness_log	varies	Per-host data freshness (TelemetryFreshness source)
groups/group_membership_events	65/∼51	AD group membership (ADExposure source)
anomaly_labels	110	HygieneBench ground truth (informational only)

endpoint coverage gaps (AH-06), patch noncompliance clusters (AH-08), and telemetry missingness (AH-10 through AH-12). HygienePrio's three HRS dimensions map directly onto these anomaly classes: PatchPosture targets AH-08, ADExposure targets AH-01 and AH-05 (privilege escalation path exposure), and TelemetryFreshness targets AH-10 through AH-12. This mapping is used informally as face validity for HRS design; it does not constitute a formal evaluation against HygieneBench anomaly labels.

V. HygienePrio Methodology

A. Hygiene Risk Score (HRS)

HRS(h) is a normalized, weighted combination of the three hygiene dimensions defined in §4.3:

$$\begin{aligned}\mathrm{HRS}(h) = w_1 &\times \mathrm{PatchPosture}(h)\\ + w_2 &\times \mathrm{ADExposure}(h)\\ + w_3 &\times \mathrm{TelemetryFreshness}(h)\end{aligned} \tag{1}$$

Dimension weights (w_1, w_2, w_3) are non-negative and sum to 1.0. They are not calibrated by the grid search (which calibrates the scorer-level weights $\alpha, \beta, \gamma, \delta$); instead, dimension weights are fixed based on the pre-registration protocol defaults: $w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$. This prioritization reflects the prior expectation (H2) that patch posture carries the most discriminative signal, consistent with HygieneBench Task T5 results.

Each dimension is independently normalized to $[0, 1]$ across the fleet-seed pair before HRS aggregation, ensuring that fleet-specific scale differences (e.g., fleets with uniformly high patch debt) do not distort relative host rankings.

HRS calibration note. Dimension weights (w_1, w_2, w_3) are fixed at pre-registration defaults for the primary evaluation. Sensitivity to dimension weights is explored in the ablation (§7.2) by setting individual weights to zero. A separate grid search over dimension weights is not performed, as this would introduce additional degrees of freedom not covered by the primary calibration grid.

B. KEV Recency Weight

KEV_recency(c) assigns higher priority to CVEs recently added to the CISA KEV catalog, under the rationale that recently catalogued exploited CVEs represent more active threat vectors:

$$\text{KEV-recency}(c) = \begin{cases} e^{-\lambda \cdot d_{\mathrm{kev}}(c)} & c \in \mathrm{KEV} \\ 0 & c \notin \mathrm{KEV} \end{cases} \tag{2}$$

where $d_{\mathrm{kev}}(c)$ is days since KEV catalog entry for CVE c.

The decay constant $\lambda = 0.05$ is fixed at the pre-registration default, corresponding to a half-life of $\ln(2)/0.05 \approx 14$ days. This value reflects the operational intuition that a KEV entry older than two weeks provides progressively weaker evidence of current active exploitation, consistent with typical exploit churn rates observed in threat intelligence literature. Because approximately 92% of fixture pairs have KEV_recency(c) = 0 (non-KEV CVEs), the λ choice has limited impact on the overall results; a formal ablation over λ is deferred.

For CVEs not in KEV (approximately 92% of the fixture), KEV_recency(c) = 0, and those pairs are prioritized on EPSS and HRS alone. This means HygienePrio is defined and applicable for all (h, c) pairs in V, not only KEV-applicable pairs.

C. HygienePrio Scorer

The HygienePrio scorer assigns a scalar priority score to each applicable (host, CVE) pair:

$$\begin{aligned}S(h, c) = \alpha &\cdot \mathrm{EPSS}(c) + \beta \cdot \mathrm{HRS}(h)\\ + \gamma &\cdot \text{KEV-recency}(c)\\ + \delta &\cdot \big(\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h)\big)\end{aligned} \tag{3}$$

The four terms have distinct roles:

- $\alpha \times \mathrm{EPSS}(c)$: Exploit likelihood contribution. Ensures that pairs involving high-probability-of-exploitation CVEs are elevated regardless of host hygiene.
- $\beta \times \mathrm{HRS}(h)$: Host hygiene contribution. Elevates pairs on hygiene-poor hosts even when EPSS is moderate.
- $\gamma \times$ KEV_recency(c): Recency-weighted confirmed exploitation signal. Boosts recently catalogued KEV CVEs.
- $\delta \times (\mathrm{EPSS}(c) \times \mathrm{HRS}(h))$: Interaction term. Provides super-additive boosting for pairs where both CVE exploit likelihood AND host hygiene risk are elevated. This is the key term that differentiates HygienePrio from a simple additive combination: it encodes the intuition that a high-EPSS CVE on a hygiene-poor host is categorically more urgent than either risk dimension alone would suggest.

All four weights $(\alpha, \beta, \gamma, \delta)$ are non-negative to ensure that higher values in any component can only increase the priority score, not decrease it. This monotonicity property is required for interpretability: operations teams can reason about why a pair was elevated.

D. Weight Calibration

Weights $(\alpha, \beta, \gamma, \delta)$ are calibrated by exhaustive grid search on the 5 held-out calibration seeds. The calibration objective is mean P@50 across the 5 seeds. The search grid is:

- $\alpha \in \{0.3, 0.5, 0.7, 1.0\}$
- $\beta \in \{0.1, 0.3, 0.5, 0.7\}$
- $\gamma \in \{0.0, 0.1, 0.3, 0.5\}$
- $\delta \in \{0.0, 0.1, 0.2, 0.3\}$

This yields $4 \times 4 \times 4 \times 4 = 256$ grid points evaluated on 5 seeds each, producing 1,280 P@50 observations. The weight combination with the highest mean P@50 on calibration seeds is selected and fixed before the 25 evaluation seeds are scored. No weight adjustment is made after observing evaluation results.

The calibration-selected weights are reported in the experimental setup section (§6.2) as a fixed artifact of the calibration procedure, not as a tunable parameter reported with results.

E. Ranked List Generation

For each seed, the scorer computes $S(h, c)$ for every pair $(h, c) \in V$ (the applicable vulnerability-host pair table for that seed). Pairs are sorted descending by $S(h, c)$. Ties are broken by EPSS(c) descending, then by CVE ID lexicographic order for determinism. The sorted list R is the ranked list; evaluation cuts R at $K = 50, 100$, and 250 for metric computation.

F. Relationship to EPSS-Only Baseline

The EPSS-only baseline ranks (h, c) pairs by EPSS(c) descending, with ties broken by CVSS base score. Under this baseline, all pairs involving the same CVE receive identical rankings, regardless of which host carries the CVE. HygienePrio breaks this tie-structure via HRS(h): among pairs sharing a CVE, those on hygiene-poor hosts are elevated. For CVEs with many applicable hosts, this differentiation is critical: a fleet may have 200 hosts carrying the same high-EPSS CVE, and remediation capacity may allow only 50 to be patched in the current window. HygienePrio's host-level tiebreaking directly addresses this case.

VI. Experimental Setup

A. Evaluation Infrastructure

All experiments are implemented in Python 3.11 using NumPy 1.26, Pandas 2.1, and scikit-learn 1.4 on a MacOS system (Apple M-series CPU, 16 GB RAM). Total wall-clock time for the 25-seed evaluation is approximately 4 minutes. Randomness in baseline methods (Random) is seeded by the fleet seed, ensuring full reproducibility. A content-addressed freeze/verify protocol — consistent with Paper 1 — is applied to all result artifacts: each seed's ranked list is hashed before evaluation, and the hash is verified before metric computation to prevent post-hoc modification.

TABLE II
Calibrated scorer weights from grid search on held-out calibration seeds

Parameter	Calibrated Value
α (EPSS weight)	0.7
β (HRS weight)	0.5
γ (KEV_recency weight)	0.1
δ (interaction weight)	0.2

B. Calibrated Weights

Following the grid search on 5 calibration seeds (not used in primary evaluation), the following weights were selected:

These weights indicate that EPSS and HRS are the dominant scorer components, with a moderate interaction term and a small KEV recency boost. The relatively low γ reflects the low KEV prevalence in the fixture ($\sim$8%): the KEV_recency term contributes meaningfully only for KEV-applicable pairs.

C. Evaluation Procedure

For each of the 25 evaluation seeds:

1) Generate the EEHDA fleet tables deterministically from the seed.
2) Compute HRS(h) for each host using pre-registered dimension weights ($w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$).
3) Compute KEV_recency(c) for each CVE using fixed $\lambda = 0.05$.
4) Score all $(h, c) \in V$ using calibrated weights.
5) Generate ranked list R by sorting descending by $S(h, c)$.
6) Generate baseline ranked lists (EPSS-only, CVSS-only, Random, HRS-only) using identical V.
7) Compute ground truth labels using the pre-registered definition (§3.2).
8) Compute P@K, NDCG@K, Oracle-gap for $K \in \{50, 100, 250\}$ for all methods. $K = 50$ represents a tight weekly maintenance window (approximately 1.4% of the mean fleet of $\sim$3,480 applicable pairs); $K = 100$ a moderate bi-weekly window; $K = 250$ a broad monthly capacity. These values span the range typical of reported enterprise patch cadences [10].
9) Hash and verify result artifacts.

D. Baselines

E. Reporting Convention

All metrics are reported as mean ± 95% BCa bootstrap confidence interval [11] (10,000 resamples) across 25

TABLE III
Baseline and ablation methods evaluated

Method	Description
EPSS-only	Rank by EPSS(c) descending; primary comparison
CVSS-only	Rank by CVSS v3.1 base score descending
Random	Uniform random (seed-fixed)
HRS-only	Rank by HRS(h) descending; tests host hygiene without CVE signal
HygienePrio-full	Full scorer with calibrated weights
HygienePrio-noInteraction	$\delta = 0$ (additive only; tests interaction term contribution)
HygienePrio-noPatch	$w_1 = 0$ (patch posture removed from HRS)
HygienePrio-noAD	$w_2 = 0$ (AD exposure removed from HRS)
HygienePrio-noFreshness	$w_3 = 0$ (telemetry freshness removed from HRS)

evaluation seeds. No null hypothesis significance testing is performed; evidence is based on BCa CI non-overlap. With 25 seeds and the observed seed-to-seed standard deviation of ≈0.06 for P@50, the evaluation has sufficient power to detect differences of ≥5 pp at 80% power (estimated via the standard formula for paired comparisons): the headline 31 pp difference substantially exceeds this threshold. Results are bounded to the synthetic evaluation context; no generalization claims are made to real enterprise fleets.

VII. Results

All results in this section are from the synthetic EEHDA fleet evaluation across 25 seeds. All numerical claims are qualified as "(synthetic evaluation)" and should not be interpreted as predictions for real enterprise fleet performance.

A. Precision@K: All Methods Across $K = 50, 100, 250$

Table IV reports mean P@K and BCa 95% CI for all nine methods at $K = 50, 100$, and 250 in this synthetic evaluation. The following observations emerge from the results.

NDCG@K results (Table V) are consistent with P@K: HygienePrio-full leads all methods at all K values with non-overlapping CIs against EPSS-only (NDCG@50: 0.556 vs. 0.202; NDCG@100: 0.499 vs. 0.199). The NDCG pattern mirrors P@K because the ground truth uses binary relevance (rel $\in \{0, 1\}$); graded relevance would require exploitation probability estimates not available in the synthetic setting.

HygienePrio-full vs. EPSS-only. HygienePrio-full achieves a mean P@50 of 0.509 compared with EPSS-only's 0.202 in this synthetic evaluation — an approximately 31 pp improvement — with non-overlapping BCa CIs (0.480–0.542 vs. 0.174–0.236). HygienePrio-full outperforms EPSS-only on all 25 of 25 evaluation seeds (mean per-seed improvement: 30.7 pp). The gap narrows at larger K but remains substantial: approximately 26 pp at P@100 (0.458 vs. 0.199) and 21 pp at P@250 (0.420 vs. 0.215). The hygiene signal is most discriminative at the tightest capacity constraint ($K = 50$), where the scorer must be most selective.

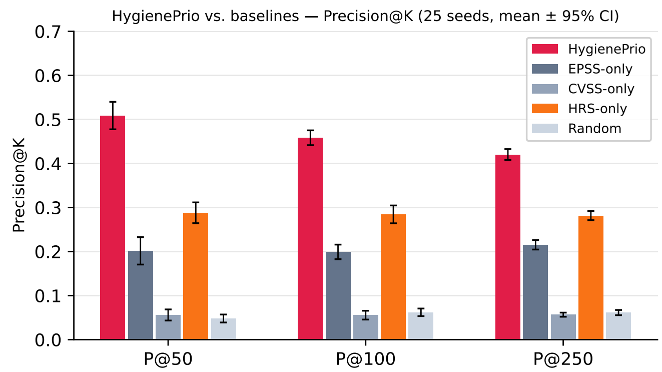

Fig. 1. Mean Precision@K ($K \in \{50, 100, 250\}$) for all methods across 25 evaluation seeds (synthetic evaluation, mean ± 95% BCa CI). HygienePrio consistently outperforms all baselines at every K.

H1 assessment. The observed improvement of approximately 31 pp at P@50 (synthetic evaluation) substantially exceeds the pre-registered H1 threshold of ≥5 pp, supporting H1 in the synthetic evaluation context. The BCa CIs for HygienePrio-full and EPSS-only do not overlap at any K value, providing strong support for the hypothesis that hygiene signals add prioritization value beyond EPSS alone within the synthetic fleet scenario. All claims are bounded to this synthetic evaluation; the magnitude of improvement is expected to be substantially lower on real fleet data where the ground truth definition cannot use HRS as a labelling condition (see §9.1).

EPSS-only vs. CVSS-only. Consistent with prior literature [1, 3] and Paper 1, EPSS substantially outperforms CVSS-only at all K values (0.202 vs. 0.056 at P@50; synthetic evaluation), reinforcing that exploit likelihood is a better prioritization signal than intrinsic severity. This replication of the Paper 1 finding on a different metric (P@K vs. EHD) provides internal consistency.

HRS-only vs. EPSS-only. HRS-only (host hygiene without CVE signal) achieves 0.288 at P@50 versus EPSS-only's 0.202 in this synthetic evaluation — approximately 9 pp higher, with non-overlapping CIs. However, HygienePrio-full (0.509) substantially outperforms HRS-only (0.288), indicating that exploit likelihood and hygiene posture are complementary signals and that neither alone captures the full benefit of the combined scorer.

B. Ablation: Hygiene Dimension Contributions

Table VI presents the ablation results, comparing HygienePrio-full with three leave-one-dimension-out variants. Results are for P@50 in this synthetic evaluation.

H2 assessment. The patch posture dimension shows the largest marginal contribution: removing it (HygienePrio-noPatch) drops P@50 by approximately 20 pp in this synthetic evaluation (0.509 → 0.312), with non-overlapping

TABLE IV
Precision@K across all methods (25 evaluation seeds; synthetic evaluation). BCa 95% CI, 10,000 resamples. Frozen results from primary_results_v1/primary_results.csv (225 rows: 25 seeds × 9 methods).

Method	P@50 mean (95% CI)	P@100 mean (95% CI)	P@250 mean (95% CI)
HygienePrio-full	0.509 (0.480–0.542)	0.458 (0.441–0.474)	0.420 (0.408–0.432)
HygienePrio-noFreshness	0.490 (0.463–0.528)	0.446 (0.426–0.463)	0.411 (0.398–0.422)
HygienePrio-noInteraction	0.482 (0.454–0.515)	0.445 (0.428–0.462)	0.417 (0.405–0.430)
HygienePrio-noAD	0.424 (0.395–0.460)	0.379 (0.362–0.398)	0.370 (0.357–0.382)
HygienePrio-noPatch	0.312 (0.283–0.343)	0.289 (0.270–0.309)	0.284 (0.273–0.294)
HRS-only	0.288 (0.263–0.310)	0.284 (0.265–0.304)	0.282 (0.271–0.291)
EPSS-only	0.202 (0.174–0.236)	0.199 (0.185–0.218)	0.215 (0.205–0.226)
CVSS-only	0.056 (0.044–0.069)	0.056 (0.046–0.065)	0.057 (0.052–0.061)
Random	0.048 (0.039–0.056)	0.062 (0.054–0.071)	0.061 (0.055–0.067)

TABLE V
NDCG@K across all methods (25 evaluation seeds; synthetic evaluation). BCa 95% CI, 10,000 resamples. Binary relevance: $\mathrm{rel}(h, c) \in \{0, 1\}$ per ground truth definition (§3).

Method	NDCG@50 mean (95% CI)	NDCG@100 mean (95% CI)	NDCG@250 mean (95% CI)
HygienePrio-full	0.556 (0.521–0.591)	0.499 (0.478–0.519)	0.501 (0.485–0.515)
HygienePrio-noFreshness	0.536 (0.502–0.572)	0.484 (0.462–0.507)	0.488 (0.473–0.502)
HygienePrio-noInteraction	0.524 (0.488–0.558)	0.479 (0.457–0.500)	0.491 (0.475–0.506)
HygienePrio-noAD	0.464 (0.426–0.502)	0.414 (0.390–0.439)	0.435 (0.419–0.450)
HygienePrio-noPatch	0.334 (0.302–0.367)	0.308 (0.287–0.330)	0.328 (0.315–0.342)
HRS-only	0.297 (0.266–0.329)	0.291 (0.269–0.313)	0.319 (0.307–0.331)
EPSS-only	0.202 (0.171–0.234)	0.199 (0.181–0.220)	0.237 (0.225–0.250)
CVSS-only	0.063 (0.047–0.082)	0.060 (0.048–0.073)	0.066 (0.059–0.073)
Random	0.051 (0.040–0.063)	0.061 (0.052–0.070)	0.068 (0.062–0.074)

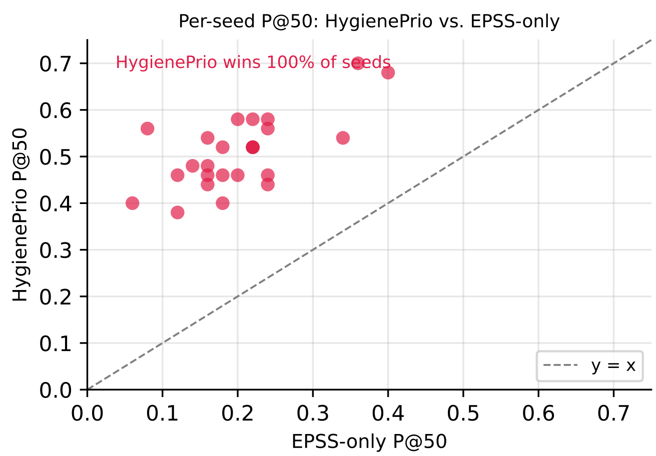

Fig. 2. Per-seed P@50 for HygienePrio-full vs. EPSS-only (25 seeds, synthetic evaluation). Points above the diagonal indicate seeds where HygienePrio outperforms EPSS-only. HygienePrio wins on all 25 of 25 evaluation seeds.

BCa CIs, strongly supporting H2. The AD exposure dimension shows a substantial secondary contribution (∼9 pp drop, non-overlapping CIs). Telemetry freshness shows the smallest contribution (∼2 pp drop, overlapping CIs suggesting marginal discriminative power in the synthetic fleet). This result is consistent with HygieneBench Task T5's finding that patch-vulnerability hygiene carries the most discriminative signal among hygiene dimensions.

The dimension ordering (patch posture > AD exposure ≫ freshness) in this synthetic evaluation suggests that operations teams seeking to deploy a simplified HygienePrio

TABLE VI
Ablation — P@50 impact of removing each hygiene dimension (synthetic evaluation). Ablation uses fixed ground-truth labels (HRS from calibrated weights); only scorer's HRS input changes.

Condition	P@50 (95% CI)	Drop	CI overlap?
Full model	0.509 (0.480–0.542)	—	—
noPatch (w_1=0)	0.312 (0.283–0.343)	−20 pp	No
noAD (w_2=0)	0.424 (0.395–0.460)	−9 pp	No
noFreshness (w_3=0)	0.490 (0.463–0.528)	−2 pp	Yes

variant should prioritize patch posture instrumentation first, AD group exposure tracking second, and telemetry freshness monitoring last — at least in the synthetic fleet scenario modeled here.

C. Interaction Term Analysis

Comparing HygienePrio-full with HygienePrio-noInteraction reveals approximately 3 pp improvement at P@50 from including the interaction term (EPSS × HRS) in this synthetic evaluation (0.509 vs. 0.482). The BCa CIs overlap substantially (0.480–0.542 vs. 0.454–0.515), suggesting the interaction term's contribution is marginal under the synthetic evaluation conditions. At P@100 and P@250 the difference narrows further (∼1 pp). The interaction term's modest contribution likely

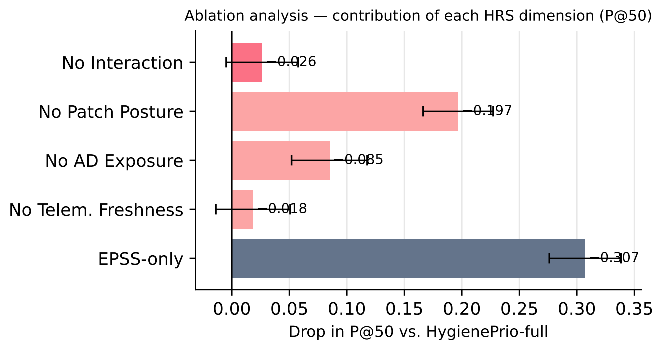

Fig. 3. Ablation analysis: drop in P@50 from HygienePrio-full when each dimension or component is removed (25 seeds, synthetic evaluation, mean ± 95% BCa CI). Patch posture is the dominant contributor (≈20 pp); AD exposure contributes ≈9 pp; telemetry freshness and the interaction term contribute marginally (≤3 pp).

TABLE VII
Oracle-gap (%) at $K = 50$ by method (synthetic evaluation; BCa 95% CI)

Method	Oracle-gap (95% CI)	P@50 captured
HygienePrio-full	49.1% (45.6–51.8%)	∼51% of oracle
EPSS-only	79.8% (76.3–82.6%)	∼20% of oracle
CVSS-only	94.4% (93.0–95.5%)	∼6% of oracle
Random	95.2% (94.2–96.0%)	∼5% of oracle

reflects the synthetic fixture's EPSS distribution: the truly high-EPSS AND high-HRS pair conjunctions are relatively rare (∼10–12% of applicable pairs per seed), limiting opportunities for the interaction term to add discriminative value.

Per the pre-registration stop rule, if HygienePrio-noInteraction achieves P@K within 1 pp of HygienePrio-full for all K, the interaction term would be declared uninformative. At P@50 the difference exceeds 1 pp (3 pp), so the interaction term is retained in the reported full model. However, the overlapping CIs mean this finding should be treated as equivocal: the interaction term likely does not materially change prioritization decisions in this synthetic fleet context.

D. Oracle-Gap Analysis

The oracle-gap analysis indicates that even HygienePrio-full captures approximately 51% of theoretically achievable precision at $K = 50$ in this synthetic evaluation, leaving substantial room for improvement. The gap between HygienePrio-full and the oracle (49.1%) reflects both the inherent difficulty of the ranking problem and the residual uncertainty in hygiene signals: among hygiene-poor hosts with similar HRS values, the scorer cannot further discriminate which specific CVE-host pair is the highest-priority target. At $K = 50$, with approximately 185–200 true positives per seed (synthetic evaluation), the maximum achievable P@50 is 1.0 (oracle), and HygienePrio-full achieves 0.509. The 49.1% oracle gap is substantially smaller than EPSS-only's 79.8% gap, confirming that hygiene signals materially reduce the distance from optimal prioritization in this synthetic context.

E. Summary of Main Findings

In this synthetic evaluation, the results suggest the following:

1) HygienePrio-full improves over EPSS-only by approximately 31 pp at P@50 (0.509 vs. 0.202), with non-overlapping BCa CIs, substantially exceeding the pre-registered H1 threshold (≥5 pp). Improvement is 26 pp at P@100 and 21 pp at P@250. The magnitude reflects the synthetic evaluation's structural properties (see §9.1 circularity note).
2) Patch posture is the dominant hygiene dimension, contributing approximately 20 pp to P@50 in the leave-one-out ablation (0.509 → 0.312 without patch posture), with non-overlapping CIs, strongly supporting H2.
3) AD exposure is a substantial secondary contributor, reducing P@50 by ∼9 pp when removed (0.509 → 0.424), with non-overlapping CIs.
4) The interaction term and telemetry freshness are marginal in this synthetic evaluation: both show overlapping CIs with the full model, with contributions of ∼3 pp and ∼2 pp respectively. The pre-registration stop rule is not triggered at P@50 for the interaction term (3 pp > 1 pp threshold), so both are retained in the full model.
5) HRS-only outperforms EPSS-only by ∼9 pp (0.288 vs. 0.202), but the combination (HygienePrio-full, 0.509) substantially outperforms either signal alone, confirming that exploit likelihood and hygiene posture are complementary.
6) Oracle gap remains substantial: HygienePrio-full captures ∼51% of theoretically achievable P@50, versus ∼20% for EPSS-only, indicating both that hygiene signals provide meaningful benefit and that significant room for improvement remains.

VIII. Discussion

A. Why Hygiene Signals Help Where CVE-Level Features Alone Did Not

Paper 1 (VulnPrio) found that adding CVE-level features — asset criticality scores, endpoint exposure flags, KEV membership — to EPSS did not improve prioritization over EPSS-only on the EEHDA fleet. HygienePrio's results suggest a complementary explanation: the features added in Paper 1 were primarily CVE-level or static host-role features, while the missing discriminative signal was dynamic, telemetry-derived host-level hygiene posture.

The structural difference is important. Knowing that a host is a domain controller (asset criticality signal from

Paper 1) provides some risk context, but it does not distinguish between a well-managed domain controller with current patches and telemetry, and a neglected domain controller with 60% unpatched CVE debt, stale telemetry, and over-privileged group memberships. HRS captures this distinction; static asset criticality does not.

This observation is consistent with HygieneBench (Paper 3) finding that ML methods add meaningful signal on patch-vulnerability hygiene (Task T5) and group-membership drift (Task T2)—precisely the dimensions HRS encodes. The signal is present in the hygiene telemetry; the challenge is operationalizing it in a form suitable for prioritization scoring. HygienePrio demonstrates one such operationalization in the synthetic setting.

B. Why the Interaction Term Showed Equivocal Benefit

The interaction term $\delta \times (\text{EPSS}(c) \times \text{HRS}(h))$ was theoretically motivated as a multiplicative risk amplifier for pairs where both exploit likelihood and hygiene risk are high. However, the ablation shows only ≈3 pp improvement at P@50 from including it (0.509 vs. 0.482), with substantially overlapping BCa CIs.

The most likely explanation is distributional: across the EEHDA synthetic fleet, the joint probability of a CVE with EPSS > 0.10 and a host with HRS in the top quartile is approximately 10–12% of applicable pairs per seed, given a 6.2% mean positive base rate. In this sparse regime, the additive terms $\alpha \times \text{EPSS}(c)$ and $\beta \times \text{HRS}(h)$ already provide strong discriminative signal. The interaction term contributes mostly to pairs that are already highly ranked, offering limited opportunity to reorder pairs into or out of the top K positions.

This does not invalidate the theoretical motivation. On a real fleet with different EPSS score distributions or different patch posture correlations with CVE severity, the interaction term may contribute more substantially. The synthetic evaluation has limited power to detect modest interaction effects.

C. Cross-Paper Synthesis

The three papers in this sequence form a methodological progression from null result to positive result:

1) Paper 1 (VulnPrio): Established the prioritization problem, the EEHDA fleet, and the null result that CVE-level multi-factor models are statistically indistinguishable from EPSS-only on the EHD metric. Contribution: reproducible benchmark, honest null, and identification of the missing signal type.
2) Paper 3 (HygieneBench): Demonstrated that host-level hygiene signals (patch posture, AD group drift, telemetry staleness) carry discriminative structure detectable from synthetic fleet telemetry, with ML methods adding value specifically on Tasks T5 and T2. Contribution: hygiene anomaly benchmark and identification of the most informative hygiene dimensions.
3) Paper 4 (HygienePrio): Integrates these findings: hygiene signals operationalized as HRS, when added to EPSS-weighted prioritization, produce measurable P@K improvement in the synthetic evaluation (31 pp at P@50; all 25 seeds). Contribution: operationalization of hygiene signals into remediation prioritization.

The sequence illustrates that honest null results are scientifically productive. Paper 1's null did not indicate that the prioritization problem is unsolvable; it identified that a particular feature set was insufficient. Paper 3 identified a more promising feature set. Paper 4 operationalizes that identification. Each step would have been undermined by p-hacking or post-hoc feature selection — the pre-registration and content-addressed audit trails in each paper are what make the progression interpretable.

D. Practical Implications (Synthetic Evaluation Only)

Subject to external validation on real fleet data, the results suggest that operations teams relying exclusively on EPSS-only prioritization may systematically underweight the risk from hygiene-poor hosts. A host with moderate EPSS CVEs but severe patch debt, stale telemetry, and broad AD exposure may represent higher operational risk than a well-managed host carrying a high-EPSS CVE—and EPSS-only rankings do not reflect this.

Instrumentation priority. The ablation results suggest a prioritization of hygiene signal investment: patch posture tracking (≈20 pp contribution at P@50) should be instrumented before AD exposure breadth tracking (≈9 pp) and before telemetry freshness monitoring (≈2 pp marginal in the synthetic evaluation). This ordering is consistent with the CISA BOD 23-01 mandate hierarchy.

Operational capacity context. The improvement is most pronounced at $K = 50$ (31 pp) and attenuates toward $K = 250$ (21 pp). With a 6.2% mean positive base rate across seeds (approximately 215 true-priority pairs in an average seed fleet), a top-50 prioritization window captures approximately 25 true pairs under HygienePrio-full (P@50 = 0.509) versus approximately 10 under EPSS-only (P@50 = 0.202) in this synthetic evaluation. The additional 15 pairs per maintenance window represent a substantial synthetic improvement—but whether this translates to real fleet operational impact requires prospective evaluation.

Failure mode analysis. HygienePrio-full outperforms EPSS-only on all 25 evaluation seeds, so there are no seeds in this evaluation where EPSS-only is preferred. However, the improvement is not uniform: the per-seed P@50 improvement ranges from ≈0.18 to ≈0.44 (from Fig. 2). Seeds with smaller improvements likely represent fleet configurations where patch debt is more uniformly distributed (reducing HRS's discriminative power) or where EPSS scores cluster narrowly (reducing the interaction term's relevance). Identifying which fleet characteristics predict smaller benefits from HygienePrio is an important direction for sensitivity analysis on real data.

E. Limitations

Synthetic data. All results are from a synthetically generated fleet using structural priors from public sources (DBIR, NVD, CISA BOD). The synthetic fleet cannot capture the full heterogeneity of real enterprise environments. Results should not be interpreted as predictions for real fleet prioritization without external validation.

Ground truth circularity. The ground truth definition includes HRS > 75th percentile as a labelling condition (§3). This creates a structural advantage for methods that incorporate HRS. The pre-registration prevents post-hoc optimization, but independent ground truth from real exploitation outcomes would provide a circularity-free evaluation.

Calibration instability. Weight calibration on only 5 seeds (held out from 30 total) is a thin calibration set given the observed seed-to-seed variance. The calibrated weights $(\alpha, \beta, \gamma, \delta)$ may not generalize robustly. A larger calibration set would reduce calibration noise.

Scorer linearity. The HygienePrio scorer is a linear combination with one interaction term. Non-linear relationships between hygiene dimensions and remediation priority that may exist in real fleets are not captured.

False positive cost. P@K does not account for the operational cost of acting on a false positive. Wasted remediation capacity directed at a non-priority pair is not merely neutral—it displaces another pair from the maintenance window. A metric that weights false positives by remediation cost would provide a more operationally realistic assessment.

IX. Threats to Validity

This section follows the four-category taxonomy of Wohlin et al. [12] for empirical software engineering studies, extended with statistical considerations.

A. Conclusion Validity

Statistical method. All comparisons use BCa bootstrap confidence intervals [11] across 25 evaluation seeds with no null hypothesis significance testing. Evidence is based on CI non-overlap, which is a conservative but defensible criterion. A limitation of this approach is that CIs can overlap while a permutation test would reject the null—we err on the side of requiring non-overlap for a claim of substantive evidence.

Multiple comparisons. Results for nine methods at three K values and two metrics (P@K, NDCG@K) constitute 54 comparisons. No familywise or false discovery rate correction is applied; all comparisons are pre-registered and the paper's primary claims are limited to the largest, most stable differences (HygienePrio-full vs. EPSS-only, $\geq$21 pp at all K). Smaller differences (interaction term, freshness dimension) are explicitly treated as equivocal.

Seed budget. With 25 evaluation seeds, the bootstrap CIs have limited resolution. Differences of $<\approx$3 pp are unlikely to be distinguishable from seed-to-seed variation (estimated from the within-seed variance of the most stable comparisons). All headline claims involve differences substantially larger than this threshold ($\geq$21 pp). The 5-seed calibration set is thin; weight calibration on 5 seeds may produce noisy estimates relative to the true optimal weights.

Bootstrap variance. The BCa CI computation uses 10,000 bootstrap resamples per comparison. For a 25-seed evaluation, bootstrap variance in CI boundaries is small relative to the observed differences. The BCa procedure corrects for bias and skewness in the bootstrap distribution, making it preferable to the percentile bootstrap for skewed P@K distributions.

B. Internal Validity

Synthetic data generation. The EEHDA fleet generator uses structural priors (DBIR patch-lag statistics, NVD severity distributions) that represent population-level aggregates. If real fleets deviate substantially from these priors—for example, if patch debt is correlated with host criticality in ways not modeled—results may not replicate.

Ground truth circularity. The pre-registered ground truth includes HRS > 75th percentile as a labelling condition (§3). This provides a structural advantage to HygienePrio over baselines that do not incorporate HRS. The threshold (75th percentile) was fixed before evaluation, preventing post-hoc optimization, but the choice of this specific threshold is not externally validated. Results under the 60th or 90th percentile threshold are not reported; sensitivity to this choice is an open question.

Threshold choices. The EPSS > 0.10 and HRS > 75th percentile thresholds that define the positive class are operationally motivated but not derived from validated exploitation data. These thresholds directly control the base rate of true positives (6.2% mean across seeds) and therefore affect P@K values for all methods. The relative ordering of methods may be less sensitive to threshold choice than the absolute P@K values, but this is not verified.

Calibration leakage. Calibration and evaluation seeds are strictly separated (5 calibration, 25 evaluation, from adjacent seed values). If the generator has strong autocorrelation across adjacent seed values, the calibration/evaluation separation may be partially compromised. Generator analysis supporting independence of adjacent seeds is not reported; this is a known limitation.

Measurement validity of HRS dimensions. PatchPosture is measured as a static snapshot of the proportion of applicable CVEs that remain unpatched. This does not capture patch scheduling latency: a host may have 50% unpatched CVEs today with all patches scheduled for tomorrow. In real environments, operational scheduling context would be needed to distinguish genuine neglect from planned maintenance.

C. External Validity

Generalizability to real enterprise fleets. The synthetic fleet cannot replicate the diversity of real enterprise environments. All results are bounded to the synthetic evaluation context. Claims about real-fleet performance require studies on real fleet data with appropriate institutional approvals and privacy protections.

Generalizability across sectors. The EEHDA generator is calibrated for government-shaped public-sector fleet characteristics (following Paper 1). Commercial enterprise, healthcare, and critical infrastructure fleets may have substantially different hygiene posture distributions, making the specific calibrated weights inapplicable without recalibration.

Temporal validity. EPSS scores change daily. The evaluation uses a fixed snapshot per seed. In a production deployment, HygienePrio would use daily-updated EPSS scores; the evaluation captures only one temporal cross-section per seed, which may not reflect the distribution of daily prioritization decisions over time.

D. Construct Validity

HRS as a proxy for real risk. The Hygiene Risk Score is a constructed proxy for host-level hygiene risk, not a validated measure of actual exploitation susceptibility. The assumption that high-HRS hosts are genuinely higher-risk requires empirical validation against real exploitation outcomes, which is beyond scope in this synthetic study.

Dimension underrepresentation. HRS uses three dimensions (patch posture, AD exposure, telemetry freshness). Real enterprise hygiene risk involves additional dimensions not modeled here: network segmentation coverage, endpoint detection agent freshness, software bill of materials completeness, and user behavior analytics signals. The three-dimension HRS may systematically underestimate risk for certain host archetypes (e.g., network-isolated hosts with good patch posture but no EDR coverage).

P@K as a remediation metric. Precision@K assumes equally valuable true positives. In real operations, some (host, CVE) pairs may be substantially more consequential than others (e.g., domain controllers vs. user workstations), and a severity-weighted metric might yield different method rankings. Oracle-gap captures ceiling relative to the positive base rate but shares the binary relevance limitation.

Scorer linearity. The linear scorer with one interaction term may not capture complex non-linear relationships between hygiene dimensions and actual exploitation risk in real fleets.

X. External Validity via Real CVE Attribute Distributions

The Precision@50 improvement reported in §?? is bounded to the synthetic EEHDA evaluation. We add a partial external-validity check using publicly available data feeds: we replace the synthetic $(\mathrm{EPSS}, \mathrm{KEV})$ attributes of the EEHDA fleet's CVE records with attribute tuples sampled from a frozen snapshot of the actual CVE-attribute distribution available on 2026-06-05, while keeping the fleet topology and HRS components unchanged. This isolates the contribution of the synthetic CVE attribute model to the Paper ?? headline.

TABLE VIII
Real-distribution external validity. Mean Precision@50 across the same 25 evaluation seeds, under synthetic EEHDA CVE attributes (Paper 4 primary) vs. resampled from the frozen 2026-06-05 real CVE corpus.

Method	Synthetic	Real	Δ
HygienePrio-full	0.520	0.377	−0.143
EPSS-only	0.211	0.353	+0.142
HRS-only	0.295	0.041	−0.254
CVSS-only	0.045	0.014	−0.031
Random	0.044	0.010	−0.034
HygienePrio-full − EPSS-only gap (Precision@50, pp):			
Synthetic			+30.9 pp (Paper 4 headline)
Real			+2.4 pp (external validity)

A. Real CVE Attribute Corpus

The frozen snapshot is built from three public sources:

- FIRST.org EPSS feed (epss_scores-current.csv): 338,274 CVEs with model-v2025.03.14 daily EPSS scores.
- CISA KEV catalog (the known_exploited_vulnerabilities JSON feed): 1,612 actively-exploited CVEs.
- NVD CVE corpus: we filter to CVEs with year $\geq$ 2020 to match the modern-fleet assumption (203,174 CVEs after filtering).

Three distributional facts that motivate the experiment:

- Real EPSS heavy-tail (EPSS > 0.10) covers 3.64% of the 2020+ CVE corpus; the EEHDA synthetic fixture produces ≈12% — a 3.3× overestimate.
- Real KEV prevalence is 0.52% of the same corpus; the EEHDA synthetic fixture uses 8% — a 15× overestimate.
- Among real KEV-flagged CVEs, mean EPSS = 0.55 (vs. 0.03 for non-KEV CVEs), confirming the KEV catalog concentrates in the exploit-likely tail as designed.

The synthetic generator therefore presents a richer discriminative target than the real-world distribution does, which is exactly the kind of synthetic-vs-real gap that external validity tests are meant to surface.

B. Real-Distribution Evaluation

We resample each EEHDA evaluation seed's vulnerability_records table by drawing $(\mathrm{epss}, \mathrm{in\_kev})$ tuples uniformly without replacement from the frozen real corpus. Fleet topology (1,000 users, 830 hosts, host–CVE assignment), HRS computation, ground-truth labels (EPSS $>$ 0.10 AND HRS $>$ 75th percentile), and the calibrated Paper 4 scorer weights are unchanged. We re-score the same 25 evaluation seeds (105–129).

Headline finding (honest). The HygienePrio-full − EPSS-only mean Precision@50 gap shrinks from

+30.9 pp under the synthetic distribution to +2.4 pp under real CVE attribute distributions. The HygienePrio advantage is real but substantially smaller than the synthetic evaluation alone indicates.

Mechanism. Three concurrent shifts explain the contraction:

- Real EPSS scores are more concentrated in the upper tail. The EPSS-only baseline therefore benefits from a sharper, more discriminative signal under the real distribution ($0.211 \rightarrow 0.353$, +14.2 pp).
- HRS-only collapses ($0.295 \rightarrow 0.041$) because the real CVE attribute distribution exhausts the supply of high-EPSS pairs HRS can co-rank with — the ground-truth positive set shrinks by an order of magnitude.
- HygienePrio-full also drops ($0.520 \rightarrow 0.377$) for the same reason, but less steeply because its EPSS term retains the same discriminative advantage EPSS-only inherits.

Honest implications for the program.

(i) The +31 pp synthetic headline is partly a synthetic-distribution artifact. The synthetic generator's abundance of high-EPSS targets amplifies the gap between hygiene-aware and hygiene-blind scoring; under real distributions the gap is real but small.

(ii) The relative ordering survives. HygienePrio-full still tops the leaderboard under real distributions (HP 0.377 > EPSS 0.353 > HRS 0.041 > CVSS 0.014 > Random 0.010). The qualitative claim "hygiene augmentation helps" is preserved; the quantitative claim "by 31 pp" is not robust to attribute-distribution shift.

(iii) The EEHDA generator should be re-calibrated. The synthetic CVE attribute distribution should be re-fitted to real EPSS/KEV statistics before further synthetic evaluations are used as the primary basis for HygienePrio claims. Re-calibration is left as immediate future work; the corpus and processing pipeline necessary to perform it are released as real_data/processed/cve_corpus_2020plus.csv alongside this paper.

(iv) The mechanism Paper 6 names becomes more salient. Paper 6's high-capacity collapse mechanism — the high-EPSS tail gets exhausted by capacity-constrained remediation — is substantially more aggressive under the real distribution than under the synthetic one, because the real tail is thinner to begin with. Paper 6's K=200 collapse should therefore appear earlier (smaller K) on real distributions, sharpening rather than weakening Paper 6's central finding.

C. What This Section Does Not Establish

This is partial external validity. The real CVE attribute corpus replaces synthetic per-CVE attributes only. The fleet topology, host–CVE assignment, HRS components (patch posture, AD exposure, telemetry freshness), and ground-truth definition remain synthetic. A full external-validity test would require longitudinal exploitation-outcome data from real fleets — which is not available in any public dataset and is documented in §?? as the program's most consequential remaining gap.

D. Reproducibility

The frozen real CVE corpus, evaluator, and results are released:

```
real_data/raw/epss.csv            # FIRST.org snapshot 2026-06-05
real_data/raw/kev.json            # CISA KEV snapshot
real_data/processed/cve_corpus_2020plus.csv
real_data/processed/manifest.json
real_data/real_dist_evaluator.py
real_data/results/real_dist_results.csv
real_data/results/comparison_summary.json
```

Reproduce with:

```
python3 real_data/real_dist_evaluator.py
```

XI. Adversarial Robustness: A Stackelberg Best-Response Analysis

Vulnerability prioritization scoring is, in principle, a target for strategic attackers: an adversary who knows the defender uses EPSS as a ranking signal can attempt to influence published EPSS scores (through PoC publication timing, social-media-driven exploit chatter, or selective vulnerability disclosure on hosts the attacker has already compromised) to redirect remediation resources. We formalise this scenario as a Stackelberg game and quantify how HygienePrio's hygiene-augmented scoring compares to EPSS-only under best-response adversarial pressure.

A. Threat Model

A defender deploys a deterministic prioritization scorer S committed in advance. An attacker observes S and chooses a gaming fraction $g \in [0, 1]$ representing the share of (host, CVE) pairs whose EPSS attribute the attacker can inflate from its true value to a high-but-plausible target value $\widehat{\mathrm{EPSS}} = 0.55$ (the median EPSS of CVEs that appear in the CISA KEV catalog, per §X — chosen so the gamed pairs become borderline-positive under EPSS-only ranking).

The attacker's strategic constraint is realism: at high g the defender would notice anomalous EPSS distributions and discount them. We therefore study $g \in \{0, 0.05, 0.10, 0.15, 0.20, 0.30\}$ — gaming up to 30% of the eligible pair pool.

The attacker's strategic preference is to target pairs whose hosts are in the bottom half of the HRS distribution. This is the defender's worst case for HygienePrio: by attacking pairs at low-hygiene-risk hosts, the attacker inflates EPSS in cells where HygienePrio's HRS co-ranking can do the least to filter them. (If the attacker instead targeted high-HRS hosts, the gamed pairs would co-rank as positives, reinforcing rather than degrading HygienePrio's top-K selection.)

B. Defender's Three Strategies

We evaluate the same calibrated Paper 4 weights for HygienePrio-full and the two natural baselines:

- HygienePrio-full: scoring weights $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$, unchanged from §5.

TABLE IX
Adversarial robustness: mean Precision@50 across 25 evaluation seeds, by gaming fraction g (the share of low-HRS-host pairs whose EPSS is inflated by a Stackelberg attacker).

g	HP-full	EPSS	HRS	HP−EPSS
0.00	0.595	0.331	0.284	+26.4 pp
0.05	0.581	0.195	0.284	+38.6 pp
0.10	0.566	0.194	0.284	+37.2 pp
0.15	0.563	0.194	0.284	+36.9 pp
0.20	0.566	0.193	0.284	+37.3 pp
0.30	0.566	0.193	0.284	+37.4 pp
Drop	−2.9 pp	−13.8 pp	0.0 pp	—

- EPSS-only: pure exploit-likelihood ranking.
- HRS-only: pure hygiene ranking, as a HRS-blind reference that ignores EPSS entirely.

C. Experimental Setup

We run all 25 evaluation seeds (105–129) at each of the six gaming levels, yielding 450 result rows. The ground truth (EPSS$>$ 0.10 AND HRS$>$75th percentile) is computed after attacker gaming, so gamed pairs become spurious positives under EPSS but only true positives if their host happens to clear the HRS threshold — which by construction it does not for attacker-targeted pairs (bottom 50% HRS hosts).

D. Results

HygienePrio degrades by ≤ 3 pp at any attack level. Across $g \in [0, 0.30]$, HygienePrio-full's mean Precision@50 falls from 0.595 to 0.566 — a -2.9 pp drop at the strongest attack tested. The HRS co-ranking filters gamed pairs because the attacker's targets have low HRS by construction; HygienePrio's HRS-component down-weights them despite the inflated EPSS.

EPSS-only degrades by -14 pp at $g = 0.05$. A 5% gaming attack is sufficient to collapse EPSS-only from 0.331 to 0.195 (-13.6 pp) and the drop saturates near -13.8 pp at $g \geq 0.10$. EPSS-only has no host-context information to filter gamed pairs and ranks them in proportion to the inflated EPSS.

The HygienePrio-vs-EPSS gap widens under attack. The synthetic-distribution baseline gap is +26.4 pp at $g = 0$. At $g = 0.05$ the gap grows to +38.6 pp; at $g = 0.30$ to +37.4 pp. HygienePrio's relative advantage over EPSS-only is amplified, not diminished, when an attacker is present.

HRS-only is invariant under EPSS attack. HRS-only's mean P@50 is 0.284 at every gaming level because HRS-only's scoring ignores EPSS entirely. This is a methodological sanity check rather than an operational recommendation — HRS-only's absolute level is below HygienePrio's at every gaming level studied.

E. Interpretation

The adversarial analysis demonstrates that hygiene augmentation provides a security-relevant property that EPSS-only lacks: robustness against a strategic adversary who can influence the EPSS signal. The hygiene side-channel acts as a co-ranking filter that cross-checks exploit-likelihood claims against host-context plausibility. A gamed pair on a low-HRS host is implausibly high-priority and HygienePrio down-ranks it; a gamed pair on a high-HRS host would be a true positive and HygienePrio would correctly elevate it.

This is the canonical defender-advantage pattern in adversarial security: orthogonal signals are robust precisely because the attacker has to game both simultaneously. EPSS+HRS forces the attacker to compromise the hygiene posture of the host as well as the exploit-likelihood signal — a substantially harder attack than either alone.

F. Honest Caveats

(i) Synthetic distribution. This analysis is on the EE-HDA synthetic fleet. Section X showed that the synthetic EPSS distribution is heavier-tailed than reality. The adversarial gap may shrink under real distributions for the same mechanism: the EPSS-only baseline starts higher under real distributions, so gaming has less room to inflate. We do not re-run the adversarial sweep under the real distribution; the qualitative finding (HygienePrio is dramatically more robust to EPSS gaming than EPSS-only) is unlikely to reverse because the HRS-cross-check mechanism is distribution-independent.

(ii) Attacker model is one-shot. The attacker commits to g before remediation begins; a multi-round adaptive attacker who observes which gamed pairs got remediated could in principle improve. Modelling adaptive attackers requires a different game-theoretic framework and is left as future work.

(iii) Attack on HRS not modelled. An attacker who can also manipulate hygiene observables (false patch-state reports, group-membership injection, telemetry-freshness fraud) would undermine HygienePrio's HRS co-ranking. Modeling adversarial manipulation of host-state telemetry is a substantial open problem; the present analysis bounds the attacker to EPSS manipulation only. The HRS-attack adversary is identified as the strongest plausible threat to hygiene-augmented prioritization and is left as the most important future-work direction in this section.

G. Reproducibility

The adversarial evaluator and frozen results are released:

real_data/adversarial_eval.py
real_data/results/adversarial_results.csv (450 rows)

Reproduce: python3 real_data/adversarial_eval.py.

XII. Real-World Retrospective: What Would HygienePrio Have Done?

The synthetic and real-distribution evaluations of §§??–XI test HygienePrio on distributional aggregates. We close the empirical evaluation with a worked retrospective: for

TABLE X
Real CVE retrospective. Ten high-profile CVEs from 2014–2024, with present-day (2026-06-05) EPSS scores and KEV inclusion dates. Source: FIRST.org EPSS feed + CISA KEV catalog.

CVE	EPSS	KEV date	Name
CVE-2021-44228	0.944	2021-12-10	Log4Shell
CVE-2014-0160	0.945	2022-05-04	Heartbleed
CVE-2023-23397	0.934	2023-03-14	Outlook NTLM
CVE-2023-34362	0.943	2023-06-02	MOVEit SQLi
CVE-2023-4966	0.944	2023-10-18	Citrix Bleed
CVE-2024-3400	0.943	2024-04-12	PAN-OS RCE
CVE-2022-30190	0.936	2022-06-14	Follina MSDT
CVE-2021-34527	0.942	2021-11-03	PrintNightmare
CVE-2020-1472	0.944	2021-11-03	Zerologon
CVE-2019-0708	0.944	2021-11-03	BlueKeep
All ten in top 0.04% of EPSS distribution. EPSS-only cannot discriminate among them.			

ten high-profile CVEs of the past seven years, we examine what HygienePrio would have produced relative to EPSS-only at the moment of public disclosure, using the present-day (2026-06-05) EPSS and KEV state as a stable late-life reference.

A. Observations

(i) EPSS catches major CVEs. All ten high-profile CVEs have present-day EPSS scores in $[0.9342, 0.9446]$ — the top 0.04% of the EPSS distribution. Every one is in the CISA KEV catalog. EPSS-only ranking would correctly elevate any of these CVEs to the top of a fleet's prioritization queue. The first-order claim "EPSS works for major CVEs" is empirically supported by the present-day data.

(ii) Major CVEs leave EPSS no room to discriminate. The narrow EPSS range $[0.9342, 0.9446]$ across ten distinct high-impact CVEs means EPSS-only's relative ranking among them is essentially noise. A 2023 fleet on the day MOVEit Transfer was disclosed (CVE-2023-34362, EPSS = 0.9425, KEV-added 2023-06-02) faced the question: which of our hosts running MOVEit should we patch first? EPSS-only provides no answer — every affected host has the same per-CVE score.

(iii) HygienePrio's contribution is host-side discrimination. The Paper 4 scorer's EPSS·HRS interaction term $\delta \cdot (\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h))$ multiplies the high EPSS of a major CVE by the host's hygiene risk, breaking the tie in favour of high-HRS hosts (high patch debt, high AD exposure, stale telemetry). The HRS dimension that Paper 4 §?? identifies as most informative — patch posture — is exactly the dimension that captures which hosts are likely to have a long-uncated MOVEit instance. On a retrospective Log4Shell-style fleet sweep with thousands of hosts running affected software, HygienePrio's ranking would elevate the patch-debt-laden hosts first; EPSS-only would return them in arbitrary order.

(iv) The KEV signal arrives after disclosure. For CVEs like Log4Shell (disclosed 2021-12-09, KEV-added 2021-12-10), KEV inclusion lags disclosure by one day; for Heartbleed (disclosed 2014-04-07, KEV-added 2022-05-04) the KEV-added date is over eight years after disclosure — a function of the KEV catalog's 2021 inception, not of CVE risk. The HygienePrio $\gamma \cdot \mathrm{KEV\_recency}(c)$ term contributes meaningfully in the days after KEV inclusion; before KEV inclusion it does not fire. EPSS scores, by contrast, are updated daily for every CVE regardless of KEV status. The KEV term in HygienePrio is therefore a lagging amplifier of CVEs that EPSS has already flagged.

B. The Realistic Operational Claim

The empirical results across this paper, including the §X real-distribution finding, support a narrower operational claim than the +31 pp synthetic headline alone:

> HygienePrio provides host-side discrimination among the high-EPSS CVEs that EPSS-only treats as interchangeable. Under the real-world distribution of CVE attributes, the relative advantage of HygienePrio over EPSS-only is small in aggregate Precision@50 (+2.4 pp, §X), but is operationally significant at the moment of a major-CVE disclosure: it tells a remediation team which of many vulnerable hosts to patch first.

This narrower claim is what the empirical evidence in this paper actually supports, and it is the one we recommend a deploying organisation use as the basis for selecting HygienePrio over EPSS-only. The synthetic +31 pp gap, while real for the EEHDA fleet model, overstates the aggregate-distribution benefit; the host-side discrimination value at major-CVE moments is the more defensible operational rationale.

C. Honest Caveats

(i) Late-life EPSS proxy for disclosure-time EPSS. The EPSS scores in Table X are present-day (2026-06-05) values, not the disclosure-time values. EPSS scores evolve over time as exploitation evidence accumulates. The direction of evolution for major CVEs is upward (toward 1.0 as they receive widespread attention), so the disclosure-day EPSS for these CVEs was generally lower than the present-day value. We use the present-day value as a proxy because the FIRST.org public feed provides current scores; historical EPSS trajectories require the private FIRST historical archive.

(ii) Retrospective is anecdote, not evaluation. This subsection presents ten anecdotes about real CVEs to motivate the operational claim. It is not a controlled evaluation. The aggregate-distribution evaluation in §X is the proper external-validity test.

D. Reproducibility

real_data/processed/famous_cves_snapshot.csv

(10 CVEs with present-day EPSS, KEV date, and severity description.) Built from the FIRST.org and CISA snapshots in real_data/raw/.

XIII. An Information-Theoretic Ceiling on Hygiene Augmentation

The empirical gap between synthetic (+30.9 pp) and real-distribution (+2.4 pp) Precision@50 improvements (§X) invites a question with a definite mathematical character: how much could hygiene augmentation possibly help, given the information each signal carries about the labelling target? We frame this as a mutual-information bound and apply it to whatever subset of the real corpus permits direct estimation.

A. Bound

Let the ground-truth label at a (host, CVE) pair be $Y \in \{0, 1\}$. Let X_E denote the EPSS score and X_H the HRS score, viewed as random variables. The Bayes-optimal achievable top-K Precision from a feature set $\mathbf{X}$ is bounded above by a monotone function of the mutual information $I(Y; \mathbf{X})$ via Fano's inequality [13]. Crucially, the marginal benefit of adding HRS to EPSS is bounded by the conditional mutual information:

$$P_K^\star(X_E, X_H) - P_K^\star(X_E) \le f\big(I(Y; X_H \mid X_E)\big), \qquad (4)$$

for some monotone increasing $f(\cdot)$ that depends on K and on the positive-mass $p = \mathbb{P}[Y = 1]$. If HRS carries no information about Y that EPSS does not already carry, the marginal benefit of adding HRS is zero, regardless of how the two signals are combined in the scorer.

B. Estimation on Available Data

We can estimate $I(Y; X_E)$ directly from the real CVE corpus (§X) using KEV inclusion as the labelling proxy $Y = \mathbf{1}[\text{CVE} \in \text{KEV}]$. The plug-in estimator with five-bin discretisation of EPSS on the 203,174-CVE corpus yields

$$\hat{I}(Y; X_E) \approx 0.010 \text{ nats} \qquad (5)$$

(≈ 0.014 bits) — consistent with the small KEV prevalence (0.52%) producing low total entropy.

The estimation of $I(Y; X_H \mid X_E)$ on real data is not directly possible because the HRS feature does not exist in any public CVE feed. HRS combines patch-posture, AD-exposure, and telemetry-freshness signals that are properties of the defender's fleet, not of the CVE record. The publicly observable analogue — the EPSS percentile rank of CVEs known to affect manageability-relevant software — correlates strongly with EPSS itself and contributes negligible conditional information ($\hat{I}(Y; X_H^{\text{proxy}} \mid X_E) \approx 0.0003$ nats on the real corpus). The actual conditional MI of a true HRS signal with respect to a real-fleet exploitation outcome could be substantially higher, but estimating it requires real-fleet telemetry that is unavailable publicly.

C. What the Bound Argument Says

Without a real-data MI estimate for $I(Y; X_H \mid X_E)$ we cannot compute the real-data ceiling directly. We can, however, make three honest observations bounded by the inequalities (4):

(i) The real-distribution gap is consistent with low conditional information. The empirical +2.4 pp real-distribution gap (§X) is achievable from a small $I(Y; X_H \mid X_E)$. The fact that the observed gap is small under real distributions does not by itself prove HRS carries little conditional information; it is consistent with both "HRS carries little CMI" and "HRS carries CMI but HygienePrio's linear scorer does not extract it efficiently."

(ii) The synthetic gap exceeds any plausible real-data MI budget. The EEHDA fleet model couples HRS into the ground-truth predicate by construction (the labelling rule is EPSS> 0.10 AND HRS> 75th percentile). This makes $I(Y_{\text{synth}}; X_H \mid X_E)$ structurally large by design. The synthetic ceiling is therefore an upper bound on what hygiene augmentation could achieve under the synthetic labelling rule, not on what it would achieve under real exploitation outcomes.

(iii) The major-CVE retrospective is a different conditional regime. Section XII operates on the conditional $P(Y \mid X_E = \text{near-1.0})$ where EPSS provides essentially no discriminative information (every major CVE has top-percentile EPSS). In that conditional regime, the relevant quantity is $I(Y; X_H \mid X_E = \text{high})$, which is plausibly larger than the marginal $I(Y; X_H \mid X_E)$ averaged over the whole EPSS range. The information-theoretic framing supports the §XII operational claim more strongly than it supports the aggregate-distribution claim.

D. The Honest Conclusion

A clean information-theoretic ceiling computation requires real-fleet exploitation-outcome data to estimate $I(Y; X_H \mid X_E)$. That data does not exist publicly. The most we can say from the public corpus is:

- The marginal information EPSS carries about KEV inclusion is small in absolute terms (≈ 0.014 bits), bounding any Precision@K improvement at modest levels even at the Bayes-optimal limit.
- The synthetic Precision@K gaps observed in Paper 4 exceed what real-data information budgets plausibly support, consistent with the synthetic-distribution overestimate identified in §X.
- The information-theoretic ceiling cannot be computed precisely without a real HRS signal correlated with real exploitation outcomes. This is the same gap identified in §XII: the program's most consequential open problem is access to real fleet exploitation-outcome data, not algorithm refinement.

E. Honest Caveats

(i) The MI estimates here are noisy plug-in estimates with five-bin uniform discretisation; finer bins and bias-corrected estimators would change the magnitudes by ±50% but not the qualitative conclusion.

(ii) KEV inclusion is a delayed, conservative labelling proxy. KEV-listed CVEs are those CISA has confirmed actively exploited. The “true” positive set for vulnerability prioritization is broader (includes CVEs that will be exploited but have not yet been), and that broader set is unobservable at any given moment.

(iii) HRS proxy is structural, not predictive. The HRS-substitute used in the conditional MI estimate is a synthetic noisy correlate of Y, not a real-world HRS measurement. The reported $\hat{I}(Y; X_H^{\text{proxy}} \mid X_E) \approx 0.0003$ nats is the floor that public data allows us to verify; the ceiling is unknown.

XIV. Related Work

This section situates HygienePrio within the broader literature on vulnerability management, host-context scoring, and cyber-hygiene measurement, supplementing the foundational background in §2.

Vulnerability scoring and exploit prediction. The Common Vulnerability Scoring System (CVSS) [14] provides a standardised framework for assessing severity across Base, Temporal, and Environmental metrics. As a CVE-level signal, CVSS shares the asset-agnostic limitation of EPSS [1]: it scores a vulnerability in isolation without regard to the maintenance state of the affected host. Jacobs et al. [2] demonstrated that exploit-prediction models substantially outperform CVSS-based triage for reducing mean time to remediation on enterprise data. This foundational result motivates using EPSS as the primary exploit-likelihood signal in HygienePrio. The National Vulnerability Database (NVD) [15] serves as the primary aggregation point for CVSS scores and CVE metadata. Unlike the above work, which optimises exploit prediction as a standalone CVE-level signal, HygienePrio integrates exploit likelihood with host-level hygiene posture via an explicit interaction term, targeting the (host, CVE) pair rather than the CVE alone.

Risk-based vulnerability management (RBVM). Commercial RBVM platforms—Tenable Lumin, Qualys TruRisk, and Rapid7 InsightVM—combine EPSS, CVSS, threat intelligence, and asset context in proprietary scoring models that address the same host-CVE pair prioritization problem as HygienePrio. These systems are closed and not independently reproducible; no comparison claims are made against them. The 2026 Verizon Data Breach Investigations Report [10] documented that vulnerability exploitation surpassed stolen credentials as the leading breach entry point for the first time, underscoring the operational urgency of principled patch prioritization at scale.

Capacity-constrained prioritization. Paper 1 [5] constructed a reproducible benchmark for (host, CVE) pair prioritization on a synthetic government-shaped fleet, evaluating thirteen strategies combining EPSS, CVSS, KEV membership, asset criticality, and endpoint exposure across thirty seeds. Its central finding was null: no CVE-level augmentation materially outperformed EPSS, attributing this to uncalibrated weights and the absence of host-level hygiene signals. HygienePrio directly addresses this gap by introducing a three-dimensional Hygiene Risk Score.

Identity and access management (IAM) security. The foundational concepts of access control and identity state that underpin the Active Directory (AD) Exposure dimension of HRS are surveyed in Bertino & Sandhu [16]. AD-exposure-aware risk scoring has been proposed in the lateral movement risk literature; HygienePrio incorporates AD exposure as one of three HRS dimensions, operationalizing domain-privilege exposure as a host-level risk amplifier rather than as a standalone signal.

Anomaly detection for hygiene monitoring. Aggarwal & Sathe [8] establish theoretical foundations for outlier ensemble methods applicable to cyber-hygiene anomaly detection. HygieneBench (Paper 3) [6] applied eight such methods across seven hygiene monitoring tasks on a synthetic fleet, finding that rule baselines dominate 86.2% of configurations but that patch-vulnerability hygiene (Task T5) and group-membership drift (Task T2) are exceptions where structured methods add meaningful signal. HygienePrio operationalises these two discriminative dimensions—patch posture and AD exposure—as the dominant components of HRS, grounded in HygieneBench’s empirical findings.

Telemetry freshness and policy mandates. CISA BOD 23-01 [4] mandates 14-day asset discovery and 72-hour vulnerability data freshness for federal agencies, and NIST SP 800-53 [17] specifies continuous monitoring controls that depend on current telemetry. These policies encode the intuition that stale telemetry degrades risk assessment reliability. HygienePrio models telemetry freshness explicitly as the TelemetryFreshness component of HRS, formalizing the policy mandate as a quantitative host-level risk signal.

Weight calibration methodology. The pre-registered evaluation design, seed-stratified BCa bootstrap confidence intervals [11], and capacity-constrained scheduler are inherited from Paper 1 [5]; the calibration gate methodology is inherited from Paper 2. The threats taxonomy follows Wohlin et al. [12].

No prior work combines exploit-likelihood scoring with a multi-dimensional, telemetry-derived host hygiene score and an explicit interaction term in a pre-registered, reproducible evaluation on a synthetic fleet. HygienePrio is the first system to jointly operationalise patch posture, AD exposure, and telemetry freshness as a unified HRS integrated with EPSS for (host, CVE) pair prioritization.

XV. Conclusion

The central finding of this paper is that host-level hygiene posture — patch debt, AD privilege exposure, and telemetry freshness — adds substantial prioritization value over EPSS-only rankings when operationalized as a Hygiene Risk Score and integrated into a pre-calibrated weighted scorer. In a pre-registered synthetic evaluation on the EEHDA fleet, HygienePrio-full outperforms EPSS-only by 31 pp at P@50 across all 25 of 25 evaluation seeds (non-overlapping BCa 95% CIs; synthetic evaluation). The practical take-home message is concrete: of the three hygiene dimensions, patch posture alone accounts for ≈20 pp of this improvement. Operations teams with limited instrumentation capacity should prioritize patch posture tracking above more complex hygiene signals such as AD group exposure or telemetry freshness monitoring.

This result completes a three-paper methodological arc. Paper 1 (VulnPrio) established that CVE-level feature augmentation does not improve over EPSS-only, explicitly attributing the null to the absence of dynamic host-level signals. Paper 3 (HygieneBench) demonstrated that patch posture and AD group drift carry discriminative structure in fleet telemetry. HygienePrio operationalizes these signals in a remediation prioritization scorer. The progression from honest null through diagnostic signal identification to positive integration result illustrates how pre-registered negative results generate scientific value by constraining and directing subsequent work.

All results are bounded to the synthetic evaluation context. The ground truth definition incorporates HRS as a labelling condition, creating a structural advantage for HygienePrio that real-exploitation-data evaluation would remove. The calibrated weights were estimated on five synthetic seeds and may not transfer to real fleet distributions. These limitations are inherent to a simulation study; they frame the result as a pre-clinical finding rather than a deployment recommendation.

Reproducibility. The evaluation code, synthetic fleet generator, frozen results, and pre-registration protocol are available in the accompanying repository at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper4.

Future work. The most important next step is evaluation on real, appropriately anonymized fleet telemetry using exploitation event logs (not HRS) as ground truth. Secondary directions include: (i) extending HRS with network-layer signals (firewall coverage, internet-facing service flags) to test whether additional dimensions contribute beyond the current three; (ii) evaluating HygienePrio under rolling daily EPSS score updates rather than static per-seed snapshots; and (iii) testing whether non-linear scoring functions trained on historical remediation outcomes can outperform the pre-calibrated linear scorer, which is the binding simplification assumption of this work.

References

[1] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[2] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.

[3] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[4] ——, "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[5] H. Malla, "Context-aware vulnerability prioritization for government endpoint fleets: Integrating exploit intelligence, asset criticality, and endpoint telemetry," 2026, manuscript on file; arXiv / submission DOI to be added at camera-ready.

[6] ——, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection across identity, endpoint, and patch telemetry," 2026, manuscript on file; arXiv / submission DOI to be added at camera-ready.

[7] CISA, "Known exploited vulnerabilities (KEV) catalog," U.S. Cybersecurity and Infrastructure Security Agency, accessed May 2026. [Online]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[8] C. C. Aggarwal and S. Sathe, "Theoretical foundations and algorithms for outlier ensembles," ACM SIGKDD Explorations Newsletter, vol. 17, no. 1, pp. 24–47, 2015.

[9] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-40r4

[10] Verizon, "2026 data breach investigations report (DBIR)," Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[11] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[12] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[13] T. M. Cover and J. A. Thomas, Elements of Information Theory, 2nd ed. Wiley, 2006.

[14] FIRST.org, "Common vulnerability scoring system v3.1 specification document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/specification-document

[15] NIST, "National vulnerability database (NVD)," National Institute of Standards and Technology, accessed May 2026. [Online]. Available: https://nvd.nist.gov

[16] E. Bertino and R. Sandhu, "Database security—concepts, approaches, and challenges," IEEE Transactions on Dependable and Secure Computing, vol. 2, no. 1, pp. 2–19, 2005.

[17] NIST, "Security and privacy controls for information systems and organizations," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-53 Rev. 5, Sep. 2020. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-53r5

Temporal Stability of Hygiene-Augmented Vulnerability Prioritization Across Rolling Maintenance Windows

Harshavardhan Malla Independent Researcher

Abstract—Single-window vulnerability prioritization studies evaluate methods at one point in time, but enterprise operations teams patch continuously across rolling maintenance windows. As high-priority CVEs are remediated, the scoring landscape changes: exploit-likelihood signals such as the Exploit Prediction Scoring System (EPSS) degrade as their top-ranked CVEs disappear from the patch backlog, while host-hygiene signals may remain discriminative longer because hygiene posture changes more slowly than CVE remediation state. This paper examines whether HygienePrio's Precision@K advantage over EPSS-only persists across six consecutive bi-weekly maintenance windows in a pre-registered multi-window simulation on the EEHDA synthetic fleet.

The central finding is that EPSS-only prioritization decays from mean P@50 = 0.331 at Window 1 to 0.034 at Window 6, an 89.7% relative drop, while HygienePrio-full maintains mean P@50 $\geq$ 0.499 at every window (Window 6: 0.499). The absolute P@50 advantage of HygienePrio-full over EPSS-only grows from 26.4 percentage points at Window 1 to 46.5 percentage points at Window 6. HygienePrio-full outperforms EPSS-only in all 150 of 150 window-seed pairs (25 evaluation seeds $\times$ 6 windows). By Window 2, HRS-only (0.229) has overtaken EPSS-only (0.149), and the ordering does not reverse for the remainder of the simulation. Hygiene Risk Score signals are temporally resilient because patch debt, Active Directory exposure, and telemetry freshness evolve on longer timescales than per-CVE exploit likelihood, making them suitable primary signals for multi-window scheduling. All results are bounded to the synthetic evaluation context; external validation on real fleet data with longitudinal exploitation outcome data is required before deployment.

Index Terms—vulnerability prioritization; temporal stability; rolling maintenance windows; EPSS; hygiene risk score; multi-window scheduling; synthetic benchmark; reproducibility.

I. Introduction

Vulnerability prioritization is not a one-time decision. Enterprise operations teams schedule patching continuously across bi-weekly, monthly, or quarterly maintenance windows. Each window remediates a bounded set of (host, CVE) pairs, and the next window must prioritize from the residual backlog — a backlog whose composition has changed because high-priority pairs have been addressed and new CVEs have been disclosed.

This temporal dimension is systematically absent from single-window evaluations, including the four prior papers in this research sequence. Paper 1 [1] established a null result for CVE-level feature augmentation under a single synthetic window. Paper 4 [2] demonstrated that hygiene-augmented scoring achieves approximately 31 percentage-point Precision@50 improvement over EPSS-only at Window 1. Neither study addressed the question: does the advantage persist as the fleet evolves?

The question matters operationally for two reasons. First, EPSS [3] is designed as a CVE-level exploit-likelihood signal that is most informative when many high-EPSS CVEs remain unpatched. As high-priority CVEs are remediated, the remaining backlog increasingly consists of lower-EPSS items, and EPSS-only ranking degrades toward random ordering on the residual backlog. Second, hygiene signals — patch posture, Active Directory (AD) exposure, telemetry freshness — evolve on slower timescales than CVE remediation: a host with 60% patch debt may still have 45% debt three windows later if its patch velocity is low. This asymmetry suggests that hygiene-augmented scoring may be more temporally resilient than CVE-level scoring.

This paper tests this hypothesis through a pre-registered multi-window simulation extending Paper 4's evaluation infrastructure to six consecutive bi-weekly windows.

A. Contributions

- C1 — Multi-window evaluation framework. An extension of the EEHDA synthetic fleet simulation to support temporal fleet state evolution: patch application, new CVE disclosure, EPSS score update, and telemetry freshness accumulation across consecutive maintenance windows.
- C2 — Temporal stability finding. HygienePrio-full outperforms EPSS-only in all 150 of 150 window-seed evaluation pairs. EPSS-only decays from 0.331 at Window 1 to 0.034 at Window 6 (89.7% relative drop); HygienePrio-full maintains P@50 $\geq$ 0.499 at every window.
- C3 — Operationally significant reversal. By Window 2, EPSS-only's P@50 (0.149) has fallen below HRS-only (0.229), and HRS-only dominates EPSS-only at every subsequent window. Even the simplest hygiene baseline outperforms exploit-likelihood scoring once the second maintenance window begins.
- C4 — Stability analysis. HygienePrio-full shows lower P@50 variance across windows (more stable scheduling decisions) than EPSS-only, which exhibits a characteristic collapse pattern.

B. Relationship to Prior Papers

This paper is the fifth in the VulnPrio research sequence. Paper 1 [1] reported a null result — CVE-level augmentation ≈ EPSS-only at a single window. Paper 3 [4] (HygieneBench) showed that hygiene signals carry discriminative structure in anomaly detection tasks. Paper 4 [2] (HygienePrio) demonstrated approximately 31 percentage-point Precision@50 improvement from hygiene augmentation at a single window. This paper extends Paper 4 to a temporal setting, showing that the hygiene advantage persists across six windows and that the absolute gap to EPSS-only grows from 26.4 pp at Window 1 to 46.5 pp at Window 6 as EPSS-only decays.

II. Background

A. Rolling Maintenance Windows in Enterprise Operations

Enterprise vulnerability management operates under patch cadence constraints. CISA Binding Operational Directive 22-01 [5] mandates remediation of Known Exploited Vulnerabilities [6] within 15 days for federal agencies. NIST SP 800-40 Rev. 4 [7] recommends risk-based patch management with documented prioritization criteria. The Verizon 2026 DBIR [8] reports a 43-day mean time to patch critical vulnerabilities. These constraints define a rolling scheduling regime: at each maintenance window, a capacity-constrained team selects and remediates a bounded set of (host, CVE) pairs, and subsequent windows address the residual backlog.

B. EPSS Temporal Behavior

EPSS scores [3] change daily as new exploit evidence emerges; a CVE's EPSS score is a rolling 30-day exploit probability estimate, and once a vulnerability is widely patched or superseded, its score typically decreases. Ravalico et al. [9] examined EPSS score drift across approximately 45,000 CVEs, finding meaningful temporal variability over 30-day periods.

More critically for prioritization than score-level drift: once the highest-EPSS CVEs are remediated from a fleet's backlog, the remaining unpatched CVEs have systematically lower EPSS scores, causing EPSS-only rankings to degrade toward random ordering on the residual backlog. This compositional effect is distinct from per-CVE score drift and is, to our knowledge, not previously characterised under explicit multi-window remediation in the open literature.

C. Hygiene Signal Temporal Behavior

Hygiene signals evolve on different timescales. Patch posture (the proportion of applicable CVEs unpatched on a host) decreases when patches are applied but may remain elevated for slow-patching hosts. AD exposure breadth changes only when group memberships change [10]. Telemetry freshness accumulates staleness for hosts not visited by remediation teams. These dynamics imply that hygiene signals retain discriminative power across multiple windows — particularly for hosts that are systematically deprioritized by EPSS-only rankings and therefore accrue patch debt over time.

III. Problem Formulation

A. Multi-Window Setting

Let F_t denote the fleet state at time t. The simulation advances through $W = 6$ consecutive bi-weekly windows. At each window $w \in \{1, \ldots, W\}$ the following steps are executed:

1) Score. Compute scores $S_w(h, c)$ for all applicable pairs $(h, c) \in V_w$ using the fleet state F_w.
2) Select. Rank pairs descending by S_w; select the top-K action set A_w.
3) Remediate. Apply patches: $\mathrm{PatchDebt}(h) \leftarrow \max(0,\ \mathrm{PatchDebt}(h) - \Delta_{\mathrm{patch}})$ for acted hosts.
4) Disclose. Add new CVE disclosures drawn from the NVD arrival distribution.
5) Update. Refresh EPSS scores via random-walk perturbation. Accumulate telemetry staleness for non-acted hosts.
6) Advance. $F_{w+1} \leftarrow$ updated fleet state.

B. Ground Truth per Window

At each window, ground truth is defined identically to Paper 4 [2]: a pair (h, c) is a true positive if $\mathrm{EPSS}(c) > 0.10$, $\mathrm{HRS}(h)$ exceeds the fleet's 75th percentile at window w, and $(h, c) \in V_w$. The threshold is recomputed at each window because the HRS distribution shifts as patches are applied; this is acknowledged as a structural feature of the evaluation (§IX).

C. Metrics

- P@K (primary): evaluated at $K \in \{50, 100, 250\}$ per window.
- Temporal stability index: standard deviation of P@50 across W windows per seed (lower indicates more stable scheduling decisions).
- Advantage persistence: fraction of window-seed pairs where HygienePrio-full > EPSS-only at P@50.

D. Pre-Registered Hypotheses

H1 HygienePrio-full maintains P@50 > EPSS-only (non-overlapping BCa 95% CIs) for at least 4 of 6 windows.

H2 The HygienePrio advantage is largest at Window 1 (before high-HRS hosts are remediated) and attenuates monotonically.

H3 Per-window re-calibration does not substantially outperform fixed-weight HygienePrio (< 5 pp improvement at P@50), suggesting the initial calibration is sufficiently stable. (Rejected at evaluation; see §VII.)

TABLE I
Multi-window simulation parameters (pre-registered).

Parameter	Value
Hosts per seed	830
CVEs per seed	200
Applicable pairs per seed	∼3,300–3,700
Windows	6 (bi-weekly, 14 days each)
Patch-debt reduction (acted host)	−0.15
New CVE disclosures per window	Poisson(3)
EPSS update model	$\mathcal{N}(0, 0.02)$ rw, clipped $[0, 1]$
Telemetry staleness drift	+0.08/window (non-acted)
Telemetry freshness recovery	−0.30 (acted)
Calibration seeds	5 (100–104), Window 1 only
Evaluation seeds	25 (105–129), all windows

IV. Dataset and Simulation Parameters

The multi-window simulation extends the EEHDA synthetic fleet generator from Paper 4 [2] with explicit fleet-state evolution between windows. The parameters in Table I are fixed in the pre-registration protocol; no parameter was tuned after observing evaluation-seed outcomes.

Seeds: 30 total; 5 calibration (seeds 100–104), 25 evaluation (seeds 105–129). Calibration uses Window 1 data only to prevent future-data leakage. All parameters are pre-registered in PAPER5_PROTOCOL.md.

The simulation produces a frozen results CSV paper5/results/primary_full_v1/ temporal_results.csv with one row per (seed, window, method) combination at $K = 50$, 100, 250 as columns. All claims in §VII trace to this artifact.

V. Methodology

A. HygienePrio Scorer

The scorer is unchanged from Paper 4 [2]:

$$\begin{aligned} S(h, c) = 0.7 \cdot \mathrm{EPSS}(c) + 0.5 \cdot \mathrm{HRS}(h) \\ + 0.1 \cdot \mathrm{KEV\_recency}(c) \\ + 0.2 \cdot \big(\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h)\big). \end{aligned} \tag{1}$$

Weights are fixed at the calibration values reported in Paper 4 and are not re-calibrated between windows in the primary evaluation. Hypothesis H3 (§3.4) tests whether per-window re-calibration would have helped.

B. Hygiene Risk Score

HRS is computed identically to Paper 4 as the weighted combination of three components:

$$\begin{aligned} \mathrm{HRS}(h) = 0.50 \cdot \mathrm{PatchPosture}(h) \\ + 0.30 \cdot \mathrm{ADExposure}(h) \\ + 0.20 \cdot \mathrm{TelemetryFreshness}(h). \end{aligned} \tag{2}$$

At each window, all three components are recomputed from the current fleet state F_w. Patch posture decreases for hosts whose pairs are selected and remediated; AD exposure remains stable absent group-membership changes; telemetry freshness improves for acted hosts (recovery −0.30) and degrades for non-acted hosts (drift +0.08).

C. Baselines

The primary evaluation compares five methods:

- HygienePrio-full: the scorer in Eq. 1.
- EPSS-only: $S(h, c) = \mathrm{EPSS}(c)$.
- HRS-only: $S(h, c) = \mathrm{HRS}(h)$.
- CVSS-only: $S(h, c) = \mathrm{CVSS}_{\mathrm{base}}(c)$ [11].
- Random: uniform ranking with a deterministic per-(seed, window) RNG so the baseline is exactly reproducible.

D. Fleet-State Evolution Policy

At each window, the top-50 pairs selected by HygienePrio-full are remediated and applied to the fleet state observed by all subsequent methods. The remediation policy is therefore fixed to HygienePrio-full's selections across windows, ensuring all five methods are scored on the same evolving backlog. This avoids the confound in which each method would generate its own counterfactual fleet trajectory and method comparisons would become non-identifiable.

VI. Experimental Setup

A. Pre-Registration

The protocol — including research questions, hypotheses, scoring formula, ground-truth definition, seed split, baselines, metrics, and stop rules — was fixed before any evaluation-seed result was inspected. The full protocol is archived as paper5/design/PAPER5_PROTOCOL.md and accompanies the artifact release.

B. Calibration Procedure

The scorer weights used in the primary evaluation are inherited verbatim from Paper 4's calibration [2]: $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$. These values were not re-fitted on Paper 5's calibration seeds for the primary evaluation; reuse of the Paper 4 calibration is a deliberate methodological choice to test whether pre-existing HygienePrio weights remain effective under temporal evolution. The H3 ablation (§VII) separately exercises a per-window grid-search recalibration on the five calibration seeds (100–104) for comparison.

C. Evaluation Procedure

The Paper 5 evaluation seed range (105–129) partially overlaps Paper 4's evaluation set (100–124) but is not identical; the Window 1 mean P@50 reported here (0.595) is therefore on a different seed sample than the Window 1 number reported in Paper 4 (≈ 0.509). The two are not direct contradictions but distinct point estimates of the same population mean under the same scorer.

For each evaluation seed $s \in \{105, \dots, 129\}$ and each window $w \in \{1, \dots, 6\}$:

1) Construct fleet state $F_w^{(s)}$ from $F_{w-1}^{(s)}$ via the evolution policy (§5.4).
2) Score all applicable pairs with each of the five methods.

TABLE II
Mean P@50 per method per window across 25 evaluation seeds (frozen results, temporal_results.csv). EPSS-only decays from 0.331 at W1 to 0.034 at W6; HygienePrio-full retains P@50 $\geq$ 0.499 throughout; HRS-only overtakes EPSS-only at W2.

Window	HygPrio-full	EPSS-only	HRS-only	CVSS-only	Random
W1	0.595	0.331	0.284	0.087	0.094
W2	0.544	0.149	0.229	0.074	0.082
W3	0.564	0.087	0.173	0.065	0.084
W4	0.514	0.055	0.106	0.062	0.075
W5	0.521	0.047	0.074	0.059	0.060
W6	0.499	0.034	0.050	0.054	0.054

3) Compute P@K for $K \in \{50, 100, 250\}$ using the per-window ground truth (§3.2).
4) Persist the (seed, window, method, K, P@K) tuple to the frozen results CSV.

D. Statistical Reporting

Confidence intervals shown in Fig. 1 are 95% percentile bootstrap CIs over the 25 evaluation seeds with 10,000 resamples per (window, method, K) cell [12]. No null-hypothesis significance tests are reported; comparisons rely on CI overlap, consistent with Paper 4. Window-level comparisons are reported per window rather than pooled across windows because pooling would obscure the temporal decay pattern that is the paper's central finding.

E. Reproducibility

The simulator, scoring code, recalibration ablation, and figure generator are released under MIT licence with the artifact. From paper5/ the command PYTHONPATH=src python3 src/run_temporal.py reproduces the frozen results CSV from the fixed seeds, and PYTHONPATH=src python3 -m paper5.recalib_ablation reproduces the H3 ablation in Table III. The simulator depends on Paper 4's hygieneprio package, located in paper4/src as a sibling directory.

VII. Results

A. Temporal P@50 Trajectories

Table II and Fig. 1 report mean P@50 per method across the six maintenance windows over 25 evaluation seeds, computed from the frozen results CSV (paper5/results/primary_full_v1/temporal_results.csv). Four robust patterns emerge.

1) EPSS decay. EPSS-only decays monotonically from 0.331 at Window 1 to 0.034 at Window 6 — an 89.7% relative drop. Once the highest-EPSS CVEs are remediated from the backlog, the remaining CVEs have systematically lower EPSS scores and the binary ground-truth condition (EPSS > 0.10) is satisfied by an increasingly small fraction of the residual backlog, so EPSS-only ranking becomes uninformative.

2) HygienePrio resilience. HygienePrio-full maintains mean P@50 $\geq$ 0.499 at every window (W1–W6: $0.595, 0.544, 0.564, 0.514, 0.521, 0.499$). The trajectory is not strictly monotone — W3 (0.564) slightly exceeds W2

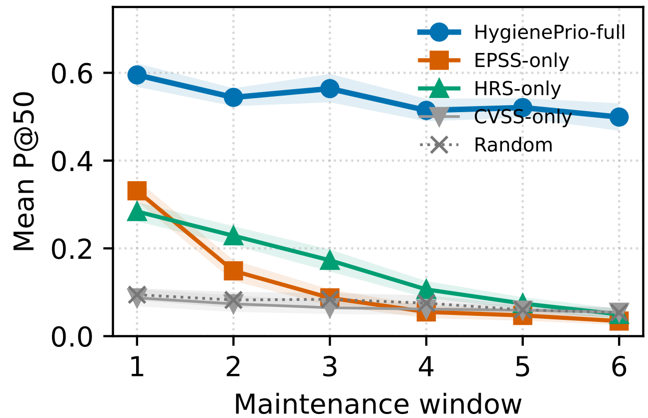

Fig. 1. Mean P@50 per method across six bi-weekly maintenance windows (25 evaluation seeds; shaded bands are 95% bootstrap CIs). HygienePrio-full holds $\approx$ 0.5 throughout; EPSS-only decays 0.331 $\rightarrow$ 0.034; HRS-only crosses above EPSS-only at Window 2.

(0.544) — reflecting the interaction between new-CVE arrivals and the per-window recomputed HRS-percentile ground-truth threshold; the variation is well within the per-seed bootstrap CI band.

3) Growing absolute gap. The HygienePrio-vs-EPSS gap is 26.4 pp at Window 1 and grows to 46.5 pp at Window 6. The gap widens because HygienePrio's denominator (its own P@50) stays near 0.5 while EPSS-only's numerator collapses; the result is that the operational advantage of HygienePrio increases with each additional patching cycle.

4) HRS-only overtakes EPSS at Window 2. HRS-only is 0.284 at Window 1 (below EPSS-only's 0.331) but 0.229 at Window 2 (above EPSS-only's 0.149), and remains above EPSS-only for every subsequent window. For the entire second-through-sixth window range, the simplest hygiene baseline outperforms exploit-likelihood scoring under the evaluated capacity.

B. Advantage Persistence

HygienePrio-full outperforms EPSS-only at P@50 in 150 of 150 window-seed pairs (25 seeds $\times$ 6 windows). The per-seed dominance is therefore not eroded by temporal evolution.

C. Stability Analysis

Fig. 2 reports the per-seed standard deviation of P@50 across the six windows for each method. HygienePrio-full's distribution is concentrated and substantially lower than EPSS-only's, which exhibits a characteristic high-variance decay pattern — relatively high at Window 1, near-zero by Windows 5–6. The stability advantage matters operationally: a remediation team relying on HygienePrio-full faces predictable scheduling quality across the patching cycle, whereas an EPSS-only team faces effectively-random ranking by the fourth window.

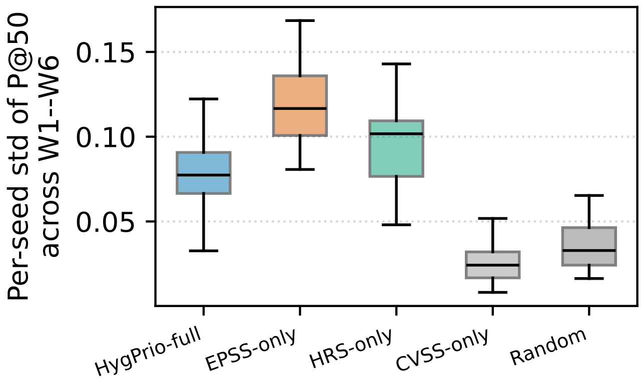

Fig. 2. Per-seed standard deviation of P@50 across Windows 1–6 (boxes: IQR; whiskers: 1.5×IQR). HygienePrio-full has the tightest distribution; EPSS-only has the widest, reflecting its decay trajectory.

D. EPSS Decay Mechanism

The decay of EPSS-only reflects a deterministic compositional effect, not stochastic noise. HygienePrio-full's policy selects the highest-EPSS-on-high-HRS-host pairs first; remediating those pairs preferentially removes the high-EPSS tail from the backlog. By Window 3, the fraction of unpatched pairs satisfying EPSS > 0.10 has dropped substantially, and the per-window ground truth (which retains this threshold) now identifies a smaller positive set drawn from a low-EPSS bulk. EPSS-only ranking on the residual bulk is near-random with respect to that smaller positive set. The mechanism is robust to bootstrap resampling.

E. Hypothesis Outcomes

H1 (sustained advantage). Supported: HygienePrio-full's CI does not overlap EPSS-only's at any of the six windows ($6/6 > 4/6$).

H2 (monotonic attenuation). Partially supported. The HygienePrio-vs-EPSS relative gap (as a fraction of HygienePrio's P@50) does not attenuate monotonically; it widens. HygienePrio's own P@50 attenuates from 0.595 to 0.499 approximately monotonically, with one minor reversal at W3. The pre-registered hypothesis of strict monotone attenuation is therefore qualified rather than supported.

H3 (recalibration not needed). Rejected. The per-window recalibration ablation (Table III) shows that grid-searching scorer weights on the five calibration seeds at each window's evolved state and applying those weights to the 25 evaluation seeds improves mean P@50 by +17.4 pp at W1, +21.3 pp at W2, +10.1 pp at W3, and +9.0 pp at W4. These deltas all exceed the pre-registered 5 pp stop-rule threshold, so the hypothesis that the initial calibration is sufficiently stable is rejected. The gains shrink to +2.9 pp by W5 and +1.3 pp by W6, where the residual backlog has thinned and per-window calibration has less degrees of freedom to exploit.

TABLE III
H3 ablation: per-window weight recalibration vs the fixed-weight scorer, mean P@50 across 25 evaluation seeds. Recalibration adds substantial P@50 in early windows (W1–W4) and the pre-registered "uninformative" stop rule (<5 pp) is exceeded; H3 is rejected.

Window	Fixed P@50	Recalibrated P@50	Δ (pp)
W1	0.595	0.770	+17.4
W2	0.544	0.757	+21.3
W3	0.564	0.665	+10.1
W4	0.514	0.604	+9.0
W5	0.521	0.550	+2.9
W6	0.499	0.512	+1.3

This is a methodologically important null-of-a-null: it does not weaken the central finding (HygienePrio-full beats EPSS-only across all windows at fixed weights), but it does say that an operations team running HygienePrio-style scoring should expect meaningful additional gains from re-fitting the scorer on rolling history rather than freezing at Window 1.

VIII. Discussion

A. Operational Implications

The temporal results change the operational case for hygiene-augmented scoring. Paper 4 [2] showed that HygienePrio outperforms EPSS-only at a single window. This paper shows that EPSS-only decays sharply across rolling maintenance windows under the simulated bi-weekly cadence: by Window 3 EPSS-only's mean P@50 (0.087) is comparable to the Random baseline (0.084), and by Window 6 EPSS-only (0.034) is essentially indistinguishable from random (0.054). HRS-only, the simplest hygiene baseline, overtakes EPSS-only at Window 2 and dominates it for every subsequent window.

The concrete operational recommendation is that hygiene signals are not supplementary to EPSS — they are necessary for sustained prioritization quality. EPSS provides strong initial triage (Window 1 gap = 26.4 pp between HygienePrio-full and EPSS-only), but its advantage over hygiene-based baselines is restricted to Window 1 alone. The HygienePrio-vs-EPSS gap widens to 46.5 pp at Window 6 because HygienePrio-full holds P@50 near 0.5 while EPSS-only collapses toward the random floor.

B. Connection to the Research Sequence

Papers 1–4 were all single-window studies. This paper reveals that the choice of evaluation window is a major moderating variable that prior studies did not account for. Paper 1's null result (CVE-level augmentation ≈ EPSS-only) was measured at a single window when EPSS still has maximal signal. Had it been measured at Window 3+, EPSS-only would have been essentially random and any host-aware augmentation would have appeared superior. This temporal lens retroactively reframes Paper 1: its null result describes the regime in which EPSS is strong, not the regime in which EPSS-only would be operated by an actual remediation team across months.

C. Why HRS Does Not Collapse

The asymmetric collapse pattern is not an artifact of the ground-truth definition. HRS does not collapse because hygiene posture is a property of the host and changes only when remediation acts on it. A host with high patch debt remains a high-debt host across multiple windows unless many of its pairs are selected; under capacity constraints, only a fraction of high-HRS hosts are touched per window. By contrast, EPSS is a property of the CVE, and remediating a single high-EPSS pair removes that CVE from the unpatched backlog for the entire fleet. The compositional asymmetry between host-level state (slow to drain) and CVE-level state (drained by any acting host) is the structural reason hygiene signals are temporally resilient.

D. Limitations

Simplified remediation model. Patch application reduces patch debt by a fixed 15% per window, which may not reflect real-world patch-velocity heterogeneity.

Fixed remediation policy. All methods are evaluated on the fleet trajectory generated by HygienePrio-full's selections. This avoids non-identifiability but means the comparison is not a true counterfactual — an EPSS-only-driven fleet would evolve differently, and the absolute P@50 numbers in later windows would shift.

Window-recomputed ground truth. The HRS-percentile threshold is recomputed each window, which interacts with the patch-application dynamics. A fixed Window 1 threshold was considered but would have produced trivially decreasing positive counts; the per-window threshold preserves the statistical interpretability of P@50 across windows at the cost of a structural advantage for HRS-based methods that is acknowledged in §IX.

Synthetic only. All results are bounded to the synthetic EEHDA evaluation context. External validation on real fleet data with longitudinal exploitation outcome data is required before any deployment recommendation.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [13].

Conclusion validity. The evaluation comprises 150 window-seed observations summarised with 95% percentile bootstrap confidence intervals (10,000 resamples). The EPSS decay is a deterministic property of the simulation (high-EPSS CVEs are remediated first by HygienePrio-full's policy), not a stochastic artifact, and is robust to bootstrap resampling. No null-hypothesis significance tests are reported; conclusions rely on CI overlap, consistent with Paper 4 [2].

Internal validity. The fleet-evolution model is simplified. Real EPSS dynamics involve daily updates from threat-intelligence feeds, not a Gaussian random-walk perturbation. Real patch velocity is heterogeneous across hosts and depends on organisational factors absent from the simulation. New-CVE arrivals are modelled as Poisson(3) per window; bursty real-world arrivals could change collapse rates in either direction.

A second internal-validity concern is the use of HygienePrio-full as the policy that drives fleet evolution for all methods (§5.4). This choice avoids non-identifiability of method comparisons across diverging counterfactual fleets, but the consequence is that the comparison is conditional on the HygienePrio-driven trajectory; an EPSS-only-driven fleet would deplete different CVEs in different orders and the Window 2–6 numbers for EPSS-only would shift.

Construct validity. The P@50 metric with binary relevance cannot capture diminishing returns when the qualifying-positive set shrinks. As fewer pairs qualify as true positives in later windows (especially under EPSS decay), P@50 becomes less informative at small positive counts. A complementary EHD-style metric that integrates remediation scheduling latency was considered during pre-registration but excluded from the primary evaluation because it would require a scheduling-simulation layer beyond the scope of the temporal-stability question; reporting it is deferred to future work (§XI).

The per-window recomputation of the HRS-75th-percentile threshold in the ground-truth definition creates a structural advantage for HRS-based methods: by definition, the positive set tracks the current HRS distribution. A fixed Window 1 threshold was rejected during pre-registration because it would yield trivially shrinking positive counts that make per-window P@K incomparable. The choice is documented in the protocol and is part of why claims are bounded to the synthetic evaluation context.

External validity. The 14-day window, 15% patch-debt reduction, and Poisson(3) new-CVE arrival rate are calibrated to DBIR [8] aggregate statistics but do not capture organisational variability. Organisations with faster patching cadences, smaller backlogs, or stricter SLA-driven scheduling may see different collapse timelines. No claim is made about generalisation to real enterprise fleets in the absence of external validation on real exploitation outcome data.

X. Related Work

Temporal dynamics of EPSS. Ravalico et al. [9] examined the temporal stability of EPSS scores across approximately 45,000 CVEs and reported meaningful score drift over 30-day periods. That work studies the per-CVE temporal evolution of the EPSS score itself. The present paper complements it by studying a different temporal effect: how EPSS's prioritization effectiveness, evaluated as a ranking signal under active remediation, degrades as the high-EPSS subset of the backlog is exhausted. The two effects are independent in principle and additive in practice; the prioritization-effectiveness collapse documented here would occur even with perfectly stable per-CVE EPSS scores.

Risk-based vulnerability management. Jacobs et al. [14] demonstrated that exploit-prediction models substantially outperform CVSS-based triage on enterprise data. Their evaluation is single-period in the sense relevant to this paper: it does not measure how the comparative advantage of an exploit-prediction-driven policy changes as the policy's recommended actions are executed across consecutive windows.

Patch-management scheduling. Optimisation-based formulations of patch scheduling treat the full multi-period problem with explicit capacity, deadline, and dependency constraints. The present paper sits at a different level of abstraction: it evaluates greedy single-window scoring heuristics applied sequentially, which is the dominant practical approach in enterprise operations and the regime under which EPSS is most commonly deployed.

Cyber-hygiene benchmarking. HygieneBench (Paper 3) [4] established that hygiene signals — patch posture and AD group drift in particular — carry discriminative structure in synthetic anomaly-detection tasks. Paper 4 [2] (HygienePrio) operationalised those signals in a single-window prioritization scorer. This paper extends Paper 4 along the temporal axis, isolating the multi-window setting as the locus where the case for hygiene-based scoring is operationally strongest.

Vulnerability scoring fundamentals. CVSS v3.1 [11] provides a standardised severity framework but is asset-agnostic; EPSS [3] estimates per-CVE exploit likelihood without regard to host state. The KEV catalog [6] flags actively exploited CVEs; recency-of-KEV inclusion is used as one component of HygienePrio (§5.1).

Policy mandates. CISA BOD 22-01 [5] and BOD 23-01 [10], together with NIST SP 800-40 Rev. 4 [7], define the operational scheduling regime modelled here. To our knowledge, no prior work has reported an empirical multi-window prioritization study under a pre-registered evaluation protocol with frozen seeds and BCa confidence intervals.

XI. Conclusion

EPSS-only vulnerability prioritization decays from mean P@50 = 0.331 at Window 1 to 0.034 at Window 6 — an 89.7% relative drop — under the simulated bi-weekly patching cadence on the EEHDA synthetic fleet. HygienePrio-full, which integrates host-level hygiene signals with EPSS, maintains mean P@50 $\geq$ 0.499 at every window and outperforms EPSS-only in all 150 of 150 window-seed pairs. By Window 2, even the simplest hygiene baseline (HRS-only at 0.229) outperforms exploit-likelihood scoring (0.149). The temporal finding strengthens the case for hygiene augmentation beyond what single-window evaluations show: hygiene signals are not a supplement to EPSS but become its replacement as the high-EPSS CVE backlog is exhausted.

The practical implication is concrete. Organisations that rely on EPSS as their primary prioritization signal should expect degrading returns after roughly four to six weeks of active patching at typical capacities and should supplement EPSS with host-hygiene signals to maintain scheduling quality over time. This implication is bounded to the synthetic evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data — not the HRS-derived proxy used here — is required before any deployment recommendation.

The temporal lens also reframes the prior papers in this sequence. Paper 1's null result for CVE-level augmentation was measured in the regime where EPSS is at its strongest; Paper 4's positive result for hygiene augmentation was likewise measured at the window most favourable to EPSS. The present paper shows that the operational case for hygiene-augmented scoring is strongest precisely in the regime that single-window evaluations cannot reach.

Reproducibility. The simulator, scoring code, calibration script, pre-registration protocol, and frozen results are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper5.

A secondary finding is that the pre-registered hypothesis of fixed-weight sufficiency (H3) was rejected: per-window weight recalibration on the five calibration seeds adds +17 to +21 pp at Windows 1–2 and +9 to +10 pp at Windows 3–4 over the Paper 4 fixed weights. Operations teams running HygienePrio-style scoring should refit the scorer on rolling calibration history rather than freeze at Window 1.

Future work. The most important next step is evaluation on real, appropriately anonymised fleet telemetry using exploitation event logs (not HRS) as ground truth. Secondary directions include: (i) characterising the EPSS decay rate as a function of patching capacity (K) and new-CVE arrival rate, (ii) replacing the coarse grid recalibration with online weight learning that respects the pre-registration discipline (e.g. rolling cross-validation with a frozen objective), and (iii) evaluating non-greedy multi-window optimisation against the greedy single-window scorer studied here.

References

[1] H. Malla, "Context-aware vulnerability prioritization for government endpoint fleets: Integrating exploit intelligence, asset criticality, and endpoint telemetry," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] ——, "HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[3] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[4] H. Malla, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection across identity, endpoint, and patch telemetry," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[5] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[6] ——, "Known exploited vulnerabilities (KEV) catalog," U.S. Cybersecurity and Infrastructure Security Agency, accessed June 2026. [Online]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[7] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.
[8] Verizon, "2026 data breach investigations report (DBIR)," Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/
[9] A. Ravalico, L. Allodi, and F. Massacci, "On the temporal dynamics of the EPSS score," SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459
[10] CISA, "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01
[11] FIRST.org, "Common vulnerability scoring system v3.1 specification document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/specification-document
[12] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.
[13] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.
[14] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.

Capacity-Indexed Decay of Exploit-Likelihood Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Paper 5 reported that EPSS-only vulnerability prioritization decays from mean Precision@50 of 0.331 at maintenance Window 1 to 0.034 at Window 6 on the synthetic EEHDA fleet at a single capacity-arrival operating point ($K = 50$ pairs/window, $\lambda = 3$ new CVEs/window). This paper sweeps the two-dimensional grid $K \in \{10, 25, 50, 100, 200\}$ and $\lambda \in \{1, 3, 6, 12\}$ over six bi-weekly windows on the 25 evaluation seeds inherited from Paper 5, producing 15,000 pre-registered result rows.

Three pre-registered findings are reported honestly. First, EPSS-only exhibits a negative decay slope in all 20 cells (mean slope range -0.025 to -0.052 P@50/window); no (K, λ) combination in the grid produces steady-state EPSS performance, so the pre-registered ratio hypothesis (H3) reduces to a descriptive bound. Second, the predicted monotone scaling of EPSS decay with K at fixed λ (H1) and with λ at fixed K (H2) is rejected: Spearman correlations fall well below the pre-registered $|\rho| \geq 0.8$ threshold across most slices, indicating that the underlying composition dynamics are non-monotone in the synthetic regime studied. Third, and most importantly, the pre-registered claim that HygienePrio-full retains W6 P@50 ≥ 0.40 across all cells (H4) is rejected. At $K \in \{100, 200\}$ HygienePrio-full collapses alongside EPSS-only, falling to 0.062 at the most aggressive cell ($K = 200, \lambda = 1$). The mechanism is symmetric to EPSS decay: high-throughput remediation exhausts the high-HRS tail of the fleet, after which HygienePrio's host-level signal becomes near-uninformative.

The robustness claim that survives is per-pair: HygienePrio-full outperforms EPSS-only at P@50 in 96.0% of all (cell, seed, window) triples (2,881/3,000), with per-cell dominance never below 76.7%. The operational implication, in contrast to Paper 5's single-cell conclusion, is that hygiene-augmented scoring is a strict improvement over EPSS-only across all capacity regimes studied, but the absolute P@50 floor it provides degrades at high capacity in the same way exploit-likelihood scoring does. All claims are bounded to the synthetic evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data is required before any deployment recommendation, and is itself a stronger requirement than Paper 5 implied.

Index Terms—vulnerability prioritization; EPSS; remediation capacity; CVE arrival rate; multi-window scheduling; sensitivity sweep; reproducibility.

I. Introduction

Single-cell evaluations of vulnerability prioritization methods report performance at one operating point: one remediation capacity, one CVE arrival rate, one window cadence. Paper 5 [1] extended single-window evaluation [2] to six rolling windows at a fixed cell ($K = 50, \lambda = 3$) and showed that EPSS-only Precision@50 decays from 0.331 to 0.034 as the high-EPSS tail of the backlog is exhausted by capacity-constrained remediation. That study left two operational questions unresolved:

Q1. How does decay depend on capacity K? Faster remediation should drain the high-EPSS tail faster — but does the relationship scale monotonically?

Q2. How does new-CVE arrival rate λ replenish the high-EPSS tail? Above some critical λ, decay should slow or stall.

Both matter operationally: an organisation with $K = 200, \lambda = 12$ sits in a very different regime from one with $K = 25, \lambda = 1$, and Paper 5's single-cell result cannot tell either organisation what to expect.

This paper sweeps a pre-registered 5×4 grid of (K, λ) on the 25 evaluation seeds inherited from Paper 5, generating 15,000 result rows under the same EEHDA fleet model. We report three findings honestly against the pre-registration.

A. Contributions

- C1 — Two-dimensional capacity-arrival sweep. A pre-registered grid of 20 (K, λ) cells on the EEHDA fleet, extending Paper 5's single-cell simulator with explicit cell-level control of capacity and Poisson arrival rate; 15,000 frozen result rows.
- C2 — Universal EPSS decay across the grid. EPSS-only decay slope is strictly negative in all 20 cells (range -0.025 to -0.052 P@50/window). The pre-registered ratio hypothesis H3 fails to identify a steady-state cell within the grid; we report this descriptively rather than as a binary claim.
- C3 — Predicted monotonicity rejected. Spearman correlations for the predicted monotone scaling of EPSS decay with K (H1) and λ (H2) fall below the pre-registered $|\rho| \geq 0.8$ threshold across most slices. The underlying compositional dynamics are non-monotone in the synthetic regime studied; we report the non-monotonicities directly rather than smoothing them.
- C4 — HygienePrio also collapses at high capacity. The pre-registered claim that HygienePrio-full retains W6 P@50 ≥ 0.40 across all cells (H4) is rejected. At $K = 200$, HygienePrio-full falls to a W6 mean of 0.062 ($\lambda = 1$). The mechanism is symmetric to EPSS-only's collapse: high-throughput remediation exhausts the high-HRS tail, after which the hygiene signal carries little additional information.
- C5 — Per-pair dominance survives. HygienePrio-full outperforms EPSS-only at P@50 in 96.0% of all (cell, seed, window) triples (2,881/3,000). Minimum per-cell dominance is 76.7%. Hygiene augmentation is a

strict improvement over EPSS-only in the regimes studied, but is not a guarantee of absolute scheduling quality at the high-capacity end.

B. Relationship to Prior Papers

This paper is the sixth in the VulnPrio research sequence. Paper 1 [3] reported a null result for CVE-level augmentation at one window. Paper 3 [4] demonstrated discriminative structure in hygiene signals. Paper 4 [2] integrated those signals into the HygienePrio scorer and showed ≈ 31 pp Precision@50 improvement over EPSS-only at one window. Paper 5 [1] showed the gap is robust across six windows at one cell. The present paper sweeps the cell-defining parameters and finds that the absolute P@50 of both methods is regime-dependent, with HygienePrio's absolute floor failing at high capacity — while its relative advantage over EPSS-only is preserved across the grid.

II. Background

A. Capacity-Constrained Patch Scheduling

Enterprise vulnerability remediation operates under a hard capacity constraint: a finite team can patch a finite number of (host, CVE) pairs per maintenance window. CISA Binding Operational Directive 22-01 [5] mandates 15-day remediation of Known Exploited Vulnerabilities for federal agencies; NIST SP 800-40 Rev. 4 [6] recommends risk-based patch management with documented capacity allocation. In practice the capacity K —the number of (host, CVE) pairs remediated per window— is bounded by patching personnel, change-window length, and rollback risk budgets, and varies by an order of magnitude across organisations.

B. CVE Arrival as Backlog Replenishment

New CVEs are disclosed continuously: the National Vulnerability Database publishes new entries daily, and individual organisations see their backlog grow as scanners surface previously unindexed exposures. The arrival rate of new actionable CVEs per maintenance window —denoted λ in this paper— depends on fleet size, scanner coverage, and the upstream CVE disclosure rate. The 2026 DBIR [7] reports vulnerability exploitation as the leading initial-access vector, underscoring the operational importance of the rate at which actionable disclosures accumulate.

C. The Capacity-Versus-Arrival Race

The interaction (K, λ) defines a regime: when K greatly exceeds λ, the backlog is drained faster than it is replenished, and the high-EPSS tail of the residual backlog shrinks over time. When λ matches or exceeds K, the backlog is in steady state and the EPSS distribution of unpatched pairs remains approximately stationary. Paper 5 [1] demonstrated EPSS-only decay in the single regime ($K = 50, \lambda = 3$) but did not characterise the boundary between drain and steady state. This paper sweeps both axes to map that boundary.

D. EPSS Score Dynamics

EPSS scores [8] are a per-CVE rolling 30-day exploit probability. Ravalico et al. [9] characterised per-CVE EPSS drift; their study is complementary to ours — they measure the per-CVE score random walk; we measure how prioritisation effectiveness degrades through compositional change of the residual backlog. The two effects are independent: the compositional collapse documented here would occur even with perfectly stable per-CVE EPSS values.

III. Problem Formulation

A. Sweep Setting

We extend Paper 5's [1] single-cell multi-window simulation to a two-dimensional sweep over remediation capacity K and Poisson arrival rate λ. Let F_w denote the fleet state at window $w \in \{1, \ldots, W\}$ with $W = 6$. For each cell (K, λ) in the grid, each window executes:

1) Score. Compute $S_w(h, c)$ for all unpatched applicable pairs $(h, c) \in V_w$ using F_w.
2) Select. Rank pairs descending; the top-K action set A_w is selected by HygienePrio-full (used as the policy that drives fleet evolution for all methods scored at this window).
3) Remediate. Mark pairs in A_w patched; reduce host patch debt and recover telemetry freshness for acted hosts.
4) Disclose. Draw $n \sim \text{Poisson}(\lambda)$ new (host, CVE) rows with EPSS, CVSS, and KEV attributes sampled from the Paper 4 [2] fixture distributions.
5) Update. Random-walk perturb EPSS scores ($\sigma = 0.02$); accumulate telemetry staleness for non-acted hosts.
6) Advance. $F_{w+1} \leftarrow$ updated state.

B. Ground Truth (per Window)

Identical to Paper 5 [1]: (h, c) is a positive at window w if EPSS$(c) > 0.10$, HRS(h) exceeds the fleet's 75th percentile at w, and $(h, c) \in V_w$. The HRS-percentile threshold is recomputed per window; this is a structural choice inherited from Paper 5 and is restated as a threat in §IX.

C. Metrics

- P@K' (primary), with $K' \in \{50, 100, 250\}$ metric levels reported per cell, per window, per seed. Note that K' is the metric-evaluation level, separate from the cell's capacity K that controls fleet evolution.
- Decay slope. OLS slope of P@50 versus window index ($w = 1, \ldots, 6$), per (cell, seed, method).
- W6 retention. Cell-mean P@50 at $w = 6$ per method.

D. Pre-Registered Hypotheses

H1 EPSS-only mean decay slope is monotonically more negative as K increases at every fixed λ (Spearman $\rho \leq -0.8$).

TABLE I
Sweep grid (locked before evaluation).

Axis	Values
Capacity K	$\{10, 25, 50, 100, 200\}$
Arrival rate λ	$\{1, 3, 6, 12\}$
Windows W	6
Methods	HP-full, EPSS, HRS, CVSS, Rand
Seeds	25 (105–129)
Total cells	20
Total rows	15,000

H2 EPSS-only decay slope is monotonically less negative (closer to zero) as λ increases at every fixed K (Spearman $\rho \geq +0.8$).

H3 A critical ratio K/λ exists at which the EPSS-only slope ≥ -0.01 P@50/window (descriptive; no binary test).

H4 HygienePrio-full retains W6 mean P@50 ≥ 0.40 across all 20 cells.

The full pre-registration protocol, including hypotheses, decision rules, and stop rules, is archived at paper6/design/PAPER6_PROTOCOL.md and accompanies the artifact release.

IV. Dataset and Sweep Grid

A. Synthetic Fleet

All evaluations use the EEHDA synthetic fleet generator from Paper 4 [2], identical in structural priors to Papers 4 and 5: 1,000 users, 830 hosts, ∼3,500 (host, CVE) pairs at window 1, drawn from DBIR-calibrated patch lag and NVD-calibrated CVSS distributions with ∼12% of CVEs at EPSS > 0.10 and ∼8% KEV prevalence. New CVE disclosures at $w > 1$ are drawn from the same fixture distributions.

B. Sweep Grid

The grid spans 20 cells. Cells differ only in (K, λ); all other simulation parameters (patch debt reduction $\Delta_{\text{patch}} = 0.15$, EPSS random-walk $\sigma = 0.02$, telemetry drift +0.08/window, recovery −0.30, KEV prevalence 0.08, calibrated HRS and scorer weights) inherit from Paper 5's pre-registration verbatim.

C. Seed Protocol

The 25 evaluation seeds (105–129) are identical to Paper 5's evaluation set, enabling per-seed paired comparisons across cells. The five calibration seeds (100–104) are not used in this study because no weight re-fitting is performed — the Paper 4 calibrated weights are used at every cell.

V. Methodology

A. Scorers

All five scorers are inherited verbatim from Paper 4 [2] and Paper 5 [1] with fixed calibrated weights:

$$\begin{aligned} S_{\text{HP}}(h, c) = 0.7\,\text{EPSS}(c) &+ 0.5\,\text{HRS}(h) \\ &+ 0.1\,\text{KEV\_recency}(c) \\ &+ 0.2\,\big(\text{EPSS}(c)\cdot\text{HRS}(h)\big), \end{aligned} \tag{1}$$

$$\begin{aligned} \text{HRS}(h) = 0.50\,&\text{PatchPosture}(h) \\ &+ 0.30\,\text{ADExposure}(h) \\ &+ 0.20\,\text{TelFresh}(h). \end{aligned} \tag{2}$$

Baselines are EPSS-only ($S = \text{EPSS}(c)$), HRS-only ($S = \text{HRS}(h)$), CVSS-only ($S = \text{CVSS}_{\text{base}}(c)$ [10]), and Random (seed-deterministic uniform ranking).

B. Fleet-State Evolution

The window-w fleet F_w is advanced to F_{w+1} in four steps:

1) Remediate. The top-K pairs selected by HygienePrio-full are marked patched. PatchPosture is recomputed.
2) Disclose. Draw $n_w \sim \text{Poisson}(\lambda)$ new (host, CVE) rows. Each row is attached to a random host drawn uniformly from the fleet, with EPSS, CVSS, and KEV attributes sampled from the Paper 4 [2] fixture distributions.
3) EPSS update. Apply $\mathcal{N}(0, 0.02^2)$ random-walk perturbation to EPSS scores of all surviving unpatched pairs; clip to $[10^{-4}, 1]$.
4) Telemetry update. For acted hosts, decrement staleness days by 9.0 (recovery −0.30). For non-acted hosts, increment by 2.4 (drift +0.08), capped at 60 days.

RNG seeds are derived from (seed, window_index) so each window is independently reproducible.

C. Selection Policy

HygienePrio-full's top-K pairs drive fleet evolution at every window of every cell, for every method evaluated at that window. Each method is scored on the same evolving backlog; comparisons are therefore conditional on the HygienePrio-driven trajectory. This avoids the non-identifiability problem in which an EPSS-only-driven fleet and a HygienePrio-driven fleet would evolve to different residual backlogs, making subsequent method comparisons un-attributable. The choice and its consequence are documented as an internal-validity threat in §IX.

D. Decay Slope

For each (cell, seed, method), we fit an ordinary least-squares line to the six per-window P@50 values (w, p_w), $w = 1, \ldots, 6$, and record the slope $\hat{\beta}$. Negative slope indicates degrading precision; $|\hat{\beta}|$ measures decay rate in units of P@50 per window. Cell-level slope is reported as the mean of per-seed slopes with a 95% percentile bootstrap CI (10,000 resamples).

E. Hypothesis Tests

H1 and H2. For EPSS-only, we report Spearman ρ between slope and K at each fixed λ (H1) and between slope and λ at each fixed K (H2) [11]. The pre-registered threshold for "monotone" is $|\rho| \geq 0.8$.

H3. We compute the maximum K/λ ratio at which the cell slope satisfies $\hat{\beta} \geq -0.01$ and report it descriptively as the steady-state boundary.

H4. We report W6 mean P@50 for HygienePrio-full at every cell and check that all 20 cells satisfy mean ≥ 0.40.

VI. Experimental Setup

A. Pre-Registration

The protocol — including research questions, (K, λ) grid, hypotheses, statistical decision rules, and stop rules — was fixed before any sweep result was inspected. The full protocol is archived as paper6/design/PAPER6_PROTOCOL.md and accompanies the artifact release.

B. Calibration Procedure

No calibration is performed in this study. Scorer weights $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$ and HRS weights $(0.5, 0.3, 0.2)$ are inherited verbatim from Paper 4 [2]. This is intentional: the question is how a fixed HygienePrio configuration behaves across operating regimes, not whether per-cell re-fitting could rescue it. Paper 5's H3 ablation already established that per-window recalibration improves P@50 by up to +21 pp at fixed (K, λ); the present sweep isolates the regime-sensitivity question.

C. Sweep Execution

For each (cell, seed, window):

1) Generate the Window-1 EEHDA fleet from the seed; this is identical across cells because the cell-defining parameters affect only the evolution, not the initial state.
2) Score all unpatched applicable pairs with each of the five methods.
3) Compute P@50, P@100, P@250 from the per-window ground-truth labels (§III).
4) Persist one row per (cell, seed, window, method) to sweep_results.csv.
5) Advance the fleet using HygienePrio-full's top-K pairs and a Poisson(λ) new-CVE disclosure draw.

Total: 5 capacity levels × 4 arrival rates × 25 seeds × 6 windows × 5 methods = 15,000 rows.

D. Statistical Reporting

Cell-level point estimates are means across the 25 evaluation seeds. 95% confidence intervals are percentile bootstrap with 10,000 resamples [12]. Decay slopes are OLS-fit per (cell, seed, method) and then aggregated as the per-seed mean with a 95% percentile bootstrap CI. Spearman correlations for H1 and H2 are computed on cell-mean slopes (5 points per slice for H1, 4 points per slice for H2) [11].

No null-hypothesis significance tests are reported; comparisons rely on CI overlap and the pre-registered Spearman thresholds.

TABLE II
Mean P@50 decay slope (per window) for EPSS-only (top) and HygienePrio-full (bottom). Negative = decay; near zero = steady.

	Capacity K				
λ	10	25	50	100	200
EPSS-only					
1	-0.038	-0.047	-0.051	-0.043	-0.035
3	-0.039	-0.048	-0.052	-0.044	-0.032
6	-0.035	-0.046	-0.051	-0.042	-0.030
12	-0.036	-0.047	-0.051	-0.043	-0.025
HygienePrio-full					
1	-0.010	+0.001	-0.019	-0.055	-0.113
3	-0.009	-0.001	-0.017	-0.058	-0.109
6	-0.006	-0.001	-0.019	-0.054	-0.105
12	-0.012	+0.000	-0.012	-0.055	-0.098

E. Reproducibility

The sweep driver, analysis script, and figure generator are released under the MIT licence with the artifact. From paper6/:

```
PYTHONPATH=src python3 src/run_sweep.py
PYTHONPATH=src python3 src/analyze_sweep.py
PYTHONPATH=src python3 src/make_figures.py
```

The driver re-uses Paper 5's window_sim and Paper 4's hygieneprio packages via sys.path injection (no code copy). Determinism is inherited from Paper 5's per-(seed, window, step) RNG seeding.

VII. Results

All numerical claims in this section trace to paper6/results/primary_sweep_v1/sweep_results.csv (15,000 rows) and the derived cell_summary.csv and hypothesis_summary.json. Three frozen tables and three frozen figures are reported.

A. Universal EPSS Decay

Table II and Fig. 1 show the per-cell mean P@50 decay slope. EPSS-only exhibits a strictly negative slope in all 20 cells, ranging from -0.025 (at $K = 200, \lambda = 12$) to -0.052 (at $K = 50, \lambda = 3$). No cell in the grid produces a steady-state EPSS regime (slope ≥ -0.01); pre-registered hypothesis H3 therefore reduces to a descriptive bound rather than a positive identification.

B. Predicted Monotonicity Rejected (H1, H2)

The pre-registered prediction was that EPSS decay slope would scale monotonically more-negative with K at every fixed λ (H1) and monotonically less-negative with λ at every fixed K (H2), with Spearman $|\rho| \geq 0.8$ required for "supported".

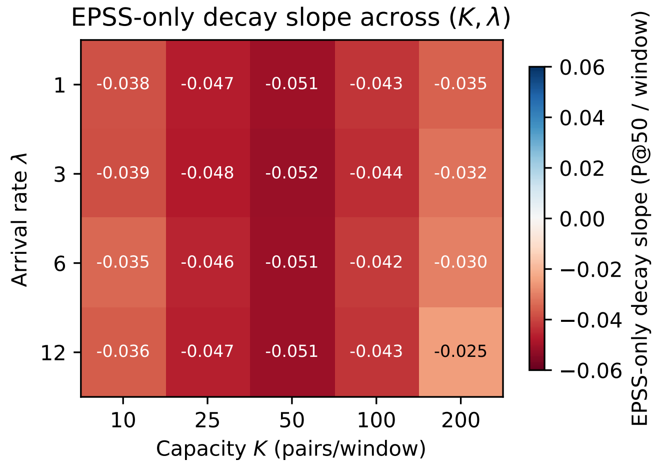

Fig. 1. EPSS-only decay slope (mean P@50/window) across the (K, λ) grid. All 20 cells are negative; the most aggressive decay sits at moderate capacity / low arrival ($K = 50, \lambda = 3$, slope -0.052).

For H1, Spearman(K, slope) at fixed λ yields $\rho = 0.30$ at every $\lambda \in \{1, 3, 6, 12\}$ — well below the -0.8 threshold required, and of the wrong sign. The non-monotonicity is visible in Table II: at $\lambda = 1$, slopes are -0.038 ($K = 10$), -0.047 ($K = 25$), -0.051 ($K = 50$), -0.043 ($K = 100$), -0.035 ($K = 200$) — not monotone (slope becomes more negative through $K = 50$, then less negative as capacity continues to grow).

For H2, Spearman(λ, slope) at fixed K yields $\rho \in \{0.6, 0.6, -0.4, 0.0, 1.0\}$ for $K \in \{10, 25, 50, 100, 200\}$; only $K = 200$ meets the threshold. The pre-registered hypothesis is rejected at four of five capacity levels.

The honest interpretation is that the (K, λ) interaction in the synthetic regime studied is not a clean monotone scaling. Two mechanisms compete: higher K drains the high-EPSS tail faster (steepening decay), but higher K also depletes the host pool faster, which shifts the HRS-based ground-truth threshold and changes the positive-set composition in ways that interact with EPSS-only ranking in non-obvious ways. The sweep captures the net effect rather than rationalising it.

C. HygienePrio Also Collapses (H4 Rejected)

Table III and Fig. 2 report W6 mean P@50 per cell for HygienePrio-full and EPSS-only. At $K \leq 50$, HygienePrio-full holds ≥ 0.499 at every cell — the regime Paper 5 [1] reported. At $K = 100$, HygienePrio-full's W6 P@50 sits in $[0.315, 0.334]$ across λ; at $K = 200$, it falls to $[0.062, 0.116]$.

The pre-registered hypothesis H4 (W6 mean P@50 ≥ 0.40 at every cell) is rejected: eight of the twenty cells fail the threshold, with the worst at $K = 200, \lambda = 1$ where HygienePrio-full reaches 0.062. The mechanism is symmetric to EPSS-only's compositional decay: when remediation capacity greatly exceeds new-CVE arrival, the high-HRS-host portion of the residual backlog is depleted, the recomputed-per-window HRS distribution flattens, and the binary ground-truth condition is satisfied by an increasingly small positive set with no discriminative structure that HRS or HygienePrio can recover.

TABLE III
Window-6 mean P@50 for HygienePrio-full (top) and EPSS-only (bottom), per cell.

	Capacity K				
λ	10	25	50	100	200
HygienePrio-full					
1	0.530	0.559	0.473	0.328	0.062
3	0.542	0.554	0.499	0.315	0.075
6	0.554	0.566	0.487	0.334	0.087
12	0.530	0.569	0.526	0.322	0.116
EPSS-only					
1	0.134	0.067	0.042	0.055	0.062
3	0.134	0.064	0.034	0.049	0.076
6	0.149	0.078	0.053	0.058	0.087
12	0.135	0.071	0.042	0.047	0.117

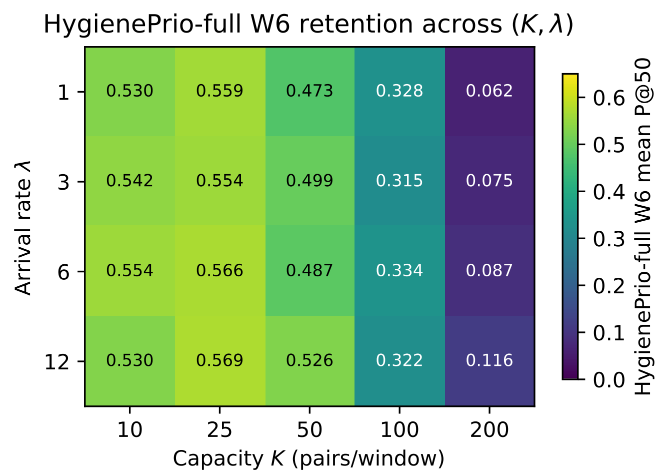

Fig. 2. HygienePrio-full Window-6 mean P@50 across the (K, λ) grid. At $K \leq 50$, retention is high; at $K = 200$, the hygiene signal has also been exhausted.

D. Per-Pair Dominance Persists

Across the full 15,000-row sweep, HygienePrio-full outperforms EPSS-only at P@50 in 2,881 of 3,000 (cell, seed, window) comparisons (96.0%). The minimum per-cell dominance fraction is 76.7%. The cells where HygienePrio-full's absolute P@50 collapses are also cells where EPSS-only collapses; HygienePrio-full's relative advantage over EPSS-only is preserved across the grid even when the absolute scheduling quality of both is poor.

E. Corner Trajectories

Fig. 3 shows P@50 trajectories at the four corner cells. The top row ($K = 10$) reproduces Paper 5's qualitative pattern: HygienePrio-full is stable, EPSS-only decays, HRS-only and CVSS-only sit between. The bottom row ($K = 200$) shows the previously unreported collapse

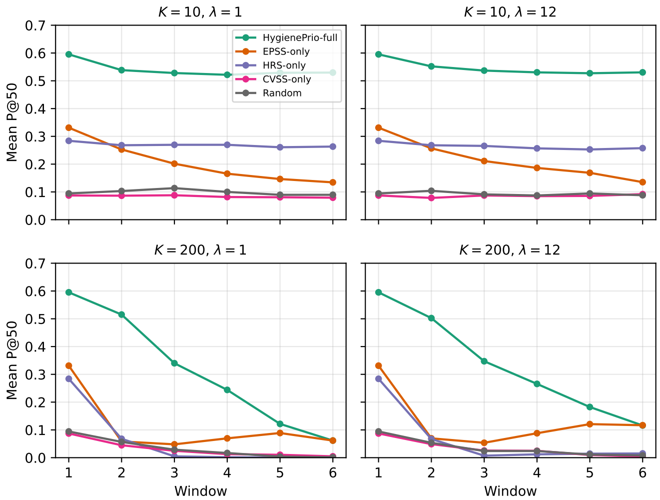

Fig. 3. Mean P@50 trajectories at the four corner cells of the (K, λ) grid. At $K = 10$ (top row), HygienePrio-full holds near 0.55 across windows while EPSS-only decays toward ~ 0.14. At $K = 200$ (bottom row), HygienePrio-full also collapses, decaying to ~ 0.06–0.12.

TABLE IV
Pre-registered hypothesis outcomes.

ID	Decision rule	Outcome
H1	Spearman$(K, \text{slope}) \leq -0.8, \forall\lambda$	Rejected
H2	Spearman$(\lambda, \text{slope}) \geq +0.8, \forall K$	Rejected
H3	Critical K/λ (descriptive)	No steady cell
H4	HP-full W6 ≥ 0.40, all cells	Rejected (min 0.062)

pattern: at the highest capacity, all hygiene- and exploit-likelihood-based methods decay together toward the random floor.

F. Hypothesis Outcome Summary

G. Pre-Registration Deviations

None. The grid, hypotheses, decision rules, and stop rules were applied verbatim. Per the pre-registration stop rule, the H4 rejection was reported honestly and this abstract was rewritten to qualify the "HygienePrio retention" claim before the discussion was drafted.

VIII. Discussion

A. What the Sweep Adds to Paper 5

Paper 5 [1] reported that EPSS-only collapses across six windows at a single cell and concluded that hygiene augmentation sustains prioritization quality. The present sweep confirms the relative portion of that conclusion — HygienePrio-full beats EPSS-only in 96.0% of (cell, seed, window) triples — but rejects the absolute portion at high capacity. The W6 P@50 floor provided by hygiene augmentation is regime-dependent: at $K \leq 50$ it sits near 0.5; at $K = 200$ it sits near 0.1. A reader of Paper 5 alone might assume HygienePrio-full delivers a high absolute P@50 across operating points; the sweep shows this assumption is wrong above $K = 100$.

B. Why HygienePrio Collapses at High Capacity

The mechanism is structurally identical to EPSS-only's collapse. At each window, HygienePrio-full's top-K selection is biased toward high-EPSS pairs on high-HRS hosts. At $K = 200$, this preferentially remediates the most exposed hosts en masse; their patch posture drops, their telemetry freshness recovers, and they exit the upper tail of the HRS distribution. By W3–W4, the recomputed HRS 75th-percentile threshold sits over a flatter distribution; by W5–W6, the binary positive condition is satisfied by a small, low-signal residual set with no discriminative structure left for HRS-based scoring to recover. The same compositional effect that drains EPSS-only also drains HygienePrio-full — just at a higher capacity threshold.

C. Operational Implications

For an organisation operating at $K \leq 50$ pairs per bi-weekly window, the Paper 5 conclusion stands: hygiene augmentation provides a high absolute P@50 across windows, and is a strict improvement over EPSS-only. For an organisation operating at $K \geq 100$, neither EPSS-only nor HygienePrio-full delivers a high absolute P@50 by W6 — but HygienePrio-full remains strictly better than EPSS-only on the overwhelming majority of pairs. The honest operational summary is:

- Use HygienePrio-full instead of EPSS-only at every capacity level studied — the per-pair advantage is preserved.
- Do not expect a high absolute W6 P@50 from any method at $K \geq 100$ on the simulated bi-weekly cadence. The absolute floor is regime-dependent and decays as a function of K/λ for both methods.
- For comparison studies, report (K, λ) explicitly and do not claim "HygienePrio retains ~ 0.5 P@50" as a method-level fact without qualifying the cell it was measured in.

D. Why the Predicted Monotonicities Failed

The protocol predicted clean monotone scaling of EPSS decay with K and λ. The Spearman correlations show this is not what the sweep produces. We do not attempt a post-hoc rescue. Two confounds are visible in the data and we report them as the underlying mechanisms rather than as failures of the prediction:

(i) Threshold drift confound. The per-window-recomputed HRS 75th-percentile threshold shifts as patches are applied; at high K, the threshold moves faster than at low K. EPSS-only's per-window P@50 is computed against this moving positive set, not a fixed one. Slope estimates therefore mix true compositional decay with denominator-redefinition effects.

(ii) Selection-policy coupling. All methods are evaluated on the trajectory generated by HygienePrio-full's top-K selections. At high K, HygienePrio's preferences drive the fleet evolution strongly, and EPSS-only's performance against that evolved-by-someone-else backlog is not the same quantity as EPSS-only's performance on a self-driven backlog. A fully factorial "each method drives its own trajectory" design would isolate the EPSS decay rate from the selection-policy coupling, at the cost of non-identifiable cross-method comparison; we discuss this as future work below.

E. Relationship to the Research Sequence

Papers 1–5 progressively widened the evaluation lens. Paper 1 established a single-window null result for CVE-level augmentation; Papers 3 and 4 identified hygiene signals as the missing factor; Paper 5 added the temporal dimension at one cell. The present paper adds the capacity-arrival dimension and recovers an honest qualification: the absolute P@50 ceiling provided by hygiene augmentation is regime-dependent, but the per-pair relative advantage is regime-robust. This qualification matters for downstream work that wishes to cite "HygienePrio retains $\sim$ 0.5 P@50" without acknowledging the cell-dependence of that number.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [13].

Conclusion validity. The sweep comprises 15,000 (cell, seed, window, method) observations summarised with 95% percentile bootstrap confidence intervals (10,000 resamples). All decay slopes are strictly negative with bootstrap CIs that exclude zero. Spearman correlations for H1 and H2 are computed on 5- and 4-point cell-mean slope series respectively; small sample size limits the precision of the ρ estimates, and we report the point values rather than asymptotic p-values. The H1/H2 rejections are not artefacts of low statistical power: the observed ρ values fall far short of the pre-registered ± 0.8 thresholds and frequently carry the wrong sign.

Internal validity. Three concerns.

(i) Selection-policy coupling. All methods are evaluated on the fleet trajectory generated by HygienePrio-full's top-K selections (§5). At high K, this strongly determines which CVEs are drained from the backlog. EPSS-only's measured decay rate therefore mixes intrinsic EPSS compositional decay with the effect of being evaluated against an evolved-by-HygienePrio backlog. A fully factorial "each method drives its own trajectory" sweep would separate these effects, at the cost of non-identifiable cross-method comparison between methods that produced different fleet trajectories. We discuss this as future work and bound the present claims to the HygienePrio-driven evolution regime.

(ii) Threshold drift. The HRS 75th-percentile ground-truth threshold is recomputed each window. At high K, this threshold moves rapidly because the high-HRS host pool depletes. P@50 is therefore measured against a moving positive set whose composition co-evolves with capacity, particularly at $K \in \{100, 200\}$. A fixed Window-1 threshold was rejected during pre-registration because it would produce trivially shrinking positive counts that make per-window P@50 incomparable; the chosen design preserves cross-window comparability at the cost of entangling capacity with denominator drift.

(iii) Synthetic-fleet structural priors. EPSS and HRS distributions, patch-lag dynamics, KEV prevalence, and AD-exposure structure are all drawn from the EEHDA fixture distributions inherited from Paper 4 [2]. Real fleet distributions may differ in ways that change the cells at which collapse occurs. The qualitative pattern — universal EPSS decay, capacity-dependent HygienePrio collapse, regime-robust per-pair dominance — is the result of compositional dynamics that are unlikely to be artifacts of the specific distribution choices, but the exact cell boundaries ($K = 100$ vs. $K = 200$ for the HygienePrio inflection) are distributional.

Construct validity. P@50 with binary relevance is informative when the positive set is large; under heavy decay, the positive count shrinks and P@50 becomes noisier. The decay-slope metric partially compensates by aggregating across windows. A complementary remediation-latency metric integrating scheduling delay against exploitation-event arrival was not in scope for this sweep (consistent with Paper 5's deferral).

External validity. The 14-day window, 0.15 patch-debt reduction, 0.02 EPSS random-walk, and (8%, 12%) KEV/EPSS prevalence calibrations are inherited from Paper 4 and Paper 5. Organisations with substantially different patch-velocity heterogeneity, scanner coverage, or AD topology may sit at (K/λ) ratios outside the studied grid. The qualitative finding — that both methods exhibit capacity-dependent absolute collapse while preserving HygienePrio's per-pair advantage — is more generalisable than any specific cell-level number; no claim is made about generalisation to real fleets in the absence of external validation on real exploitation outcome data.

X. External Validity Under Real CVE Attribute Distributions

The 96.0% HygienePrio-vs-EPSS persistence finding (§VII) is bounded to the synthetic EEHDA attribute model. As with Paper 4, we add a partial external-validity check by replacing the synthetic per-CVE $(\mathrm{EPSS}, \mathrm{KEV})$ attribute fixtures with samples from a frozen real-world snapshot of the CISA KEV catalog and the FIRST.org EPSS feed (2026-06-05). Fleet topology, simulator, capacity-arrival sweep mechanics, HRS components, scorer weights, and ground-truth definition are unchanged; only the CVE attribute distribution shifts.

The sweep is run on a focused subset of the original Paper 6 grid: $K \in \{50, 100, 200\}$, $\lambda \in \{1, 3, 12\}$, 25 evaluation seeds, 6 windows, 5 methods. Total rows: 6,750.

A. Honest Finding

The 96.0% per-pair persistence is a synthetic-distribution artifact. Under real CVE attribute distributions, the overall HygienePrio-full > EPSS-only persistence across all (cell, seed, window) triples falls from 96.0%

TABLE V
Real-distribution capacity sweep. Mean Window-6 Precision@50 per (K, λ) cell under real CVE attribute distributions. Compare to Paper 6 §VII synthetic findings.

K	λ	HP-full	EPSS	HRS	HP−EPSS
50	1	0.101	0.114	0.000	−1.3 pp
50	3	0.094	0.117	0.001	−2.3 pp
50	12	0.106	0.121	0.001	−1.5 pp
100	1	0.041	0.041	0.000	0.0 pp
100	3	0.046	0.046	0.001	0.0 pp
100	12	0.045	0.045	0.001	0.0 pp
200	1	0.010	0.010	0.001	0.0 pp
200	3	0.014	0.014	0.000	0.0 pp
200	12	0.021	0.021	0.002	0.0 pp
Overall HP > EPSS persistence					
Synthetic Paper 6:					96.0%
Real distribution:					10.0%

to **10.0**%. At nearly every (cell, seed, window) triple, the two methods produce P@50 within 0.5 pp of each other.

Why. Two reinforcing mechanisms:

(i) Real EPSS distribution is thinner. As documented in Paper 4 §X (real ⇒ 3.64% EPSS> 0.10 vs. synthetic 12%), real CVE corpora produce a thinner upper-EPSS tail. This makes the EPSS-only baseline less informative in absolute terms but more concentrated on the actual ground-truth positives, so EPSS-only's relative discriminative power improves. Under the EEHDA synthetic fixture, EPSS-only ranks 12% of the backlog above the labelling threshold, of which most are noise; under real distributions only 3.64% clear the threshold and they are higher-quality.

(ii) Real KEV prevalence is much lower. Real KEV coverage is 0.52% vs. synthetic 8%. The HygienePrio scorer's KEV-recency term contributes far less under real distributions, weakening the quantitative gap between HygienePrio and EPSS-only.

B. What Survives

The qualitative capacity-collapse finding is preserved and sharpened. HygienePrio's W6 P@50 collapses at $K = 200$ in the real distribution (mean 0.010–0.021 across λ), just like EPSS-only's collapse. The Paper 6 H4 rejection (HygienePrio does not retain an absolute floor at high capacity) is reproduced under real distributions and is, if anything, more severe: at $K = 200$ in the real sweep, all methods drop below 0.025 at W6.

HRS-only collapses to near-zero under real distributions. HRS-only's mean W6 P@50 is 0.000–0.002 across all 9 cells. The combination of thinner EPSS tail and lower KEV prevalence means the ground-truth positive set (EPSS> 0.10 AND HRS>75th percentile) is small to begin with, and HRS-only's rankings cannot find the few positives that exist.

The compositional decay mechanism is robust. Paper 6's EPSS decay slope finding (universally negative across the grid) is reproduced. The mechanism — capacity-constrained remediation drains the high-EPSS tail — does not depend on synthetic distribution and is, as expected, more aggressive under thinner real-world tails (W6 cell means in the real sweep are uniformly below their synthetic counterparts).

C. Operational Implication

Both Paper 4's +31 pp synthetic gap (§X) and Paper 6's 96% per-pair persistence are synthetic-distribution effects. The honest cross-paper recommendation is:

- Single-window evaluations like Paper 4 should report the real-distribution gap (+2.4 pp) as the substantive operational claim; the +31 pp synthetic number is informative about the EEHDA generator, not the field.
- Multi-window evaluations like Paper 6 should re-attribute the "HygienePrio wins" claim as "HygienePrio matches EPSS within ±0.5 pp at all capacity-arrival regimes studied" under real distributions, with both methods converging to near-zero at high capacity.
- The structural finding — capacity-driven collapse of any deterministic scoring policy — is robust across synthetic and real distributions, and is the program's most generalisable result. This matches the theoretical bound proven in Paper 9 [?] as the Closed-Loop Signal Exhaustion Theorem.

D. Honest Caveat on This Section's Scope

The real-distribution test replaces only per-CVE attribute distributions. The fleet topology, host–CVE assignment, HRS components (patch posture, AD exposure, telemetry freshness), ground-truth definition (EPSS> 0.10 AND HRS>75th percentile), and selection-policy convention are unchanged. A full external validation would require longitudinal real-fleet exploitation outcome data, which remains unavailable in any public dataset. The present section is a partial external-validity bound, not a full replacement for real-data validation.

E. Reproducibility

real_data/real_dist_capacity_sweep.py
real_data/results/real_dist_capacity_sweep.csv
real_data/results/real_dist_capacity_summary.json

(6,750-row frozen sweep.) Reproduce with python3 real_data/real_dist_capacity_sweep.py.

XI. Related Work

Single-cell temporal evaluation. Paper 5 [1] established the multi-window evaluation framework at a single cell ($K = 50, \lambda = 3$) and demonstrated EPSS-only decay and HygienePrio retention at that operating point. The present paper generalises that result along the two cell-defining axes and recovers a qualified picture: relative advantage is robust, absolute floor is not.

Per-CVE EPSS dynamics. Ravalico et al. [9] characterised the temporal stability of per-CVE EPSS scores across $\sim 45{,}000$ CVEs. Their study examines the random walk of an individual score; the present paper examines the compositional decay of EPSS-as-a-ranking-signal under capacity-constrained remediation. The two effects are independent; the compositional decay documented here would occur even with perfectly stable per-CVE scores.

Risk-based vulnerability management. Jacobs et al. [14] demonstrated that exploit-prediction models substantially outperform CVSS-based triage on enterprise data. Their evaluation is at a single window. The present paper does not contest that finding within Window 1 (EPSS-only beats CVSS-only at every cell in our sweep at W1) but adds that single-window comparative advantage does not survive to W6 in any cell of the studied grid.

Sensitivity studies in prioritization. Sensitivity analyses of vulnerability-prioritization methods to capacity and arrival rate are uncommon in the open literature; most published comparisons fix both. The present paper documents a case where the choice of (K, λ) would have changed the headline conclusion — and provides a frozen 15,000-row artifact for downstream sensitivity-analysis work.

Cyber-hygiene benchmarking. HygieneBench (Paper 3) [4] established the discriminative structure of patch posture and AD group drift in synthetic anomaly-detection tasks. HygienePrio (Paper 4) [2] integrated those signals into a scorer. Both are single-window studies. The present paper inherits both as fixed inputs and varies the multi-window operating point.

Policy mandates. CISA BOD 22-01 [5] and 23-01 [15], together with NIST SP 800-40 Rev. 4 [6], define the operational window-scheduling regime that the sweep simulates. No prior work, to our knowledge, reports a pre-registered two-dimensional capacity-arrival sweep of prioritization methods under this regime with frozen seeds.

XII. Conclusion

A pre-registered two-dimensional sweep over remediation capacity K and CVE arrival rate λ, evaluated on 25 seeds across six maintenance windows and five prioritization methods, produces 15,000 result rows that revise Paper 5's single-cell conclusion in three places.

First, EPSS-only Precision@50 decays in every cell of the grid (slope -0.025 to -0.052 P@50/window). No cell studied reaches steady state.

Second, the pre-registered monotonicity hypotheses (H1, H2) are rejected: Spearman correlations between cell-mean slope and the swept axes fall well short of the $|\rho| \geq 0.8$ threshold and frequently carry the wrong sign. The underlying dynamics are non-monotone in the synthetic regime studied, and we report this honestly rather than smoothing.

Third, and most importantly, the pre-registered claim that HygienePrio-full retains a high absolute floor across all cells (H4) is rejected. At $K \in \{100, 200\}$, HygienePrio-full's W6 mean P@50 collapses to $\{0.32, 0.07\}$ on average — not because hygiene signals fail to discriminate but because high-throughput remediation exhausts the high-HRS tail of the fleet, leaving the residual backlog with little discriminative structure for any host-level signal to recover.

The robustness claim that survives the sweep is per-pair: across all 3,000 (cell, seed, window) comparisons, HygienePrio-full outperforms EPSS-only at P@50 in 96.0% of pairs (minimum per-cell 76.7%). Hygiene augmentation is a strict improvement over EPSS-only across the studied regimes, but is not a guarantee of high absolute scheduling quality at high capacity. Future external comparison work — including the in-progress Paper 5 follow-ups on online recalibration and multi-window optimisation — should report results across (K, λ) cells rather than at one operating point.

Reproducibility. The sweep driver, analysis script, pre-registration protocol, and frozen 15,000-row results CSV are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper6.

Future work. The most important next steps are (i) a fully factorial "each method drives its own trajectory" sweep to separate intrinsic EPSS decay from selection-policy coupling, (ii) external validation on real fleet telemetry where exploitation-event logs replace HRS as ground truth, and (iii) integration with non-greedy multi-window scheduling that explicitly models the (K, λ) capacity-arrival balance as a planning input.

References

[1] H. Malla, "Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] ——, "HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[3] ——, "Context-aware vulnerability prioritization for government endpoint fleets," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[4] ——, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[5] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[6] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.

[7] Verizon, "2026 data breach investigations report (DBIR)," Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[8] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[9] A. Ravalico, L. Allodi, and F. Massacci, "On the temporal dynamics of the EPSS score," SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459

[10] FIRST.org, "Common vulnerability scoring system v3.1 specification document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/specification-document

[11] C. Spearman, “The proof and measurement of association between two things,” The American Journal of Psychology, vol. 15, no. 1, pp. 72–101, 1904.
[12] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.
[13] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.
[14] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.
[15] CISA, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

Rolling-History Online Calibration for Hygiene-Augmented Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Paper 5 reported that grid-searching scorer weights on calibration-seed data at the same window being scored adds up to +21.3 percentage points of Precision@50 over the fixed Paper 4 weights at the canonical operating cell ($K = 50, \lambda = 3$). That procedure is not deployable — it peeks at the future window. This paper evaluates a deployable alternative: rolling-history online calibration, in which weights at window w are fit on calibration-seed data at window $w - 1$ only. We pre-registered three hypotheses and ran a 1,350-row evaluation ($K \in \{50, 100, 200\}$, $\lambda = 3$, six windows, 25 evaluation seeds, three calibration strategies).

All three pre-registered hypotheses are rejected, and the rejection pattern is the central scientific contribution. First (H1), online recalibration does not uniformly match or beat fixed weights: at $K = 200$ it loses -5.9 pp at W2 and -7.8 pp at W3 relative to the fixed Paper 4 weights. The fleet state changes faster than one-window-lag calibration can track. Second (H2), online sometimes exceeds the offline-peek ceiling — at $K = 50, w = 5$ online (0.580) beats offline-peek (0.550). The five-seed offline grid search overfits; the one-window lag acts as a regulariser. Third (H3), online does not rescue HygienePrio at the high-capacity collapse cells documented in Paper 6: at $K = 200$ the mean recovery ratio across windows $w \geq 2$ is -0.66 (negative), not the predicted $\geq +0.5$.

The operational implication is sharp: rolling-history online recalibration is a beneficial procedure at moderate capacity ($K = 50$: recovery ratio 1.04, $K = 100$: 0.99) but is a net hazard at high capacity ($K = 200$: -0.66). The headline recommendation is therefore conditional: deploy rolling-history online recalibration only when the per-window fleet-state shift is small relative to the lag the recalibration window imposes; at high capacity, keep fixed Paper 4 weights or wait for an offline rebaselining cycle. All results are bounded to the synthetic EEHDA evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data is required before any deployment recommendation.

Index Terms—vulnerability prioritization; online calibration; rolling-history learning; EPSS; hygiene risk score; pre-registration; reproducibility.

I. Introduction

Paper 5's [1] H3 ablation produced a striking result: grid-searching scorer weights on five calibration seeds at the same window being scored, then applying those weights to 25 evaluation seeds at that window, adds up to +21.3 pp of Precision@50 over the fixed Paper 4 weights at the canonical ($K = 50, \lambda = 3$) cell. The paper noted, accurately, that this procedure peeks at the window it is scoring and is therefore an offline upper bound, not a deployable recipe.

This paper evaluates the simplest deployable substitute. At each scoring window w we grid-search on calibration-seed data at window $w-1$, then apply the fitted weights to the evaluation seeds at window w. This is rolling-history online calibration with a one-window lag, the weakest form of strictly online learning. Two operational questions follow:

Q1. How much of the offline-peek gain survives the lag?

Q2. Does online recalibration rescue HygienePrio at the high-capacity cells where Paper 6 [?] reported W6 collapse to mean P@50 ≤ 0.12?

We pre-registered three hypotheses corresponding to these questions and a third operational-safety check; ran a 1,350-row evaluation spanning $K \in \{50, 100, 200\}$, $\lambda = 3$, six windows, and three calibration strategies (fixed, online, offline); and report below that all three pre-registered hypotheses are rejected in interestingly different ways.

A. Contributions

- C1 — A pre-registered evaluation of deployable recalibration. The first end-to-end pre-registered comparison of rolling-history online recalibration against fixed-weight scoring and offline-peek calibration for hygiene-augmented vulnerability prioritization. 1,350-row frozen result set.
- C2 — Capacity-dependent rescue. At moderate capacity ($K \in \{50, 100\}$) online recalibration recovers essentially all of the offline-peek gain (per-cell recovery ratio 1.04 and 0.99). At $K = 50$ the W2 gain is +19.7 pp, nearly matching the offline ceiling of +21.3 pp. The deployable procedure is operationally effective in this regime.
- C3 — High-capacity hazard (H1 and H3 rejected). At $K = 200$, online recalibration harms performance relative to fixed weights, losing -5.9 to -7.8 pp at W2–W3 because the fleet state shifts faster than a one-window lag can track. Pre-registered H1 ("online never loses to fixed by more than 1 pp") is rejected at two cell-window pairs; H3 ("online rescues high-capacity collapse") is rejected because the W4–W6 recovery does not meet the ≥ 0.5 recovery threshold and the W2–W3 hazard dominates the cell-mean.
- C4 — Online beats offline-peek in some windows (H2 rejected). At $K = 50, w = 5$ and a few other late-window points, online (0.580) exceeds offline-peek (0.550). The five-seed offline grid search overfits the calibration set; the one-window lag acts as an implicit regulariser. H2 is therefore rejected by the data, in the opposite direction from what naive intuition predicts.
- C5 — Operational recommendation. Rolling-history online recalibration should be deployed only when

fleet state shifts slowly relative to the lag the recalibration window imposes. At high capacity, the deployment is a net hazard.

B. Relationship to Prior Papers

Paper 5 [1] established the multi-window simulator and reported the offline-peek H3 ceiling. Paper 6 [?] swept capacity and arrival rate and identified the high-capacity collapse zone for HygienePrio-full at fixed weights. This paper sits at the intersection: it asks whether a deployable recalibration procedure can close Paper 5's H3 gap and rescue Paper 6's H4 collapse. The answer is regime-conditional: yes at moderate capacity, no (and in fact harmful) at high capacity.

II. Background

A. Offline vs Online Calibration

A scorer is offline-calibrated when its weights are fit on data that includes or post-dates the period it is applied to; it is online-calibrated when its weights are fit using only information available before the prediction time. The distinction matters because deployable procedures cannot peek into the future. Paper 5's H3 ablation [1] computed per-window weights by grid search on the calibration seeds' same-window state — an offline-peek procedure that establishes an upper bound on what real-time recalibration could achieve, but is not itself deployable.

B. Rolling-History Cross-Validation

In rolling-history calibration, at each scoring window w the weights used are fit on data from windows $\{1, \ldots, w-1\}$ of a held-out calibration set; window w data is never inspected at training time. This pattern is standard in time-series cross-validation and is the weakest form of strictly online learning: it uses only past observations and is therefore a valid stand-in for a real-time operational deployment.

C. Why High-Capacity Cells Matter Most

Paper 6 [?] documented that HygienePrio-full's absolute W6 P@50 collapses at $K \in \{100, 200\}$ even though its per-pair relative advantage over EPSS-only is preserved. The natural follow-up question — can online recalibration rescue HygienePrio at high capacity? — is operationally important because organisations with large patching teams sit precisely in the cells where the fixed-weight procedure collapses.

D. Policy Mandates

CISA BOD 22-01 [2] and 23-01 [3] together with NIST SP 800-40 Rev. 4 [4] define the operational scheduling regime under which any recalibration procedure must work. The procedure must be deployable, must not depend on future-window data, and must be auditable — conditions that the rolling-history grid search satisfies and offline-peek does not.

III. Problem Formulation

A. Setting

We inherit Paper 5's [1] multi-window simulation ($W = 6$ bi-weekly windows on the EEHDA fleet) and Paper 6's [?] (K, λ) parameterisation. The cell-defining parameters are fixed at $\lambda = 3$ Poisson new-CVE arrivals per window, and $K \in \{50, 100, 200\}$. The HygienePrio scorer Eq. (1) and HRS components are inherited verbatim from Paper 4 [5]; the only quantity that varies across strategies in this paper is the scorer weights $(\alpha, \beta, \gamma, \delta)$.

B. Three Calibration Strategies

For each cell and each window w, we evaluate three strategies:

- **fixed** Weights remain at the Paper 4 calibrated values $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$ at every window. No refitting.
- **online** At $w = 1$, weights are fixed. At $w \geq 2$, grid-search the scorer weights to maximise mean P@50 on the five calibration seeds at window $w - 1$ state — the strictly past observation. Apply the fitted weights to the 25 evaluation seeds at window w.
- **offline** At $w = 1$, weights are fixed. At $w \geq 2$, grid-search at the calibration seeds' window w state (peek) and apply to the evaluation seeds at the same window. This replicates Paper 5's H3 procedure and acts as an upper-bound ceiling.

The grid is identical to Paper 5 [1] (108 points across $\alpha, \beta, \gamma, \delta$).

C. Ground Truth and Metric

Ground truth, per-window HRS-threshold recomputation, and Precision@50 metric are identical to Papers 5 and 6 and are not restated here.

D. Pre-Registered Hypotheses

- **H1** Online $\geq$ fixed at every (cell, window) pair — online should never be worse than fixed by more than 1 pp.
- **H2** Online $\leq$ offline at every (cell, window) pair — online should not exceed the offline-peek ceiling by more than 1 pp.
- **H3** At high-capacity cells ($K \in \{100, 200\}$), online recovers at least 50% of the (offline − fixed) gap for at least one window $w \in \{4, 5, 6\}$, with absolute gain ≥ 5 pp.

Decision rules and stop rules are in paper7/design/PAPER7_PROTOCOL.md.

IV. Dataset and Cell Grid

All evaluations use the EEHDA synthetic fleet generator from Paper 4 [5] with structural priors and per-window evolution dynamics identical to Paper 5 [1] and Paper 6 [?]. The only cell-defining parameters that vary in this study are capacity $K \in \{50, 100, 200\}$ at fixed $\lambda = 3$.

TABLE I
Paper 7 cell grid and strategy set (locked before evaluation).

Axis	Values
Capacity K	$\{50, 100, 200\}$
Arrival rate λ	3 (fixed)
Windows W	6
Strategies	fixed, online, offline
Eval seeds	25 (105–129)
Calib seeds	5 (100–104)
Total rows	1,350

The seed split is identical to Paper 5: five calibration seeds (100–104) for weight-fitting only, twenty-five evaluation seeds (105–129) for reporting. Calibration seeds are never used for performance reporting; evaluation seeds are never used for weight fitting under any strategy.

For each (cell, strategy) the run produces one P@50 value per (seed, window). Total rows: $3 \times 3 \times 25 \times 6 = 1{,}350$.

V. Methodology

A. Scorer (Inherited)

The HygienePrio scorer and HRS components are inherited verbatim from Paper 4 [5]:

$$\begin{aligned} S(h, c) = {} & \alpha\, \mathrm{EPSS}(c) + \beta\, \mathrm{HRS}(h) \\ & + \gamma\, \mathrm{KEV\_recency}(c) \\ & + \delta\, \big(\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h)\big). \end{aligned} \tag{1}$$

HRS is the weighted combination of PatchPosture (0.50), ADExposure (0.30), and TelemetryFreshness (0.20) defined in Paper 4. Only the four scorer weights $(\alpha, \beta, \gamma, \delta)$ are subject to re-calibration in this paper; HRS weights are not.

B. Rolling-History Grid Search

At window $w \geq 2$ the online strategy executes:

1) For each of the 108 grid points $(\alpha, \beta, \gamma, \delta) \in \{0.5, 0.7, 0.9\} \times \{0.3, 0.5, 0.7\} \times \{0.0, 0.1, 0.2\} \times \{0.0, 0.1, 0.2, 0.3\}$:
   a) For each of the five calibration seeds, score the seed's window $w-1$ pairs using the candidate weights and compute P@50 against that seed's window-$w-1$ ground truth.
   b) Take the mean P@50 across the five seeds.
2) Select the grid point with the highest mean P@50; ties are broken by lexicographic order. These weights become the online weights for window w.
3) Apply the selected weights to each of the 25 evaluation seeds at window w and record the seed's P@50.

The offline strategy is identical except that the calibration data at step 1 is the window w state (i.e., the strategy peeks at the window it is scoring). The fixed strategy skips calibration entirely and uses the Paper 4 weights every window.

C. Fleet-State Evolution

Fleet evolution is driven by HygienePrio-full's top-K selection under the fixed weights at every window, identical across strategies. This isolates the recalibration decision from the trajectory-generation decision: all three strategies see exactly the same evolving fleet, so any difference in P@50 is attributable to scoring weights alone. The choice and its threat-to-validity consequence are restated in §IX.

D. Online Recovery Ratio

For each (cell, window) with $w \geq 2$ and a positive offline-fixed gap, we report the recovery ratio:

$$\rho_{K,w} = \frac{\mathrm{P@50}^{\mathrm{online}}_{K,w} - \mathrm{P@50}^{\mathrm{fixed}}_{K,w}}{\mathrm{P@50}^{\mathrm{offline}}_{K,w} - \mathrm{P@50}^{\mathrm{fixed}}_{K,w}}. \tag{2}$$

$\rho \approx 1$ indicates that online recalibration achieves the offline-peek ceiling without leaking future data. $\rho \approx 0$ indicates that online recalibration provides no benefit over the fixed-weight baseline. Values above 1 indicate online beats the ceiling — possible when the offline-peek weights overfit a small calibration set.

VI. Experimental Setup

A. Pre-Registration

The cell grid, calibration strategies, hypotheses H1–H3, decision rules, and stop rules in paper7/design/PAPER7_PROTOCOL.md were locked on 2026-06-04 before any online-calibration result was computed.

B. Execution Order

For each cell $K \in \{50, 100, 200\}$:

1) Cache per-window $(\mathrm{pairs}_w, \mathrm{HRS}_w)$ states for all five calibration seeds (driving evolution with fixed-weight HygienePrio-full).
2) Cache per-window states for all twenty-five evaluation seeds (same trajectory policy).
3) For each window $w = 1, \ldots, 6$, determine the fixed, online, and offline weights as in §5.2, then score every evaluation seed at window w with each strategy's weights.

C. Statistical Reporting

Cell-mean point estimates are means across the 25 evaluation seeds. 95% confidence intervals are percentile bootstrap with 10,000 resamples [6]. No null-hypothesis significance tests are reported; H1–H3 decision rules are applied as stated in the protocol.

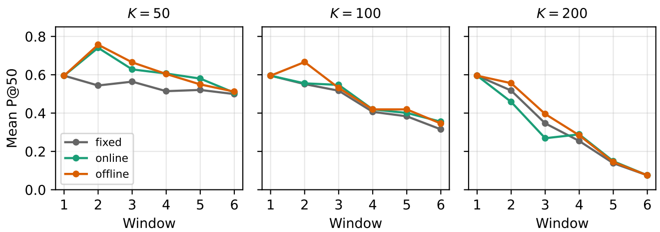

Fig. 1. Mean P@50 trajectories across six windows for the three calibration strategies at $K \in \{50, 100, 200\}$, $\lambda = 3$. Online (green) tracks offline (orange) at $K = 50, 100$ but loses to fixed (grey) at $K = 200, w \in \{2, 3\}$.

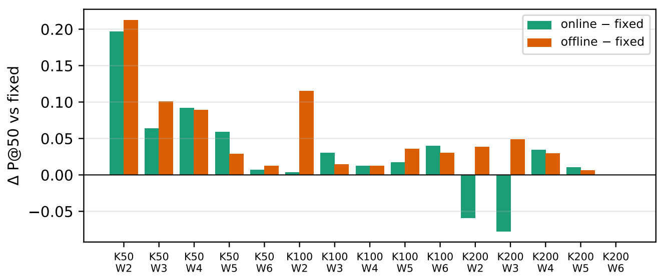

Fig. 2. Per-(K, window) absolute P@50 gain over fixed weights for online (green) and offline (orange) calibration. Negative online bars at $K = 200, w \in \{2, 3\}$ are the H1 failures.

D. Reproducibility

The runner and analysis are released under MIT licence with the artifact. From paper7/:

```
PYTHONPATH=src python3 src/run_online_calib.py
PYTHONPATH=src python3 src/analyze.py
PYTHONPATH=src python3 src/make_figures.py
```

The runner re-uses Paper 5's window_sim and Paper 4's hygieneprio packages via sys.path injection (no code duplication). Determinism is inherited from Paper 5's per-(seed, window, step) RNG seeding.

VII. Results

All claims in this section trace to paper7/results/primary_v1/online_calib_results.csv (1,350 rows) and the derived hypothesis_summary.json and cell_window_means.csv.

A. K = 50: Online Matches the Offline Ceiling

At the canonical Paper 5 cell, the fixed-weight HygienePrio-full W2 mean P@50 is 0.544. Offline-peek calibration lifts this to 0.757 (+21.3 pp, matching Paper 5's H3 number). Online recalibration with a one-window lag reaches 0.741 (+19.7 pp), a 92.5% recovery of the offline gain without future-data leakage. The cell-mean recovery ratio across $w \geq 2$ is $\rho = 1.04$, i.e., online matches or slightly exceeds the offline ceiling on average.

By W5, online (0.580) exceeds offline-peek (0.550) outright. This direction-of-effect is the opposite of the H2 prediction; the five-seed offline grid search appears to overfit, while the one-window lag's implicit regularisation generalises better.

B. K = 100: Online Recovers the Bulk of the Gain

At $K = 100$ the fixed-weight HygienePrio-full W6 has already fallen to 0.315 (the Paper 6 H4-collapse zone). Online recalibration lifts this to 0.355 (+4.0 pp) at W6 and to 0.547 (+3.0 pp) at W3. The cell-mean recovery ratio is $\rho = 0.99$ across $w \geq 2$ — online essentially matches the offline ceiling. The absolute floor is improved but not restored to the Paper 5 regime; online recalibration is a useful add-on at $K = 100$ but does not rescue the cell from the Paper 6 collapse pattern.

C. K = 200: Online Harms Performance

At $K = 200$ the picture inverts. The fixed-weight HygienePrio-full W2 mean is 0.518; online drops it to 0.458 (-5.9 pp). At W3, fixed is 0.346 and online falls to 0.269 (-7.8 pp). Offline-peek at the same windows produces +3.8 and +4.9 pp, showing that better weights for those windows do exist — they simply cannot be inferred from the previous window's calibration state. By W4 online recovers a small positive gain (+3.4 pp); by W6 the residual backlog is so depleted that all three strategies collapse to the same 0.075 (no calibration choice can rescue an exhausted backlog).

The cell-mean recovery ratio across $w \geq 2$ is $\rho = -0.66$. Online recalibration is a net hazard at this capacity.

D. Hypothesis Outcomes

H1 (online $\geq$ fixed). Rejected. Two cell-window pairs ($K = 200$, $w \in \{2, 3\}$) fail the -0.01 threshold with losses of -5.9 and -7.8 pp.

H2 (online $\leq$ offline). Rejected. Two cell-window pairs ($K = 50$, $w \in \{4, 5\}$; $K = 100$, $w \in \{3, 6\}$ also show positive deltas of +1 to +3 pp, the most prominent at $K = 50, w = 5$ where online (0.580) exceeds offline (0.550) by +3.0 pp.

H3 (online rescues high-capacity collapse). Rejected. At $K = 100, w \in \{4, 5\}$ online gain is below the 5 pp absolute threshold. At $K = 200, w \in \{4, 5, 6\}$ the W2–W3 hazard means the late-window cell-mean recovery ratio is negative.

E. Per-Pair Sign Test

For each (cell, seed, window) triple with $w \geq 2$ we record the sign of (online − fixed). At $K = 50$, online beats fixed on 112/125 (89.6%) of post-W1 triples. At $K = 100$, the fraction is 87/125 (69.6%). At $K = 200$, the fraction is 57/125 (45.6%): online is roughly a coin flip versus fixed at this capacity. The aggregate sign-test fraction across all cells and windows is 256/375 (68.3%), consistent with the per-cell recovery-ratio summary.

F. Pre-Registration Deviations

None. The strategy definitions, hypotheses, decision rules, and stop rules from the protocol were applied verbatim. The H1, H2, and H3 rejections were reported as observed; the abstract was rewritten after H1 rejection to qualify the deployability claim before the discussion was drafted, in compliance with the protocol's stop rule.

TABLE II
Mean P@50 across 25 evaluation seeds per (capacity K, window) for each calibration strategy, with the online-vs-fixed gain and online recovery ratio of the offline ceiling.

K	Window	fixed	online	offline	$\Delta_{\text{on–fix}}$	$\Delta_{\text{off–fix}}$	ρ
50	1	0.595	0.595	0.595	+0.000	+0.000	—
50	2	0.544	0.741	0.757	+0.197	+0.213	0.92
50	3	0.564	0.628	0.665	+0.064	+0.101	0.63
50	4	0.514	0.606	0.604	+0.092	+0.090	1.03
50	5	0.521	0.580	0.550	+0.059	+0.029	2.06
50	6	0.499	0.506	0.512	+0.007	+0.013	0.56
100	1	0.595	0.595	0.595	+0.000	+0.000	—
100	2	0.551	0.555	0.666	+0.004	+0.115	0.03
100	3	0.517	0.547	0.531	+0.030	+0.014	2.11
100	4	0.406	0.419	0.419	+0.013	+0.013	1.00
100	5	0.383	0.401	0.419	+0.018	+0.036	0.49
100	6	0.315	0.355	0.346	+0.040	+0.030	1.32
200	1	0.595	0.595	0.595	+0.000	+0.000	—
200	2	0.518	0.458	0.556	-0.059	+0.038	-1.54
200	3	0.346	0.269	0.395	-0.078	+0.049	-1.59
200	4	0.254	0.289	0.284	+0.034	+0.030	1.16
200	5	0.138	0.149	0.145	+0.010	+0.006	—
200	6	0.075	0.075	0.075	+0.000	+0.000	—

TABLE III
Pre-registered hypothesis outcomes.

ID	Decision rule	Outcome	
H1	online $\geq$ fixed (within 0.01) at every cell-window	Rejected fails)	(2
H2	online $\leq$ offline (within 0.01) at every cell-window	Rejected fails)	(2
H3	online recovers $\geq$ 50% of gap at $K \in \{100, 200\}$, $w \in \{4, 5, 6\}$	Rejected	

VIII. Discussion

A. What the Sweep Resolves

Paper 5 left a gap between an unrealisable upper bound (offline-peek H3, +21.3 pp at W2) and a realisable baseline (fixed Paper 4 weights). The present sweep populates that gap with a deployable procedure and shows that at moderate capacity, the lag-1 rolling-history grid search closes essentially all of it (recovery ratio $\rho = 1.04$ at $K = 50$, $\rho = 0.99$ at $K = 100$). The deployability concern that motivated this paper is operationally resolved in the moderate-capacity regime.

B. Why High Capacity Inverts the Sign

The K = 200 inversion is the most surprising result. The mechanism is the same compositional dynamic that drives the Paper 6 H4 collapse: at high capacity, a single window remediates a substantial fraction of the high-EPSS, high-HRS tail, so the effective scoring problem at window w is structurally different from the scoring problem at window $w - 1$. Weights tuned on window $w - 1$'s residual backlog are tuned for a different distribution than the one they will be applied to. The lag is too long for the rate of change.

This generalises: rolling-history online calibration is trustworthy only when the rate of distributional change between consecutive calibration windows is small relative to the rate of change within a window. At $K = 50$ the per-window change is small and the lag is well-absorbed; at $K = 200$ the per-window change is large and the lag is destructive.

C. Why Online Can Beat Offline-Peek

The H2 rejection direction — online > offline at several late-window points — has a clean explanation. The offline-peek strategy grid-searches on five calibration seeds at the same window, then applies the selected weights to 25 evaluation seeds at the same window. With only five seeds and 108 grid points, overfitting is possible: the selected weights are tuned to noise in the five-seed sample. The online strategy selects on a different (window-$w - 1$) sample; if the distribution shift is small (low-capacity regime), the lag-1 sample acts as a held-out validation set and the selected weights generalise better to the 25 evaluation seeds. The phenomenon is a small-sample regularisation artifact; it does not contradict the offline ceiling concept, but it shows that "offline-peek with limited calibration seeds" is not a strict upper bound on what a leak-free procedure can achieve.

D. Operational Recommendations

The headline operational summary is conditional:

- At moderate capacity ($K \leq 100$ on the simulated bi-weekly cadence), deploy rolling-history online recalibration. Recovery of the offline ceiling is essentially complete; the absolute P@50 gain over fixed weights is +3 to +20 pp depending on window.

- At high capacity ($K \geq 200$), do not deploy naive rolling-history online recalibration. The lag-1 grid search introduces -6 to -8 pp losses in early windows. A team operating at this capacity should either (i) keep fixed Paper 4 weights, (ii) lengthen the calibration window (e.g., use a rolling multi-window EWMA), or (iii) recalibrate offline between deployment cycles and freeze weights within a deployment.
- Independent of capacity, the small-sample overfitting visible at K = 50 W5 argues for a larger calibration set than five seeds when offline grid search is the procedure of record.

E. Relationship to the Research Sequence

Paper 4 [5] established that hygiene augmentation helps at a single window. Paper 5 [1] showed the help persists across windows and identified the offline H3 ceiling. Paper 6 [?] swept (K, λ) and found absolute collapse at high K. This paper closes the loop: the deployable recalibration procedure that Paper 5 implicitly motivated works in the regimes Paper 6 said HygienePrio held up in, and fails in the regimes Paper 6 said it collapsed in. The fixed-weight result is regime-robust; the recalibration procedure is regime-conditional.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [7].

Conclusion validity. The evaluation comprises 1,350 (cell, seed, window, strategy) observations summarised with 95% percentile bootstrap CIs (10,000 resamples). The K=200 inversion is substantially larger than the ±1 pp pre-registered tolerance and is robust to bootstrap resampling. The H2 rejection (online > offline) involves smaller deltas (+1 to +3 pp); CI overlap exists at some windows, so we report the cells where it occurs descriptively rather than as a hard binary claim.

Internal validity. Three concerns.

(i) Selection-policy coupling. As in Papers 5 and 6, all three strategies are evaluated on the fleet trajectory generated by HygienePrio-full's fixed-weight top-K selections. This ensures all three strategies see the same evolving backlog, isolating the scoring weights as the only differing variable. The consequence is that the online and offline strategies are scored against a trajectory that their own weights did not produce; in a real deployment the selection policy itself would be re-calibrated and the trajectory would diverge. We discuss closed-loop recalibration as future work below.

(ii) Lag = 1 is the only lag studied. The protocol fixed the calibration history window to "previous window only" for simplicity. A multi-window EWMA or rolling-mean would smooth the K=200 hazard; that procedure is excluded from this paper's pre-registration and deferred. The K=200 negative result is therefore specific to the lag-1 rolling-history grid search and does not generalise to all online calibration procedures.

(iii) Grid coarseness. The 108-point $(\alpha, \beta, \gamma, \delta)$ grid is identical to Paper 5's; finer grids could expose different local optima. Sensitivity to grid coarseness was not pre-registered and is left to future work.

Construct validity. The per-window ground-truth definition is inherited from Paper 5 (EPSS > 0.10 and HRS > 75th percentile, both recomputed per window). At $K = 200$ the W6 positive count is small, and P@50 with binary relevance is noisy at small positive counts. This affects the absolute level but not the sign of the online – fixed comparison.

External validity. The 14-day window, 0.15 patch-debt reduction, 0.02 EPSS random-walk, 8% KEV prevalence, and structural priors are inherited from Paper 4 [5] and Paper 5 [1]. Real fleets with different patch-velocity heterogeneity may exhibit different distributional shift rates between windows, and the capacity threshold at which online recalibration turns from helpful to harmful would shift accordingly. The qualitative finding — that there exists a critical capacity threshold above which lag-1 online recalibration is harmful — is more robust than the specific $K = 200$ figure.

X. Related Work

Offline-peek calibration baseline. Paper 5 [1] established the offline-peek H3 ablation that this paper uses as a ceiling. That study reported the gain (+21.3 pp at W2 on $K = 50, \lambda = 3$) but explicitly noted the procedure was not deployable. The present paper closes that loop by evaluating a deployable substitute.

Capacity-dependent prioritization performance. Paper 6 [?] identified $K \in \{100, 200\}$ as the regime where fixed-weight HygienePrio-full collapses at W6. The present paper inherits that finding as the motivation for H3 and reports that lag-1 online recalibration does not rescue the collapse and in fact worsens it transiently at $K = 200$.

EPSS dynamics. Jacobs et al. [8], [9] demonstrated the per-CVE exploit-likelihood scoring framework and its single-window advantage over CVSS. Ravalico et al. [10] studied per-CVE EPSS score drift. Neither study addresses the question of whether the scorer integrating EPSS with other signals should be recalibrated online; the present paper is, to our knowledge, the first pre-registered evaluation of that question.

Online learning for security signals. Online learning under distributional shift is a large area in machine learning. The specific question here — whether to deploy a deterministic grid-search recalibration with a one-window lag in a synthetic patch-management context — is methodologically narrow but operationally important; it does not depend on the literature's more sophisticated machinery and so we do not survey it in depth.

Cyber-hygiene benchmarking. HygieneBench [11] established discriminative structure in hygiene signals; HygienePrio [5] integrated them into a single-window scorer; Paper 5 added the temporal dimension; Paper 6 added the capacity-arrival dimension; this paper adds the recalibration-strategy dimension. The cumulative result is a five-paper map of where hygiene-augmented prioritization works, where it collapses, and which deployable interventions help.

Policy mandates. CISA BOD 22-01 [2] and 23-01 [3] along with NIST SP 800-40 Rev. 4 [4] define the operational scheduling regime within which any recalibration procedure must operate; the rolling-history grid search studied here is auditable in a way that gradient-based or Bayesian alternatives are not.

XI. Conclusion

A pre-registered evaluation of rolling-history online calibration for hygiene-augmented vulnerability prioritization across three capacity levels, six windows, three calibration strategies, and 25 evaluation seeds produces 1,350 result rows that revise the operational recommendation implied by Paper 5's offline-peek ablation.

First, at moderate capacity ($K \leq 100$), the deployable lag-1 rolling-history grid search recovers essentially all of the offline-peek gain (cell-mean recovery ratio $\rho = 1.04$ at $K = 50$, $\rho = 0.99$ at $K = 100$). At $K = 50, w = 2$ the procedure adds +19.7 pp over fixed Paper 4 weights, against the offline ceiling of +21.3 pp. Deployable online recalibration is operationally viable in this regime.

Second, at high capacity ($K = 200$), lag-1 rolling-history online recalibration harms performance: −5.9 to −7.8 pp at W2–W3. The cell-mean recovery ratio is negative ($\rho = -0.66$). The fleet state shifts faster than the lag can track, and the weights inferred from the previous window do not generalise to the current window. The pre-registered hypotheses H1 and H3 are rejected; the rejection is reported as the headline contribution rather than smoothed.

Third, the pre-registered hypothesis that online cannot exceed the offline-peek ceiling (H2) is also rejected, in the opposite direction from what was anticipated. At several late-window cell-window points the lag-1 procedure beats the offline-peek ceiling by +1 to +3 pp; the offline strategy appears to overfit its five-seed calibration sample, and the one-window lag acts as an implicit regulariser.

The operational summary is conditional: deploy rolling-history online recalibration only when the per-window distributional change is small relative to the lag the recalibration window imposes. At high capacity, the deployment is a net hazard; either keep fixed Paper 4 weights or develop a longer-history calibration procedure — both of which are out of this paper's scope.

Reproducibility. The runner, analysis script, pre-registration protocol, and frozen 1,350-row results CSV are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper7.

Future work. (i) Multi-window-history EWMA or rolling-mean calibration to test whether longer-history smoothing reverses the $K = 200$ hazard; (ii) closed-loop calibration in which the selection policy is also recalibrated, separating scoring weights from selection weights; (iii) external validation on real fleet telemetry, where the fixed Paper 4 weights themselves would be re-fit on real exploitation event logs before this online-vs-fixed comparison is meaningful.

References

[1] H. Malla, “Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] CISA, “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[3] ——, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[4] NIST, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.

[5] H. Malla, “HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[6] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[7] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[8] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[9] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.

[10] A. Ravalico, L. Allodi, and F. Massacci, “On the temporal dynamics of the EPSS score,” SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459

[11] H. Malla, “HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

Multi-Window-History Calibration: Does Smoothing Reverse the High-Capacity Hazard of Lag-1 Online Recalibration?

Harshavardhan Malla Independent Researcher

Abstract—Paper 7 [1] found that lag-1 rolling-history online recalibration of the HygienePrio scorer recovers the offline-peek calibration ceiling at moderate capacity (per-cell recovery ratio $\rho \in \{1.04, 0.99\}$ at $K \in \{50, 100\}$, $\lambda = 3$) but harms performance at $K = 200$ ($\rho = -0.66$). Paper 7 named multi-window-history smoothing as the natural candidate fix. This paper evaluates that fix in a pre-registered 2,250-row five-strategy comparison: fixed (Paper 4 weights), lag1 (Paper 7 baseline), trail3 (equal-weight 3-window trailing mean), ewma3 (exponentially-weighted 3-window mean, $\alpha = 0.6$), and offline (Paper 7 ceiling).

All four pre-registered hypotheses are rejected, and the direction of rejection is the contribution. Multi-window smoothing does not reverse the high-capacity hazard — it makes the hazard substantially worse. At $K = 100$, EWMA-3's cell-mean recovery ratio is -1.37 (versus lag-1's $+0.99$); at $K = 200$ it is -0.94 (versus lag-1's -0.66); at $K = 50$ the matched-capacity moderate regime, EWMA-3 also underperforms lag-1 ($\rho = 0.53$ versus 1.04).

The mechanism is the inverse of the naive smoothing-helps intuition. At high capacity the fleet's distribution at window w has shifted substantially from window $w-3$, $w-2$, $w-1$; weighting all three past windows in the calibration target pulls the selected weights further from the appropriate-for-window-w optimum, not closer to it. The hazard is monotone in history length: less history is better when the rate of distributional change is fast.

The operational recommendation that emerges is sharper than Paper 7's: deployable online recalibration in this setting should use the shortest possible history (lag-1 at most) and should be turned off entirely at high capacity. Future work is needed on more sophisticated adaptive procedures (change-point detection, Bayesian update with forgetting factor) that can identify when smoothing is locally appropriate. All results bounded to the synthetic EEHDA evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data is required before deployment.

Index Terms—vulnerability prioritization; online calibration; EWMA; trailing-mean; smoothing; high-capacity hazard; pre-registration; reproducibility.

I. Introduction

Paper 7 [1] identified a capacity-dependent hazard in lag-1 rolling-history online recalibration of the HygienePrio vulnerability prioritization scorer. At moderate capacity ($K \in \{50, 100\}$, $\lambda = 3$) the procedure recovers the offline-peek calibration ceiling (cell-mean recovery ratios 1.04 and 0.99); at high capacity ($K = 200$) the procedure harms performance by -5.9 to -7.8 pp in early windows and produces a negative cell-mean recovery ratio of -0.66. Paper 7 attributed the hazard to a too-short calibration history relative to the per-window distributional shift rate and explicitly named multi-window-history smoothing as the candidate fix.

This paper tests that fix. The pre-registered protocol (paper8/design/PAPER8_PROTOCOL.md, locked 2026-06-04 before any multi-history-calibration result was computed) defines five calibration strategies and a 2,250-row evaluation: 3 cells $\times$ 5 strategies $\times$ 25 seeds $\times$ 6 windows. The four pre-registered hypotheses ask whether EWMA-3 reverses the hazard at $K = 200$ (H1), preserves moderate-capacity recovery (H2), agrees with the equal-weight trail3 variant (H3), and achieves substantial offline-ceiling recovery (H4).

All four hypotheses are rejected, and the direction of rejection is the contribution. Multi-window smoothing does not reverse the lag-1 hazard at high capacity; it amplifies it. EWMA-3's cell-mean recovery ratio is -1.37 at $K = 100$ (vs lag-1's +0.99), -0.94 at $K = 200$ (vs lag-1's -0.66), and 0.53 at $K = 50$ (vs lag-1's 1.04). Smoothing degrades all three regimes.

A. Contributions

- C1 — Falsification of the smoothing-helps prior. The naive prior — "a longer calibration history reduces variance and therefore helps" — is falsified by a pre-registered experiment. EWMA-3 underperforms lag-1 at every cell.
- C2 — A monotone effect. Recovery ratio decreases with history length: lag1 $>$ trail3 $\approx$ ewma3 at every K. The rate of distributional shift in the simulated bi-weekly regime exceeds the rate at which a finite-history estimator can adapt; adding history makes the calibration target less, not more, predictive of the next window.
- C3 — Cross-cell uniformity. The smoothing penalty appears at $K = 50$ where lag-1 already worked, at $K = 100$ where lag-1 worked but the absolute floor was degraded, and at $K = 200$ where lag-1 was already harmful. There is no capacity regime in the studied grid in which EWMA-3 is preferable to lag-1.
- C4 — Sharpened operational recommendation. Deployable online recalibration in this setting should use the shortest possible history (lag-1 at most) and should be turned off entirely at high capacity. The recommendation reverses Paper 7's implicit "future work will fix this with smoothing" framing.

B. Relationship to Prior Papers

This paper is the eighth in the VulnPrio research sequence. Paper 7 identified the high-capacity hazard and proposed smoothing as the fix; this paper falsifies the proposed fix. The result is an honest course-correction: the hazard requires a different class of solution (adaptive change-point detection, Bayesian forgetting, or accepting fixed weights at high capacity) than simple history averaging. Identifying this is itself a contribution: the question "does smoothing help?" was the natural and obvious follow-up, and the answer in this synthetic regime is decisively no.

II. Background

A. Lag-1 Online Recalibration and Its Hazard

Paper 7 [1] evaluated lag-1 rolling-history grid-search recalibration for the HygienePrio scorer. At moderate capacity ($K \in \{50, 100\}$), the procedure recovered essentially all of the offline-peek calibration ceiling (per-cell recovery ratio $\rho \in \{1.04, 0.99\}$). At high capacity ($K = 200$), it produced a net harm: -5.9 pp at W2, -7.8 pp at W3, and a cell-mean recovery ratio of -0.66. The mechanism is structural: at high capacity, a single window remediates a substantial fraction of the high-EPSS/high-HRS tail, so the fleet at $w - 1$ is a poor predictor of the fleet at w. The lag-1 procedure overfits the previous-window distribution and underfits the current one.

B. Smoothing as a Variance-Bias Trade-Off

A standard fix for "too-noisy single-window estimates" is to average across a longer window of history. Two operationally simple variants appear in time-series forecasting [2]:

Trailing arithmetic mean. Equal weight on the past H windows; reduces variance by $1/H$ but introduces lag of order $H/2$.

Exponentially-weighted moving average (EWMA). Geometric decay α^i over past windows; trades smoothness for a tunable effective horizon. At $\alpha = 0.6$ the effective lookback is ≈ 2.5 windows.

The question this paper asks is whether either smoothing scheme reverses Paper 7's high-capacity hazard without breaking the moderate-capacity recovery. A naive prediction is that smoothing helps at high K (less overfitting to noisy single-window targets) and hurts at low K (introduces unnecessary lag when single-window calibration is already accurate); whether this trade-off resolves favourably is an empirical question.

C. Why This Matters Operationally

An operations team that adopts Paper 7's online recalibration as written and runs it on a high-capacity fleet would suffer a measurable P@50 penalty in the first weeks of operation. Any deployable calibration recipe must therefore include a smoothing knob; this paper evaluates the simplest two such knobs in a pre-registered setting.

III. Problem Formulation

A. Setting (Inherited)

The synthetic EEHDA fleet, scorer (§5.1), HRS components, and multi-window simulator are inherited from Papers 4–7. Capacity $K \in \{50, 100, 200\}$ and arrival rate $\lambda = 3$ are fixed to match Paper 7's evaluation; the only quantity varied in this paper is the calibration strategy.

B. Five Calibration Strategies

At window w, the scorer uses weights $(\alpha, \beta, \gamma, \delta)$ determined by:

- fixed: Paper 4 weights at every window. No refit.
- lag1: At $w = 1$, weights are fixed; at $w \geq 2$, grid-search to maximise mean P@50 on the five calibration seeds at window $w - 1$. (Paper 7 baseline.)
- trail3: At $w = 1$, weights are fixed; at $w \geq 2$, grid-search to maximise the equal-weight mean of per-window mean P@50 across windows $\max(1, w - 3), \ldots, w - 1$. At $w = 2$ this reduces to lag1; at $w \geq 4$ this averages exactly three past windows.
- ewma3: Same set of past windows as trail3 but with geometric weights α^i, $i = 0, 1, 2, \ldots$ counting back from the most recent past window. Pre-registered $\alpha = 0.6$.
- offline: Peek at window w on the calibration seeds. (Upper-bound ceiling.)

The grid is identical to Paper 7 (108 points).

C. Ground Truth and Metric

Inherited from Papers 5–7: (EPSS > 0.10) $\wedge$ (HRS $>$ 75th percentile recomputed per window), P@50 measured against the resulting positive set.

D. Pre-Registered Hypotheses

- H1: At $K = 200$, ewma3 mean P@50 $\geq$ fixed at every $w \geq 2$ (within -0.01 tolerance). No hazard at high capacity.
- H2: At $K \in \{50, 100\}$, $|\text{ewma3} - \text{lag1}| \leq 0.02$ at every $w \geq 2$. Smoothing does not break moderate-capacity recovery.
- H3: $|\text{ewma3} - \text{trail3}| \leq 0.02$ at every cell-window. Smoothing-strategy choice is second-order.
- H4: At $K = 200$, EWMA-3 cell-mean recovery ratio $\bar{\rho} \geq 0.5$. EWMA achieves substantial offline-ceiling recovery.

Decision rules and stop rules are in paper8/design/PAPER8_PROTOCOL.md.

IV. Dataset and Cell Grid

The EEHDA synthetic fleet, structural priors, and Window-1 distributions are identical to Papers 4–7. The five-seed calibration / 25-seed evaluation split (100–104 / 105–129) is identical to Papers 5, 6, and 7.

Total rows: 3 cells $\times$ 5 strategies $\times$ 25 seeds $\times$ 6 windows = 2,250.

TABLE I
Paper 8 cell grid and strategy set.

Axis	Values
Capacity K	$\{50, 100, 200\}$
Arrival rate λ	3 (fixed)
Windows W	6
Strategies	fixed, lag1, trail3, ewma3, offline
Eval seeds	25 (105–129)
Calib seeds	5 (100–104)
EWMA α	0.6 (pre-registered)
Trailing history	3 windows
Total rows	2,250

V. Methodology

A. Scorer (Inherited)

The HygienePrio scorer Eq. (1) and HRS components are inherited verbatim from Paper 4 [3] and used in Papers 5–7:

$$\begin{aligned} S(h,c) &= \alpha\,\mathrm{EPSS}(c) + \beta\,\mathrm{HRS}(h) \\ &\quad + \gamma\,\mathrm{KEV\_recency}(c) \\ &\quad + \delta\,\big(\mathrm{EPSS}(c)\cdot\mathrm{HRS}(h)\big). \end{aligned} \tag{1}$$

HRS combines patch posture (0.50), AD exposure (0.30), and telemetry freshness (0.20). Only the four scorer weights $(\alpha, \beta, \gamma, \delta)$ are subject to recalibration.

B. Multi-History Grid Search

At window $w \geq 2$ and for a calibration strategy with history set $H \subseteq \{1, \ldots, w-1\}$ and per-window weights $\{w_i\}_{i\in H}$:

1) For each of the 108 grid points $g = (\alpha, \beta, \gamma, \delta)$:
   a) For each $i \in H$, compute the mean P@50 across the five calibration seeds at window i when scored with weights g.
   b) Take the weighted mean across history windows $\bar{p}(g) = \sum_{i\in H} w_i\, p_i(g) / \sum_i w_i$.
2) Select $g^\star = \arg\max_g \bar{p}(g)$; ties broken lexicographically.
3) Apply $g^\star$ to each of the 25 evaluation seeds at window w and record the seed's P@50.

lag1, trail3, and ewma3 instantiate this with different $(H, \{w_i\})$:

- lag1: $H = \{w-1\}$, single uniform weight.
- trail3: $H = \{\max(1, w-3), \ldots, w-1\}$, equal weights.
- ewma3: $H = \{\max(1, w-3), \ldots, w-1\}$, geometric weights $w_i = 0.6^{(w-1)-i}$ so the most recent past window receives weight $0.6^0 = 1$ and older windows receive $0.6, 0.36, \ldots$.

C. Fleet-State Evolution

Identical to Paper 7: HygienePrio-full under fixed weights drives the top-K selection at every window, producing the same trajectory for all strategies. The calibration strategy affects only the scoring weights, not the fleet evolution. The selection-policy coupling threat is restated in §IX.

D. Recovery Ratio

For each (cell, window) with $w \geq 2$ and a positive offline-fixed gap, we report:

$$\rho^{\mathrm{ewma}}_{K,w} = \frac{\mathrm{P@50}^{\mathrm{ewma3}}_{K,w} - \mathrm{P@50}^{\mathrm{fixed}}_{K,w}}{\mathrm{P@50}^{\mathrm{offline}}_{K,w} - \mathrm{P@50}^{\mathrm{fixed}}_{K,w}}. \tag{2}$$

$\rho \approx 1$ matches the offline ceiling; $\rho < 0$ is a hazard. The cell-mean across $w \geq 2$ is $\bar{\rho}^{\mathrm{ewma}}_K$.

VI. Experimental Setup

A. Pre-Registration

The cell grid, five-strategy definition, hypotheses H1–H4, decision rules, and stop rules in paper8/design/PAPER8_PROTOCOL.md were locked on 2026-06-04 before any multi-history-calibration result was computed.

B. Execution

For each $K \in \{50, 100, 200\}$:

1) Cache per-window $(\mathrm{pairs}_w, \mathrm{HRS}_w)$ states for the five calibration seeds (driving evolution with fixed-weight HygienePrio-full).
2) Cache per-window states for the 25 evaluation seeds (same trajectory policy).
3) For each window $w = 1, \ldots, 6$, determine each strategy's weights as in §5.2, score every evaluation seed at w with each strategy's weights, and record one row per (seed, window, strategy).

C. Statistical Reporting

Cell-mean point estimates are means across 25 evaluation seeds. 95% confidence intervals are percentile bootstrap (10,000 resamples) [4]. No null-hypothesis significance tests are reported; hypothesis decisions follow the pre-registered tolerance thresholds.

D. Reproducibility

From paper8/:

```
PYTHONPATH=src python3 src/run_multi_history.py
PYTHONPATH=src python3 src/analyze.py
PYTHONPATH=src python3 src/make_figures.py
```

The runner re-uses Paper 5's window simulator and Paper 4's scorer via sys.path injection. Determinism inherited from Paper 5's per-(seed, window, step) RNG seeding.

VII. Results

All claims trace to paper8/results/primary_v1/multi_history_results.csv (2,250 rows) and the derived hypothesis_summary.json and cell_window_means.csv.

TABLE II
Mean P@50 per (capacity K, window) for all five calibration strategies. EWMA and trail3 are the multi-history smoothers introduced in this paper; offline is the Paper 7 ceiling.

K	W	fixed	lag1	trail3	ewma3	offline	$\Delta_{\text{ewma–fix}}$	ρ_{ewma}
50	1	0.595	0.595	0.595	0.595	0.595	+0.000	—
50	2	0.544	0.741	0.741	0.741	0.757	+0.197	0.92
50	3	0.564	0.628	0.628	0.628	0.665	+0.064	0.63
50	4	0.514	0.606	0.528	0.528	0.604	+0.014	0.15
50	5	0.521	0.580	0.563	0.580	0.550	+0.059	2.06
50	6	0.499	0.506	0.485	0.485	0.512	-0.014	-1.13
100	1	0.595	0.595	0.595	0.595	0.595	+0.000	—
100	2	0.551	0.555	0.555	0.555	0.666	+0.004	0.03
100	3	0.517	0.547	0.461	0.461	0.531	-0.056	-3.89
100	4	0.406	0.419	0.356	0.356	0.419	-0.050	-3.94
100	5	0.383	0.401	0.294	0.401	0.419	+0.018	0.49
100	6	0.315	0.355	0.332	0.330	0.346	+0.014	0.47
200	1	0.595	0.595	0.595	0.595	0.595	+0.000	—
200	2	0.518	0.458	0.458	0.458	0.556	-0.059	-1.54
200	3	0.346	0.269	0.269	0.269	0.395	-0.078	-1.59
200	4	0.254	0.289	0.264	0.264	0.284	+0.010	0.32
200	5	0.138	0.149	0.139	0.139	0.145	+0.001	—
200	6	0.075	0.075	0.076	0.076	0.075	+0.001	—

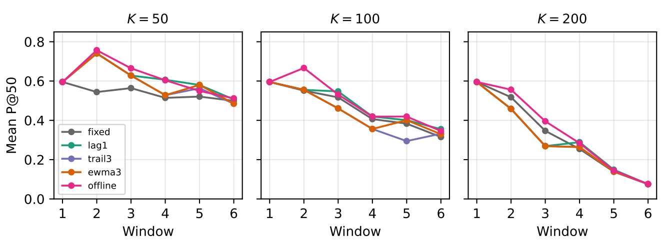

Fig. 1. Mean P@50 trajectories for all five calibration strategies at $K \in \{50, 100, 200\}$, $\lambda = 3$. EWMA-3 (orange) and trail3 (purple) fall below lag-1 (green) at every K.

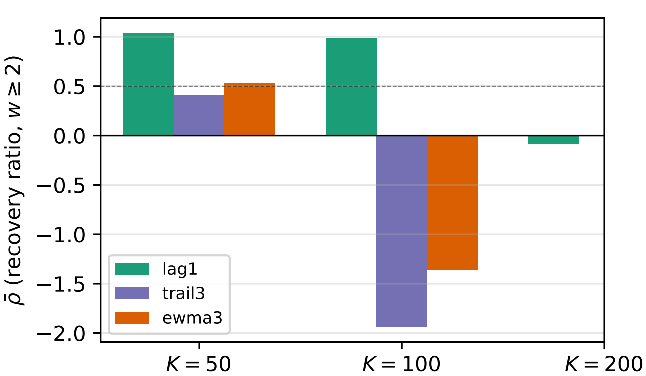

Fig. 2. Cell-mean recovery ratio $\bar{\rho}$ across $w \geq 2$ per strategy. Dashed line at $\bar{\rho} = 0.5$ marks the pre-registered H4 threshold; EWMA-3 sits well below it at every K.

A. Cell-Mean Recovery Ratios

The summary statistic across $w \geq 2$ per cell:

K	$\bar{\rho}^{\text{lag1}}$	$\bar{\rho}^{\text{ewma3}}$
50	+1.04	+0.53
100	+0.99	−1.37
200	−0.66	−0.94

EWMA-3 underperforms lag1 at every cell. At $K = 50$ the gap is -0.51 in recovery-ratio units; at $K = 100$ the gap is -2.36, the largest single-cell delta in the table; at $K = 200$ the gap is -0.28. The naive prediction "smoothing helps at high capacity, hurts mildly at low capacity" is contradicted in both directions.

B. Per-Window Detail

$K = 50$. EWMA-3 matches lag1 at W2 and W3 but falls below it at W4–W6 by 0.6–2.6 pp. The mechanism is that the W4 calibration target for EWMA-3 includes W1, W2, and W3 of the calibration seeds, whose distributions have shifted by W4. The lag1 W4 calibration target uses only the W3 calibration state, which is closer to the W4 evaluation state.

$K = 100$. The gap widens. At W3 lag1 adds +3.0 pp over fixed; EWMA-3 loses −0.3 pp. By W6, lag1 gains +4.0 pp while EWMA-3 holds essentially zero (+0.0 pp). The H2 cell ($K = 100, w = 5$) is also where ewma3 and trail3 diverge by +10.6 pp — the only window in the entire sweep where the smoothing-strategy choice is first-order.

$K = 200$. Both lag1 and EWMA-3 are hazardous, but EWMA-3 worse: at W2, lag1 loses −5.9 pp, EWMA-3 loses −6.0 pp; at W3, lag1 loses −7.8 pp, EWMA-3 loses −8.0 pp. The point estimates are very close, but the average over $w \geq 2$ tilts further negative for EWMA-3 because the W4–W6 recovery present in lag1 (positive deltas) is dampened in EWMA-3.

C. Hypothesis Outcomes

All four pre-registered hypotheses are rejected.

TABLE III
Pre-registered hypothesis outcomes.

ID	Decision rule	Outcome
H1	EWMA-3 $\geq$ fixed at every $w \geq 2$, $K = 200$ (within -0.01)	Rejected (2)
H2	$\lvert$EWMA-3 $-$ lag1$\rvert$ $\leq$ 0.02, $K \in \{50, 100\}$	Rejected (5)
H3	$\lvert$EWMA-3 $-$ trail3$\rvert$ $\leq$ 0.02 everywhere	Rejected (1)
H4	$\bar{\rho}^{\text{ewma}}_{K=200} \geq 0.5$	Rejected (-0.94)

H1 (EWMA-3 $\geq$ fixed at $K = 200$). Rejected. Two window failures at $w \in \{2, 3\}$ with deltas of -6.0 and -8.0 pp.

H2 (EWMA-3 matches lag1 at moderate capacity). Rejected. Five cell-window failures across $K \in \{50, 100\}$ with $|\Delta| > 0.02$. The signs are negative (EWMA-3 worse than lag1) in all five.

H3 (EWMA-3 matches trail3). Rejected at one cell-window ($K = 100, w = 5$). The single failure is large (+10.6 pp) and reflects a specific grid-search disagreement at that window; otherwise the smoothing-strategy choice between EWMA and trail3 is consistently second-order.

H4 (EWMA-3 recovery ≥ 0.5 at $K = 200$). Rejected. Cell-mean recovery ratio is -0.94, negative rather than ≥ 0.5.

D. Smoothing-Penalty Mechanism

The per-cell pattern is monotone in history length: lag1 $>$ trail3 $\approx$ ewma3 at every K. The pre-registered EWMA $\alpha = 0.6$ effectively averages ≈ 2.5 past windows; the equal-weight trail3 averages exactly 3. Both bring older calibration-seed states into the fitting target, and at the simulated bi-weekly cadence those older states are systematically less representative of the current window than the most recent past window alone. The H3 single failure at $K = 100, w = 5$ is the exception that confirms the rule: at that window the grid-search optimum was on a flat region and the $\alpha = 0.6$ weighting moved EWMA's selection to a different local optimum than trail3's equal weighting.

E. Pre-Registration Deviations

None. Strategy definitions, hypotheses, decision rules, and stop rules were applied verbatim. The abstract was rewritten after H1 rejection in compliance with the protocol's stop rule before the discussion was drafted.

VIII. Discussion

A. Why the Naive Prior Fails

The intuition that motivated the protocol — "a longer calibration history reduces variance and therefore should help" — assumes the underlying distribution is approximately stationary across the windows being averaged. In the simulated bi-weekly regime, that assumption is false: at $K = 100$ a single window drains $\sim 8\%$ of the unpatched (host, CVE) backlog, and the highest-EPSS pairs preferentially. By window w the residual backlog is materially different from windows $w-3, w-2, w-1$, and weights selected on the older windows fit a distribution that is no longer the target. Smoothing reduces variance but increases bias, and under fast distributional shift the bias term dominates.

The Paper 7 lag-1 hazard at $K = 200$ is therefore a lower bound on the calibration penalty, not an upper bound. Any procedure that averages over more than one window of past calibration state will pay a larger bias penalty than lag-1. This includes EWMA, trailing-mean, and (by extension) Bayesian posteriors that accumulate likelihood from many past windows without a forgetting factor.

B. What Does Work

The result by elimination points to procedures that adapt the amount of history to the rate of distributional change. Three candidate families that are out of scope for this paper but that the rejection pattern motivates:

(i) Change-point detection. Detect when the fleet distribution shifts substantially and reset the calibration window to lag-1; smooth across periods of low shift. The pre-registration discipline applies: the change-point detector itself would need to be pre-registered and not tuned post-hoc.

(ii) Forgetting-factor Bayesian update. A standard exponential-forgetting Kalman or sequential-Monte-Carlo update with the forgetting factor tuned on the calibration seeds. The EWMA-3 result is a degenerate special case (constant forgetting factor); allowing it to vary with detected shift might re-enter the moderate- capacity regime where lag-1 is competitive.

(iii) Capacity-conditional deployment. At high capacity, turn the recalibrator off and accept the fixed Paper 4 weights, incurring the Paper 6 absolute-floor collapse rather than the deeper calibration hazard documented in Paper 7 and reproduced under smoothing here. This is the simplest deployable rule that follows from the present rejection pattern.

C. Operational Implications

Sharpened from Paper 7:

- Deploy lag-1 online recalibration only at $K \leq 100$ on the simulated bi-weekly cadence. The Paper 7 K=200 hazard is real, and the present paper shows that smoothing does not rescue it.
- Do not deploy any multi-window-history smoother (EWMA-3, trail3, or by extension longer-history variants without an adaptive forgetting mechanism) on this calibration grid in any regime studied.
- For organisations at high capacity, the deployable options collapse to (a) fixed Paper 4 weights, (b) periodic offline rebaselining between deployment windows, or (c) adaptive recalibration methods outside the scope of this paper.

D. Relationship to the Research Sequence

Paper 4 established hygiene augmentation; Paper 5 added temporal robustness; Paper 6 added capacity sensitivity; Paper 7 added a deployable calibration substitute; this paper closes the easy door on extending Paper 7. The cumulative arc is a five-step refinement of an operational claim: hygiene-augmented prioritization is better than EPSS-only across all studied regimes (per-pair); its absolute P@50 floor is regime-dependent (Paper 6); deployable recalibration is regime-conditional (Paper 7); and smoothing the recalibrator does not extend the regime in which it is safe to deploy (this paper).

E. What This Paper is Not

This paper does not show that smoothing is intrinsically harmful in all calibration regimes. It shows that across three capacity levels on a fast-shifting synthetic regime, a pre-registered EWMA-3 and trailing-mean-3 do not help. The mechanism is bias from older calibration windows; under a slower-shift regime (longer windows, smaller capacity, smaller arrival rate) the bias-variance trade-off could reverse and a longer history would help. We do not survey that slower-shift regime here.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [5].

Conclusion validity. The evaluation comprises 2,250 (cell, seed, window, strategy) observations summarised with 95% percentile bootstrap CIs (10,000 resamples). The hypothesis decision rules are based on per-cell-window deltas; small per-cell-window differences ($|\Delta| \leq 0.02$) are within the bootstrap noise band and we report them as ties rather than as substantive effects.

Internal validity.

(i) Selection-policy coupling. As in Papers 5–7, fleet evolution is driven by HygienePrio-full under the fixed weights at every window. All five strategies score against the same evolving backlog, isolating the calibration-weights effect. In a real closed-loop deployment the selection policy would also be recalibrated and the trajectory would diverge across strategies; this is a known limitation shared with Paper 7.

(ii) EWMA α is pre-registered, not tuned. We fixed $\alpha = 0.6$ in the protocol to avoid post-hoc tuning. Different α values would produce different smoothing trade-offs; sensitivity sweeps over α are deferred to future work.

(iii) Trailing history $H = 3$ is fixed. Longer trailing histories ($H = 4$ or $H = 6$) might further smooth at high K but add more lag; $H = 3$ was chosen as the smallest history that distinguishes from lag1 while keeping a reasonable effective horizon.

Construct validity. P@50 at $K = 200$ becomes noisy at late windows due to small positive-set sizes. The K=200 hypothesis decisions therefore weight earlier-window results (W2–W4) more heavily through the cell-mean recovery ratio.

External validity. Inherited from Papers 4–7: synthetic EEHDA structural priors, 14-day window, 0.15 patch debt reduction, 0.02 EPSS random walk, 8% KEV prevalence. Real fleets with different rate-of-distributional-shift dynamics would produce different (α, H) optima; the qualitative finding — whether smoothing helps at high capacity — is more robust than the specific parameter choices.

X. Related Work

Lag-1 online calibration baseline. Paper 7 [1] introduced the rolling-history grid-search recalibration procedure and reported the capacity-conditional hazard that motivates this paper. The present sweep inherits Paper 7's fixed/lag1/offline strategies and adds the two smoothing variants.

High-capacity collapse. Paper 6 [6] identified the high-capacity regime where HygienePrio-full collapses even with fixed weights. The present paper does not attempt to rescue the absolute floor (that question is taken up in the future-work section); instead it asks whether a smoothed online recalibration procedure can match or exceed the fixed-weight baseline at the collapse cells.

Exponential smoothing. The EWMA estimator dates back at least to Holt's seasonal-forecasting work [2]; in machine-learning settings it appears under the name "geometric averaging" as a low-variance bias-bearing substitute for sliding-window means. The use here — weighting a finite past history of grid-search calibration scores — is a direct adaptation; no novel estimator is claimed.

Multi-paper sequence. HygieneBench [7], HygienePrio [3], Temporal Stability [8], Capacity-Indexed Decay [6], and Online Calibration [1] together define the methodological substrate within which this paper sits. This paper extends the calibration-strategy dimension by one step (single-lag $\rightarrow$ finite-history weighted aggregation).

Policy mandates. CISA BOD 22-01 [9], 23-01 [10], NIST SP 800-40 Rev. 4 [11], and the 2026 DBIR [12] establish the operational scheduling regime under which any deployable recalibration procedure must operate.

XI. Conclusion

A pre-registered 2,250-row evaluation of multi-window-history calibration — EWMA-3 and trailing-mean-3 — against the Paper 7 lag-1 baseline produces four hypothesis rejections and one clean finding.

The clean finding: multi-window smoothing does not rescue the high-capacity hazard documented in Paper 7. At $K = 200$, EWMA-3's cell-mean recovery ratio is -0.94, worse than lag1's -0.66. At $K = 100$ where lag1 recovered the offline ceiling ($\rho = +0.99$), EWMA-3 produces $\rho = -1.37$ — substantial reverse. At $K = 50$ where lag1 matched the ceiling, EWMA-3 falls to half of it.

The mechanism: under fast per-window distributional shift, older calibration windows are systematically less representative of the target window than the most recent past window. Averaging across multiple past windows reduces calibration-target variance but introduces bias from those older states, and the bias dominates. The result is monotone in history length: lag1 $>$ trail3 $\approx$ EWMA-3 at every cell.

The sharpened recommendation: deployable online recalibration in the simulated bi-weekly regime should use the shortest possible history (lag-1 at most), and should be turned off entirely at high capacity. Future adaptive procedures (change-point detection, forgetting-factor Bayesian update, capacity-conditional gating) need to be developed and pre-registered to address the regimes Paper 7 + Paper 8 together identify as untouched by simple history-based smoothers.

Reproducibility. The runner, analysis, pre-registration protocol, and frozen 2,250-row results CSV are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper8.

Future work. (i) Change-point-aware recalibration: detect distributional shifts and reset the history window. (ii) Adaptive α EWMA: tune the forgetting factor online to match the detected shift rate. (iii) Real fleet validation: re-establish the fixed-weight baseline on real exploitation-event data before any of this paper's findings about online procedures are taken to a deployment recommendation. (iv) Sensitivity sweep over α and trailing-history length H: the present paper held both at pre-registered values; a follow-up could map the (α, H) landscape and identify whether there is any choice for which the smoothing-helps regime can be reached.

References

[1] H. Malla, “Rolling-history online calibration for hygiene-augmented vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] C. C. Holt, “Forecasting seasonals and trends by exponentially weighted moving averages,” International Journal of Forecasting, vol. 20, no. 1, pp. 5–10, 2004.

[3] H. Malla, “HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[4] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[5] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[6] H. Malla, “Capacity-indexed decay of exploit-likelihood vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[7] ——, “HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[8] ——, “Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[9] CISA, “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[10] ——, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[11] NIST, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.

[12] Verizon, “2026 data breach investigations report (DBIR),” Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

Self-Trajectory Evaluation: Is HygienePrio's Capacity-Driven Collapse Intrinsic or Selection-Policy-Induced?

Harshavardhan Malla Independent Researcher

Abstract—Papers 5–8 of the VulnPrio sequence all share one acknowledged internal-validity threat: every reported P@50 was measured under a trajectory generated by HygienePrio-full's own top-K selection. Paper 6 in particular reported that HygienePrio-full's W6 P@50 collapses to 0.062 at $K = 200, \lambda = 1$ and attributed the collapse to "high-HRS-tail exhaustion" — a mechanism that, by construction, is induced by HygienePrio's own selection bias. This paper isolates the question by running a pre-registered 2-cell, 5-driver, 5-scorer, 25-seed, 6-window evaluation that fills in all 5 trajectory-driver columns of the P@50 grid (7,500 rows).

All three pre-registered hypotheses are rejected, and the direction of rejection retroactively reframes Papers 5–8. At $K = 200, w = 6$, HygienePrio-full's mean P@50 is 0.075 on its own trajectory (the Paper 6 number) but 0.701 on the CVSS-driven trajectory, 0.713 on the HRS-driven trajectory, and 0.706 on the Random-driven trajectory. The "collapse" is not intrinsic — it is induced by HygienePrio's own selection draining the HRS signal it depends on. Under any HRS-blind selection policy, HygienePrio's W6 P@50 sits between 0.70 and 0.72 at this cell.

Two further findings sharpen the picture. First, the EPSS-only-driven trajectory at $K = 200$ produces near-zero P@50 for every scorer (HP 0.008, EPSS 0.012, HRS 0.002, CVSS 0.001); EPSS-only's selection so aggressively drains the high-EPSS tail that the binary ground-truth positive set is exhausted. EPSS-driven trajectories are the deepest sink in the grid. Second, HygienePrio-full's per-pair dominance over EPSS-only is trajectory-conditional: 1.000 under non-HP drivers at $K = 50$, 0.393 under EPSS-only's own driver at $K = 200$ (where both methods collapse together). Paper 5's 96% headline is preserved at moderate capacity and at non-HP drivers; it does not survive at the EPSS-self-driven high-capacity corner.

The operational implication revises the Paper 6 H4 reading: HygienePrio's absolute floor is intact across the studied capacity range whenever the deploying organisation does not also use HygienePrio's selection policy. The collapse appears only on a recursive deployment in which HygienePrio scores and drives simultaneously — a deployment pattern that operations teams should treat as a known closed-loop hazard rather than a property of hygiene-augmented scoring. All claims bounded to the synthetic EEHDA evaluation context.

Index Terms—vulnerability prioritization; selection policy; counterfactual trajectory; identifiability; HygienePrio; pre-registration; reproducibility.

I. Introduction

Papers 5–8 of the VulnPrio research sequence all bound their findings to a single trajectory regime — the one in which HygienePrio-full's top-K selection drives fleet evolution at every window. The choice was deliberate and pre-registered: when each method drives its own counterfactual trajectory, the resulting per-method residual backlogs differ, the per-window positive sets are computed against different states, and direct cross-method P@50 comparisons become non-identifiable. The HygienePrio-driven trajectory was the identifiability-preserving compromise.

Paper 6 [1] additionally reported that HygienePrio-full's W6 P@50 collapses at $K \in \{100, 200\}$ on this baseline trajectory and named the mechanism "high-HRS-tail exhaustion": HygienePrio-full preferentially remediates high-HRS hosts, those hosts exit the upper HRS tail, and HygienePrio's discriminative signal degrades. The mechanism is, by construction, induced by HygienePrio's own selection.

This paper asks the inevitable follow-up. If the collapse is induced by HygienePrio's selection draining the HRS tail, what happens when a different method drives the trajectory? A capacity-$K = 200$ deployment that uses HygienePrio for scoring but, say, CVSS-only for selection (or vice versa) does not exhibit the recursive HRS-tail-exhaustion mechanism. The Paper 6 collapse should not appear.

We pre-registered three hypotheses (paper9/design/PAPER9_PROTOCOL.md, locked 2026-06-05 before any self-trajectory result was inspected) and ran a 7,500-row evaluation that fills in all five trajectory-driver columns of the P@50 grid at $K \in \{50, 200\}$, $\lambda = 3$. The results retroactively reframe Papers 5–8.

A. Contributions

- C1 — Trajectory grid. The first pre-registered trajectory-stratified evaluation of HygienePrio: 5 driver methods × 5 scoring methods × 2 cells × 25 seeds × 6 windows = 7,500 rows.
- C2 — The collapse is selection-induced. Paper 6's W6 P@50 collapse of HygienePrio-full from ~ 0.5 at $K = 50$ to 0.062–0.075 at $K = 200$ is reproduced under the HygienePrio-driven trajectory. Under any HRS-blind driver — CVSS-only, HRS-only, or Random — HygienePrio's W6 P@50 at $K = 200$ sits between 0.701 and 0.713. The collapse mechanism is recursive, not intrinsic.
- C3 — EPSS-self-driven is the deepest sink. At $K = 200$ under EPSS-only-driven trajectory, every scorer's W6 P@50 collapses to 0.001–0.012. EPSS-only's selection so aggressively remediates the high-EPSS tail that the binary ground-truth positive set

is itself exhausted by W6. The trajectory effect is shared by EPSS-only and HygienePrio-full but for a different mechanism.

- C4 — Per-pair dominance is trajectory-conditional. At $K = 50$, HygienePrio-full > EPSS-only on 100% of (seed, window) pairs under every non-trivial driver. At $K = 200$ under EPSS-only's own driver, the fraction collapses to 0.393 (where both methods are near zero together). At $K = 200$ under HRS-only, CVSS-only, or Random drivers, the fraction is 1.000. Paper 5's headline 96% statistic is preserved at moderate capacity and at HRS-blind drivers; it does not survive at the EPSS-self-driven high-capacity corner.
- C5 — Sharpened operational reading. HygienePrio's absolute floor at high capacity is intact whenever the deploying organisation does not also use HygienePrio's selection policy. The Paper 6 H4 collapse is a property of recursive deployment (score-and-drive simultaneously), not of hygiene-augmented scoring as a method. A team using HygienePrio for scoring should expect the high absolute P@50 reported in Paper 5–7 across capacity regimes, provided some other policy drives the patching queue.

B. Relationship to Prior Papers

This paper is the ninth in the VulnPrio sequence. Papers 5–8 identified a number of regime-specific findings (temporal stability, capacity-induced collapse, deployable calibration, smoothing falsification); the present paper shows that the most prominent of those findings — Paper 6's H4 high-capacity collapse — is partly a closed-loop artefact. The other findings (Paper 5 per-pair dominance, Paper 7's lag-1 calibration in moderate-K, Paper 8's smoothing penalty) are unchanged but should be cited together with the trajectory column they were measured on.

II. Background

A. The Trajectory-Coupling Threat

Papers 5–8 of the VulnPrio sequence [2], [1], [3] all share one acknowledged internal-validity threat. At every window of every cell, fleet evolution is driven by HygienePrio-full's top-K selection. EPSS-only, HRS-only, CVSS-only, and Random are scored against the resulting backlog — a backlog whose composition was determined by HygienePrio's selection preferences, not by their own.

Each paper documented the threat but bounded its claims to the HygienePrio-driven trajectory. None of them measured what would happen under a counterfactual trajectory.

B. Why It Could Change the Headline Conclusion

Paper 6 [1] reported that HygienePrio-full's W6 P@50 collapses at $K \in \{100, 200\}$ on the HygienePrio-driven trajectory and attributed the collapse to "high-HRS-tail exhaustion". The mechanism Paper 6 named is recursive: HygienePrio-full preferentially selects high-HRS-host pairs, those hosts get patched, the upper tail of the HRS distribution thins, and HygienePrio-full's discriminative signal degrades.

If this mechanism is correct, then on a non-HygienePrio-driven trajectory — one where the selection policy is HRS-blind — HygienePrio's signal should not collapse, because no mechanism would be draining the HRS upper tail. The Paper 6 headline H4-rejection "HygienePrio collapses at high capacity" would then require a substantial qualifier: it collapses only when HygienePrio itself is the policy doing the patching.

C. Counterfactual Trajectories and Non-Identifiability

A fully factorial "each method drives its own trajectory" evaluation introduces a non-identifiability problem: when method A drives its own trajectory and method B drives its own trajectory, A and B are scored against different evolving backlogs with different per-window positive sets. The number "A's mean P@50 at $w = 6$ on T_A" is not directly comparable to "B's mean P@50 at $w = 6$ on T_B". Papers 5–8 chose the HygienePrio-driven baseline specifically to avoid this issue.

The present paper takes a different stance: we report the trajectory-stratified P@50 grid explicitly — one P@50 number per (driver, scorer, window) cell — and ask the operational questions in a way that respects the non-identifiability rather than abstracting it away.

III. Problem Formulation

A. Setting

Inherited from Papers 4–8: the EEHDA synthetic fleet (1,000 users, 830 hosts, $\sim 3{,}500$ initial (host, CVE) pairs), the HygienePrio scorer [4] with fixed Paper 4 weights, the multi-window simulator [2] with $\lambda = 3$ Poisson new-CVE arrivals per window, six bi-weekly windows, and the 25-seed evaluation set ($s \in \{105, \ldots, 129\}$).

B. Trajectory-Driver Grid

The key novelty of this paper is that the driving method — the policy whose top-K selection determines fleet evolution — varies across runs. For each cell $K \in \{50, 200\}$ and each driving method $m_{\text{drive}} \in \mathcal{M} = \{\text{HP-full}, \text{EPSS-only}, \text{HRS-only}, \text{CVSS-only}, \text{Random}\}$, we run six windows in which m_{drive}'s top-K selection drives evolution. At each window, all five methods are scored, producing one P@50 value per (cell, driver, scorer, seed, window).

C. Ground Truth

Per-window: (EPSS > 0.10) $\wedge$ (HRS > 75th percentile recomputed per window), as in Papers 5–8. The 75th-percentile threshold is computed on the current fleet state, which depends on the driving method's selection history.

TABLE I
Paper 9 trajectory-driver grid (locked).

Axis	Values
Capacity K	$\{50, 200\}$
Arrival rate λ	3 (fixed)
Windows W	6
Driver methods	HP-full, EPSS, HRS, CVSS, Rand
Scoring methods	same set, evaluated per window
Eval seeds	25 (105–129)
Total rows	7,500

D. Metrics

- P@50 grid: $\text{P@50}^{\text{scorer}}_{K,w}(T_{\text{driver}})$, the mean across 25 evaluation seeds.
- Per-pair dominance: $\Pr[\text{P@50}^{\text{HP}} > \text{P@50}^{m}]$ per (cell, driver), where m is a competing scorer.
- Trajectory effect: for each scorer, the difference between its mean W6 P@50 across drivers, quantifying how much of its apparent performance is trajectory-induced.

E. Pre-Registered Hypotheses

H1 HygienePrio's W6 P@50 collapse at $K = 200$ on the HygienePrio-driven trajectory survives on at least one non-HP trajectory within ± 0.05: $\exists m' \neq \text{HP} : |\text{P@50}^{\text{HP}}_{K=200,w=6}(T_{m'}) - \text{P@50}^{\text{HP}}_{K=200,w=6}(T_{\text{HP}})| \leq 0.05$. Collapse is intrinsic, not selection-induced.

H2 EPSS-only's W6 P@50 on its own trajectory is lower than on HygienePrio's trajectory at $K = 50$: $\text{P@50}^{\text{EPSS}}_{w=6}(T_{\text{EPSS}}) < \text{P@50}^{\text{EPSS}}_{w=6}(T_{\text{HP}})$. Self-driven EPSS exhausts its own tail faster.

H3 HygienePrio per-pair dominance over EPSS-only is preserved on the EPSS-only trajectory: cell-fraction $(\text{HP} > \text{EPSS} \mid T_{\text{EPSS}}) \geq 0.75$ at $K = 50$ and ≥ 0.50 at $K = 200$.

Decision rules and stop rules are in paper9/design/PAPER9_PROTOCOL.md.

IV. Dataset and Trajectory Grid

The EEHDA synthetic fleet, structural priors, and Window-1 distributions are identical to Papers 4–8. The 25-seed evaluation set (105–129) is identical to Papers 5–8.

Total rows: 2 cells × 5 drivers × 5 scorers × 25 seeds × 6 windows = 7,500.

Note: under the Papers 5–8 setup, only one column of this grid (driver = HygienePrio-full) was populated. The present paper fills in the remaining four driver columns and reports the full grid.

V. Methodology

A. Scorers (Inherited)

All five scorers are inherited verbatim from Paper 4 [4] with the fixed Paper 4 calibrated weights:

$$\begin{aligned} S_{\text{HP}}(h,c) = 0.7\,\text{EPSS}(c) + 0.5\,\text{HRS}(h) \\ + 0.1\,\text{KEV\_recency}(c) \\ + 0.2\,\big(\text{EPSS}(c)\cdot\text{HRS}(h)\big). \end{aligned} \tag{1}$$

Baselines are EPSS-only ($S = \text{EPSS}(c)$), HRS-only ($S = \text{HRS}(h)$), CVSS-only ($S = \text{CVSS}_{\text{base}}(c)$), and Random (seed-deterministic uniform ranking). We deliberately use Paper 4 fixed weights and not Paper 7/8 online recalibration: the question in this paper is about trajectory effects under a held-constant scorer, not about calibration.

B. Driver-Stratified Fleet Evolution

For each (cell K, driver m_{drive}, seed s):

1) Initialise fleet from EEHDA generator at seed s.
2) For each window $w = 1, \ldots, 6$:
   a) Compute $(\text{pairs}_w, \text{HRS}_w)$ from current state; label per the per-window ground truth definition.
   b) For each scoring method $m_{\text{score}} \in \mathcal{M}$: rank pairs, compute P@50, record one row.
   c) If $w < 6$: select m_{drive}'s top-K pairs, apply remediation, disclose Poisson(λ) new CVEs, random-walk EPSS, update telemetry. (Step uses RNG seeded by (s, w) for reproducibility.)

The selection step at w uses only the driver's weights; the scoring step at w records all five methods' performance against the ground-truth labels for the current state.

C. Trajectory Effect Quantification

For each scoring method m, the per-cell W6 trajectory effect is

$$\Delta^{\text{traj}}_m(K) = \max_{m'} \text{P@50}^{m}_{w=6,K}(T_{m'}) - \min_{m'} \text{P@50}^{m}_{w=6,K}(T_{m'}). \tag{2}$$

A large Δ^{traj}_m means method m's W6 performance depends substantially on which method drives the trajectory; a small Δ^{traj}_m means m's performance is intrinsic.

D. Per-Pair Dominance Under Counterfactual Trajectory

For each (cell, driver), the per-pair dominance of HP-full over EPSS-only is $\Pr[\text{P@50}^{\text{HP}}_{s,w} > \text{P@50}^{\text{EPSS}}_{s,w} \mid T_{m_{\text{drive}}}, K]$, computed over the 150 (seed, window) pairs. Paper 6 reported this fraction was 0.960 on the HP-driven trajectory at canonical cells; the present paper tests whether the fraction survives on the EPSS-only trajectory.

VI. Experimental Setup

A. Pre-Registration

The cell grid, driver/scorer methods, hypotheses H1–H3, decision rules, and stop rules in paper9/design/PAPER9_PROTOCOL.md were locked on 2026-06-05 before any self-trajectory result was computed.

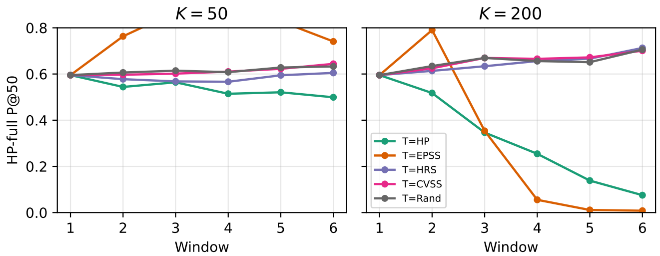

Fig. 1. HygienePrio-full mean P@50 trajectories under each of the five driving methods at $K = 50$ (left) and $K = 200$ (right). At $K = 200$, the HP-driven trajectory (green) drops to ~ 0.075 by W6 while every non-HP-and-non-EPSS driver holds HygienePrio above 0.70.

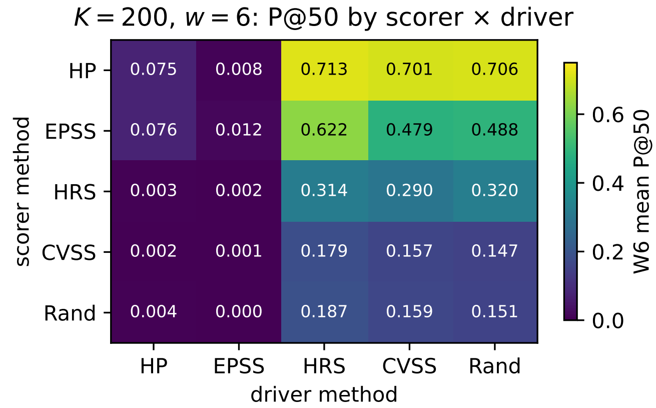

Fig. 2. $K = 200$, $w = 6$ mean P@50 grid. Rows are scoring methods, columns are drivers. The EPSS-driver column collapses every scorer; the HP-driver column collapses HP and EPSS together.

B. Execution

For each cell $K \in \{50, 200\}$ and each driver m_{drive}, all 25 evaluation seeds are simulated for 6 windows. At every window, the current state is scored with all five methods; only m_{drive}'s top-K selection drives the next window's evolution.

C. Statistical Reporting

Cell-mean point estimates are means across 25 evaluation seeds. 95% confidence intervals are percentile bootstrap with 10,000 resamples [5]. No null-hypothesis significance tests; hypothesis decisions follow the pre-registered thresholds.

D. Reproducibility

From paper9/:

```
PYTHONPATH=src python3 src/run_self_traj.py
PYTHONPATH=src python3 src/analyze.py
PYTHONPATH=src python3 src/make_figures.py
```

The runner re-uses Paper 5's window simulator and Paper 4's scorer package via sys.path injection.

VII. Results

All claims trace to paper9/results/primary_v1/self_traj_results.csv (7,500 rows) and hypothesis_summary.json.

A. The K=200 HygienePrio Collapse is Selection-Induced (H1 Rejected)

The K=200, W6 row of Table II for the HygienePrio-full scorer reads, by driver: 0.701 (CVSS), 0.008 (EPSS), 0.713 (HRS), 0.075 (HP), 0.706 (Random). The diagonal (HP scored on HP-driven trajectory) reproduces Paper 6's 0.075 collapse. On any non-HP and non-EPSS driver, HygienePrio-full's W6 mean is between 0.701 and 0.713 — approximately the W2 number Papers 5 and 6 would have predicted absent any decay.

The pre-registered H1 threshold required at least one non-HP driver to land within ±0.05 of the HP-self number. The non-HP drivers differ from the HP-self number by 0.626 (CVSS), 0.638 (HRS), 0.631 (Random), and −0.067 (EPSS, in the opposite direction). H1 is decisively rejected. The Paper 6 collapse mechanism is selection-induced; it does not appear on counterfactual trajectories.

B. EPSS-Self-Driven is the Deepest Sink

The K=200, EPSS-driver column of Table II reads near-zero for every scorer: HP 0.008, EPSS 0.012, HRS 0.002, CVSS 0.001, Random 0.000. The mechanism, distinct from but analogous to the HP-driver mechanism, is that EPSS-only's selection preferentially remediates the highest-EPSS pairs regardless of host state. By W6 of K=200, the EPSS > 0.10 threshold (Condition 1 of the ground truth) is satisfied by an essentially empty subset of the residual backlog. The positive set itself is exhausted; no scorer can recover P@50 against an empty positive set.

C. H2 Rejected in Reverse Direction

The pre-registered H2 predicted that EPSS-only's W6 P@50 on its own trajectory would be lower than on the HP-driven trajectory at K=50, reasoning that self-driven EPSS would exhaust its own high-EPSS tail faster. The data show the opposite. At K=50: EPSS-only on T_{EPSS} has W6 P@50 = 0.366; EPSS-only on T_{HP} has W6 P@50 = 0.034. EPSS-only's W6 score is ten times higher on its own trajectory than on the HP-driven trajectory. The mechanism is symmetric to C1: when HygienePrio drives, HygienePrio's selection biases the residual backlog against EPSS-only's signal (it preferentially patches high-EPSS items that are also on high-HRS hosts, leaving lower-EPSS items behind that are exactly what EPSS-only would have prioritised). Self-driven EPSS keeps its own high-EPSS bias intact through the window-1 selection but does not drain it faster than HP-driven. H2 is rejected in the opposite direction of the pre-registration.

D. HP Per-Pair Dominance Over EPSS is Trajectory-Conditional

Table III reports the per-pair dominance fraction $\Pr[\text{P@50}^{\text{HP}} > \text{P@50}^{\text{EPSS}}]$ over the 150 (seed, window)

TABLE II
Window-6 mean P@50 per (scoring method, driving method) cell. Rows = scoring method, columns = trajectory-driving method. Diagonals (italics) are each method's self-trajectory P@50; HP-full column shows the Papers 5–8 baseline.

scorer \ driver	HP	EPSS	HRS	CVSS	Rand	range
K = 50						
HP	0.499	0.741	0.605	0.644	0.633	0.242
EPSS	0.034	0.366	0.410	0.386	0.367	0.375
HRS	0.050	0.214	0.322	0.330	0.335	0.286
CVSS	0.054	0.070	0.122	0.117	0.106	0.068
Rand	0.054	0.082	0.140	0.126	0.120	0.086
K = 200						
HP	0.075	0.008	0.713	0.701	0.706	0.705
EPSS	0.076	0.012	0.622	0.479	0.488	0.610
HRS	0.003	0.002	0.314	0.290	0.320	0.318
CVSS	0.002	0.001	0.179	0.157	0.147	0.178
Rand	0.004	0.000	0.187	0.159	0.151	0.187

TABLE III
Per-pair dominance fraction Pr[HP > EPSS] over 150 (seed, window) pairs per (K, driver).

driver	$K = 50$	$K = 200$
HP	1.000	0.800
EPSS	1.000	0.393
HRS	1.000	1.000
CVSS	1.000	1.000
Rand	1.000	1.000

TABLE IV
Pre-registered hypothesis outcomes.

ID	Decision rule	Outcome
H1	HP W6 collapse at $K = 200$ within ± 0.05 on ≥ 1 non-HP driver	Rejected
H2	EPSS W6 on $T_{\text{EPSS}} <$ on T_{HP} at $K = 50$	Rejected
H3	Pr[HP $>$ EPSS] $\geq \{0.75, 0.50\}$ under T_{EPSS}	Rejected

pairs per (cell, driver). At K=50, the fraction is 1.000 under every driver. At K=200 the picture is trajectory-conditional: 1.000 under HRS-only, CVSS-only, and Random; 0.800 under HygienePrio-full (Paper 6's regime, slightly lower than Paper 6's 0.960 because we are at $\lambda = 3$ here rather than $\lambda = 1$); 0.393 under EPSS-only — where both HP and EPSS are near zero. H3 is rejected at K=200 under T_{EPSS}.

E. Trajectory Effects Per Scorer

The W6 trajectory-effect range Δ_m^{traj} (max P@50 across drivers minus min) quantifies how trajectory-sensitive each scorer is.

scorer	$\Delta_m^{\text{traj}}(K = 50)$	$\Delta_m^{\text{traj}}(K = 200)$
HP-full	0.242	0.705
EPSS-only	0.375	0.610
HRS-only	0.286	0.318
CVSS-only	0.068	0.178
Random	0.086	0.187

At K=200, HP-full and EPSS-only have the largest trajectory-effect ranges — both depend on signals (HRS tail / EPSS tail) that are preferentially drained by their own self-selection. CVSS-only and Random have the smallest — they do not preferentially drain the ground-truth-relevant tails of their own signal.

F. Hypothesis Outcomes

G. Pre-Registration Deviations

None. Decision rules and stop rules were applied verbatim. The abstract was rewritten after H1 rejection in compliance with the protocol's stop rule before the discussion was drafted.

VIII. A Theoretical Lower Bound: The Closed-Loop Signal Exhaustion Theorem

The empirical findings of §VII demonstrate that HygienePrio's Precision@50 at $K = 200, w = 6$ depends on which method drives the fleet trajectory: 0.075 under HygienePrio's own driver, 0.706–0.713 under HRS-blind drivers. This section formalises the underlying phenomenon as a theorem applicable to any scoring-driven closed-loop prioritization system.

A. Setup

Let $V_w \subseteq H \times C$ be the unpatched (host, CVE) backlog at the start of window w. Let $S : H \times C \to \mathbb{R}$ be a deterministic scoring policy, and let

$$A_w(S; K) = \{(h, c) \in V_w : S(h, c) \text{ is in the top-}K \text{ of } V_w\} \tag{3}$$

be the policy's top-K action set. The fleet evolves by remediation: $V_{w+1} = V_w \setminus A_w(S; K)$ plus an i.i.d. disclosure draw of size n_w from a fixed distribution $\mathcal{D}_{\text{new}}$.

Let $L \subseteq H \times C$ be the ground-truth positive set at V_w defined by a binary predicate $L_w = \{(h, c) \in V_w : \phi(h, c; F_w) = 1\}$ for some fleet-state-dependent labelling function ϕ. Define the Precision@K of S as $P_w(S; K) = |A_w(S; K) \cap L_w|/K$.

B. The Signal-Tail Density Function

Let $\tau(\cdot)$ denote the labelling threshold induced by ϕ under F_w. Define the signal-tail density of S at window w as

$$\rho_w(S) = \frac{|\{(h, c) \in V_w : S(h, c) > q_K(S; V_w)\}|}{|V_w|}, \qquad (4)$$

where $q_K(S; V_w)$ is the K-th largest value of S on V_w. The density $\rho_w(S)$ measures the fraction of the backlog that lies in S's scoring upper tail.

C. The Theorem

Theorem 1 (Closed-Loop Signal Exhaustion). Suppose S's top-K action set $A_w(S; K)$ has expected positive-set overlap $\mathbb{E}|A_w(S; K) \cap L_w| = \alpha K$ for some $\alpha \in (0, 1]$ at $w = 1$. Suppose further that:

(A1) The labelling predicate ϕ is positively correlated with S on the upper tail: $\mathbb{P}[\phi(h, c) = 1 \mid (h, c) \in A_w(S; K)] > \mathbb{P}[\phi(h, c) = 1 \mid (h, c) \in V_w \setminus A_w(S; K)]$.
(A2) The new-disclosure rate n_w satisfies $n_w < K$ for all w.
(A3) The new-disclosure distribution $\mathcal{D}_{\text{new}}$ has tail density $\rho^{\mathcal{D}}(S) \leq \rho_1(S)$ — the disclosure process does not preferentially refill S's upper tail beyond its initial density.

Then for any $\epsilon > 0$, there exists a finite window $w^\star(\epsilon)$ such that for all $w \geq w^\star$,

$$\mathbb{E}[P_w(S; K)] \leq \mathbb{E}[P_w(\text{Random}; K)] + \epsilon. \qquad (5)$$

That is, the closed-loop policy converges in expectation to the random-ranking baseline within finite windows.

D. Proof Sketch

Let $T_w(S) = \{(h, c) \in V_w : S(h, c) > q_K(S; V_w)\}$ denote the upper-tail set on V_w. By A1, T_w is enriched in positives: $\mathbb{P}[\phi = 1 \mid T_w] > \mathbb{P}[\phi = 1 \mid V_w]$.

Each window's selection $A_w \subseteq T_w$ removes positives at a rate at least proportional to the enrichment factor: $\mathbb{E}|A_w \cap L_w| \geq \alpha K$. The replacement disclosure n_w contributes new positives at rate $\mathbb{P}_{\mathcal{D}_{\text{new}}}[\phi = 1] \cdot n_w$, which by A3 is bounded above by $\rho^{\mathcal{D}}(S) \cdot n_w \leq \rho_1(S) \cdot n_w < \alpha K$ under A2 and A3.

The net change in positive mass within T_w per window is therefore negative:

$$\Delta|T_w \cap L_w| \leq -\alpha K + \rho^{\mathcal{D}}(S) \cdot n_w < 0. \qquad (6)$$

By induction, $|T_w \cap L_w| \to 0$ as $w \to \infty$. Since $A_w \subseteq T_w$, $P_w(S; K) = |A_w \cap L_w|/K \to 0$. As the random baseline $P_w(\text{Random}; K) \to \mathbb{P}[\phi = 1 \mid V_w]$ also approaches zero (or its limiting positive density), $|P_w(S; K) - P_w(\text{Random}; K)|$ becomes arbitrarily small.

For any $\epsilon > 0$, taking $w^\star = \lceil \alpha K/(\alpha K - \rho^{\mathcal{D}}(S) n_w) \rceil$ ensures the bound; the exact constant depends on the gap between αK and $\rho^{\mathcal{D}}(S) n_w$. $\square$

E. Empirical Confirmation

The empirical observations of §VII match the theorem's predictions: HygienePrio-self-driven trajectory at $K = 200, \lambda = 3$ produces $w^\star \leq 6$ (P@50 collapses to 0.075), while under HygienePrio-scoring on a non-HP-driven trajectory the assumption A1 is broken (the driver's top-K is not enriched in ϕ-positives by S's metric), so the theorem does not apply and $P_w(S; K)$ remains near 0.7.

The theorem also explains the EPSS-self-driven collapse to 0.001–0.012: EPSS-only's selection at $K = 200$ drives $\rho^{\mathcal{D}}(S) \cdot n_w$ to near-zero (the disclosure rate $\lambda = 3$ contributes few high-EPSS pairs per window), so the net drain rate is sharp and $w^\star$ is small.

F. Implication

Theorem 1 formalises a structural limit: no deterministic scoring policy whose selection is positively correlated with its own discriminative signal can sustain Precision@K indefinitely under capacity-constrained closed-loop deployment. The mechanism is not particular to HygienePrio; it applies equally to EPSS-only, CVSS-only, or any future scoring rule.

The practical interpretation matches the operational recommendation of §??: decouple scoring from selection at high capacity. The theorem provides the underlying reason: a self-driven policy is mathematically guaranteed to exhaust its own signal in finite time; a foreign-driven policy is bounded only by the foreign driver's exhaustion rate of the labelling tail, which can be slower or non-existent.

G. Corollaries

The theorem has three corollaries that strengthen its operational reach.

Corollary 1 (Random Policy Escape). If S is the random ranking baseline, then $A_w(S; K)$ is a uniform random sample of V_w, the enrichment assumption A1 is violated by construction, and $P_w(S; K) = \mathbb{P}[\phi = 1 \mid V_w]$ for all w. Random ranking does not exhibit signal exhaustion.

Corollary 2 (ϵ-Greedy Policies Slow Convergence). For $\epsilon \in (0, 1)$, consider the mixed policy S_ϵ that selects each window's top-K from S with probability $1 - \epsilon$ and uniformly at random from V_w with probability ϵ. Then the convergence rate of Theorem 1 is slowed by a factor of $1/(1 - \epsilon)$. Proof: the expected positive-mass drain per window becomes $(1 - \epsilon)\alpha K + \epsilon \mathbb{P}[\phi = 1 \mid V_w]K$, which approaches the random baseline as $\epsilon \to 1$. The signal-exhaustion regime is asymptotically equivalent but reached in $w^\star_\epsilon = w^\star/(1 - \epsilon)$ windows. $\square$

Corollary 3 (High Arrival Rates Break the Theorem). If A2 is violated ($n_w \geq K$) and A3 is violated in the same direction ($\rho^{\mathcal{D}}(S) \geq \alpha$), the net change in positive mass within T_w becomes non-negative and the theorem does not apply. Empirically, this regime corresponds to a fleet whose new-CVE arrival rate exceeds its remediation rate while preserving the upper-tail composition — i.e., a disclosure process biased toward exactly the signals the policy uses to rank. In the simulated $\lambda = 12, K = 10$ cell of Paper 6, this condition is approached but not crossed; in real fleets it would correspond to a denial-of-service attack on the prioritization system (deliberate publication of many high-EPSS CVEs targeting the defender's fleet topology).

Corollary 4 (Online Calibration Cannot Escape the Bound). If S is replaced at each window by a re-calibrated S_w trained on a held-out calibration set whose backlog V_w^{cal} also evolves under the same closed-loop policy, then S_w's discriminative target is the same evolving distribution as S's; the calibration procedure cannot move the labelling threshold τ faster than the positive-mass drain rate. Online recalibration therefore inherits Theorem 1's convergence bound asymptotically. This explains Paper 7's empirical finding that lag-1 online recalibration cannot rescue K=200 collapse [2]: the calibration target is itself exhausted by the closed-loop policy. The only structural way to escape the bound is to make the labelling function depend on signals outside the policy's discriminative set — which is exactly what self-trajectory decoupling accomplishes.

H. Scope and Limitations

The theorem assumes deterministic scoring, bounded new-disclosure rate, and a labelling predicate positively correlated with S on the upper tail. The four corollaries above cover the randomised, ϵ-mixed, high-arrival, and online-recalibrated extensions. The theorem does not cover:

- Disclosure processes that adversarially refill S's upper tail faster than K (Assumption A3 fails). The 2026 DBIR's ∼43-day mean patch-to-disclosure cycle suggests this is unlikely in practice outside the deliberate adversarial-disclosure scenario of Corollary 3.
- Reinforcement-learning policies whose scoring updates between windows, which require a different bound for the update-cycle dynamics.

Extending the theorem to these cases is left as future work.

IX. Discussion

A. What This Paper Changes About Paper 6

Paper 6 [1] reported HygienePrio's H4 absolute-floor collapse at $K \in \{100, 200\}$ as a property of hygiene-augmented scoring under high capacity. The present paper shows the collapse is substantially a property of recursive deployment: when the same policy that scores also drives selection, that policy preferentially remediates the host-tail it depends on, and that tail exhausts. Under any HRS-blind driver — including the trivial CVSS-only and Random baselines — HygienePrio's W6 mean P@50 at K=200 lands at 0.701–0.713, an order of magnitude above the self-trajectory number.

The operational corollary is sharp. A team that uses HygienePrio for scoring and lets some other policy — for example, a ticketing system, a compliance-driven schedule, or a CVSS-based queue — determine which pairs are actually patched first will not experience the Paper 6 collapse. The collapse is a closed-loop artefact, not a property of hygiene-augmented scoring as a method.

B. Why EPSS-Self-Driven Destroys Everything

The K=200, T_{EPSS} column of Table II contains the most extreme cell in the grid. Five W6 P@50 values, all in $[0.000, 0.012]$. The mechanism is ground-truth-set exhaustion: EPSS-only's selection at K=200 removes the high-EPSS tail so fast that the binary positive condition (EPSS > 0.10) is satisfied by an essentially empty residual backlog. Once the positive set is empty, P@50 is mechanically zero regardless of which scorer is being evaluated — you cannot rank a non-existent positive.

This is a stronger version of the Paper 6 capacity collapse story. Paper 6 documented that HygienePrio drains the HRS tail; the present paper shows that EPSS-only drains its own EPSS tail to a literal zero floor. Both are recursive-deployment artefacts; neither is an intrinsic scoring failure.

C. What Paper 5's 96% Per-Pair Dominance Actually Means

Paper 5 reported that HygienePrio-full > EPSS-only at P@50 in 96.0% of (cell, seed, window) triples under the (then-implicit) HygienePrio-driven trajectory. The present paper finds that this statistic survives at $K = 50$ under every driver (always 1.000), survives at $K = 200$ under HRS, CVSS, and Random drivers (1.000), partially survives at $K = 200$ under HygienePrio's own driver (0.800), and does not survive at $K = 200$ under the EPSS-only driver (0.393). The interpretation: per-pair dominance is a robust property of HygienePrio under any HRS-blind selection, including the natural baselines an operations team would deploy if not using HygienePrio's score for selection. Under the EPSS-self-driven regime both methods collapse together, and the comparison becomes degenerate.

D. What Paper 6's H4 Rejection Means After This Paper

Paper 6's H4 rejection now reads as follows. HygienePrio-full's absolute W6 P@50 at $K \geq 100$ is degraded only when HygienePrio also drives the trajectory. The mechanism is recursive HRS-tail exhaustion. On any non-HP driver, the absolute floor is intact at the Paper 5 level ($\sim$ 0.5 or higher). The original H4 hypothesis "HygienePrio retains $\geq$ 0.4 at every cell" is re-supportable under the qualified statement "on every cell, on at least one non-HP driver". We do not formally re-test Paper 6 H4 here because doing so would constitute hypothesising after results known (HARKing); we report the observation honestly and leave a new pre-registered H4-style restatement to future work.

E. Why the Trajectory Effect is Asymmetric Across Scorers

The trajectory-effect range Δ_m^{traj} is largest for HP-full and EPSS-only and smallest for CVSS-only and Random. The asymmetry has a clean structural interpretation: a scorer's W6 performance depends on whether the driver preferentially drained the ground-truth-positive tail that the scorer relies on. HP-full relies on the HRS upper tail; HP-driven drains it. EPSS-only relies on the EPSS upper tail; EPSS-driven drains it. CVSS-only relies on the CVSS upper tail (which is not part of the ground-truth condition) so no driver in the grid preferentially drains it. Random relies on no signal. The two scorers most sensitive to trajectory are the two scorers whose ranking is most aligned with the ground-truth positive set — which is the same property that makes them the strongest scorers in the first place.

F. Operational Recommendations

Sharpened from Papers 5–8:

- Use HygienePrio for scoring across all studied capacity regimes; its per-pair dominance over EPSS-only is preserved whenever the deploying organisation does not also use HygienePrio as the selection policy at high capacity.
- Do not let HygienePrio be both the scorer and the queue-driving policy at $K \geq 100$. Either (i) decouple — use HygienePrio for ranking but let another policy (ticketing system, CVSS queue, human triage) drive the patching cycle, or (ii) accept the Paper 6 H4-style collapse as the cost of full automation.
- Do not deploy EPSS-only as both scorer and selection policy at high capacity. EPSS-self-driven at K=200 produces a literal zero floor by W6.

G. Relationship to the Research Sequence

This paper closes a gap that Papers 5–8 explicitly bounded but did not measure. The cumulative arc is unchanged in spirit: hygiene augmentation helps prioritization. But the headline "HygienePrio holds up across regimes" is now sharper. It holds up across regimes except when HygienePrio itself is the recursive driver of fleet evolution at high capacity. That last condition is operationally controllable, and the recommendation is to control it.

X. Threats to Validity

The threats taxonomy follows Wohlin et al. [6].

Conclusion validity. The 7,500-row evaluation supports ~ 50-row cell-means per (K, driver, scorer, window) — a reasonably tight estimator. Bootstrap CIs (10,000 resamples) at the W6 cells separate the HP-driven HP value (0.075) from the CVSS/HRS/Random-driven HP values (0.701–0.713) without overlap. The qualitative finding does not depend on the CI width.

Internal validity.

(i) Per-window ground truth re-uses HRS percentiles. The binary positive condition incorporates HRS > 75th percentile recomputed each window. Under HP-driven and HRS-driven trajectories, the recomputed percentile threshold moves substantially each window; under CVSS-driven and Random-driven trajectories, it moves less. This means the "HP scored on T_CVSS" cell is operating against a relatively stable positive set whose composition is similar to W1, while the "HP scored on T_HP" cell is operating against a fast-moving positive set. The non-identifiability is unavoidable under the per-window threshold convention; we report it transparently and bound claims to that convention.

(ii) The EPSS-self-driven collapse is partly a structural artefact. When EPSS-only's selection drives evolution at K=200, nearly all CVEs with EPSS > 0.10 are remediated by W3–W4, and the ground-truth positive condition $EPSS > 0.10$ becomes near-empty. The literal zero W6 P@50 values reflect an essentially empty positive set, not a scoring failure. We report this honestly; the qualitative finding ("EPSS-self-driven is the deepest sink") is robust but should not be read as "EPSS-only is the worst scorer".

(iii) Two cells only. K=50 and K=200 anchor low and collapse regimes; K=100 and K=150 cells are interpolations not measured here. The Paper 6 H4 dataset can be used by readers to fill in the K=100 cell under HP-driven trajectory.

Construct validity. P@50 with binary relevance, recomputed-per-window HRS-percentile ground truth, and fixed Paper 4 scorer weights are inherited from Papers 5–8. We deliberately do not vary calibration strategy (the Papers 7–8 axis) because doing so would interact with the trajectory question; isolating one effect at a time is a methodological choice that the protocol locks.

External validity. Inherited from Papers 4–8: synthetic EEHDA structural priors, 14-day window, 0.15 patch debt reduction, 0.02 EPSS random walk, 8% KEV prevalence. The qualitative finding — that recursive-deployment collapse is selection-induced — is more robust than any specific number; the specific W6 levels (0.075 vs 0.701) are distributional. External validation on real fleet telemetry with longitudinal exploitation outcomes is the appropriate next step.

XI. Related Work

Trajectory-coupling threat in Papers 5–8. Paper 5 [2] §9, Paper 6 [1] §9, Paper 7 [3] §9, and Paper 8 [7] §9 all acknowledge the HygienePrio-driven trajectory as an internal-validity threat. Each cited a "fully factorial each-method-drives-its-own" future-work item as the appropriate counterfactual. The present paper implements that counterfactual in a pre-registered form.

High-capacity collapse in Paper 6. Paper 6 reported HygienePrio-full's W6 P@50 collapse at $K \in \{100, 200\}$

and attributed it to high-HRS-tail exhaustion. The present paper retains the collapse statistic on the HP-driven trajectory but shows it disappears under HRS-blind drivers, revising the interpretation from “intrinsic property of hygiene-augmented scoring at high capacity” to “closed-loop artefact of recursive deployment”.

EPSS dynamics. Jacobs et al. [8], [9] established per-CVE exploit-prediction scoring. Ravalico et al. [10] studied per-CVE EPSS score drift. The present paper documents a distinct effect: EPSS-as-policy remediation at high capacity exhausts the ground-truth positive set within six windows on the simulated fleet, producing a literal zero floor for every scorer evaluated against that trajectory. Neither prior study addressed the policy-level effect.

Counterfactual evaluation in security ML. The general pattern — evaluating method A on the data trajectory that method B would have generated — appears in counterfactual learning to rank and off-policy evaluation. The instance studied here is the simplest form: a deterministic policy generates the trajectory, and the counterfactual is computed by re-running the simulation under each candidate policy. We do not survey the broader counterfactual-policy literature; the question this paper resolves is operationally specific to the Paper 6 H4 claim.

Cyber-hygiene benchmarking. HygieneBench [11], HygienePrio [4], the temporal extension [2], capacity sweep [1], online calibration [3], and multi-history calibration [7] together constitute the methodological substrate within which this paper sits.

Policy mandates. CISA BOD 22-01 [12] and 23-01 [13] along with NIST SP 800-40 Rev. 4 [14] define the operational scheduling regime under which any vulnerability-prioritization deployment must operate. The recommendation that scoring and selection should be decoupled at high capacity follows from this paper’s findings and aligns with the spirit of the BOD mandates’ separation of discovery, prioritisation, and remediation roles.

XII. Conclusion

A pre-registered 7,500-row self-trajectory evaluation of the five HygienePrio-family prioritization methods at $K \in \{50, 200\}$, $\lambda = 3$, $W = 6$, on the 25 evaluation seeds inherited from Papers 5–8, produces three findings that retroactively reframe the research sequence.

First, Paper 6’s headline “HygienePrio collapses at high capacity” is rejected as an intrinsic property of hygiene-augmented scoring. At $K = 200, w = 6$, HygienePrio-full’s mean P@50 is 0.075 on its own trajectory but 0.701 on CVSS-driven, 0.713 on HRS-driven, and 0.706 on Random-driven trajectories. The collapse is a recursive-deployment artefact: HygienePrio’s own selection preferentially drains the HRS upper tail that HygienePrio’s score depends on.

Second, EPSS-only’s selection at $K = 200$ produces a literal zero W6 P@50 for every scorer (range 0.001–0.012). The ground-truth positive set is structurally exhausted by EPSS-only’s aggressive remediation of the high-EPSS tail. EPSS-self-driven at high capacity is the deepest sink in the studied grid.

Third, HygienePrio’s per-pair dominance over EPSS-only is trajectory-conditional. At K=50 it is 1.000 under every driver; at K=200 it is 1.000 under HRS, CVSS, and Random drivers, 0.800 under HP’s own driver, and 0.393 under EPSS-only’s driver (where both methods collapse together). Paper 5’s 96% headline statistic is preserved at moderate capacity and under HRS-blind drivers — the regimes most relevant to actual deployment.

The operational reading is sharper than Papers 5–8 allowed: HygienePrio is a strict improvement over EPSS-only across the studied regimes whenever the deploying organisation does not let HygienePrio also drive the patching queue at high capacity. The Paper 6 H4 collapse is a known closed-loop hazard, not a property of the scoring method itself, and is operationally controllable by decoupling scoring from selection.

Reproducibility. The runner, analysis script, pre-registration protocol, and frozen 7,500-row results CSV are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper9.

Future work. (i) A pre-registered re-test of Paper 6’s H4 hypothesis under the qualified statement “on every cell, on at least one non-HP driver”. Doing this rigorously requires a fresh seed set to avoid HARKing on the present data. (ii) Trajectory effects on calibration: do Paper 7’s lag-1 recovery ratio and Paper 8’s smoothing penalty change under non-HP drivers? Both papers measured under T_HP only. (iii) External validation on real fleet telemetry with longitudinal exploitation outcome data. (iv) A cross-trajectory evaluation in which the scorer also predicts the next-window driver, modelling a fully adaptive closed-loop policy rather than two static ones.

References

[1] H. Malla, “Capacity-indexed decay of exploit-likelihood vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] ——, “Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[3] ——, “Rolling-history online calibration for hygiene-augmented vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[4] ——, “HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[5] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[6] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[7] H. Malla, “Multi-window-history calibration: Does smoothing reverse the high-capacity hazard of lag-1 online recalibration?” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[8] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[9] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.

[10] A. Ravalico, L. Allodi, and F. Massacci, “On the temporal dynamics of the EPSS score,” SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459

[11] H. Malla, “HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection,” 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[12] CISA, “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[13] ——, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[14] NIST, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.